# 🌐 Module 03: Open Source Intelligence (OSINT) and Attack Surface Mapping

```
# Exercise 5: Identifying and Mapping Attack Surface
```

### Scenario

Attack surface mapping is a critical step in penetration testing, combining insights gained from OSINT with detailed scanning and analysis to identify and evaluate potential entry points and vulnerabilities within a target's infrastructure. This process provides a comprehensive understanding of publicly visible and exploitable components, enabling penetration testers to plan further testing phases effectively. By thoroughly mapping and scanning the attack surface, penetration testers can prioritize vulnerabilities, develop targeted exploitation strategies, and recommend effective defenses. Attack surface mapping ensures that penetration tests are both effective and aligned with the organization's specific security challenges.

### Objective

The objective of this lab is to help students learn how to identify and map attack surfaces:
- Discover Network Devices with Netdiscover and Nmap
- Scan with the Tool DMitry
- Scanning and Scripting with hping3
- Automate Penetration Testing Tasks Using Bash Scripting
- Using Workspaces and db_nmap
- Scanning and Building a Target Database
- OS Fingerprinting with Nmap
- Use AI to Perform Network Scanning

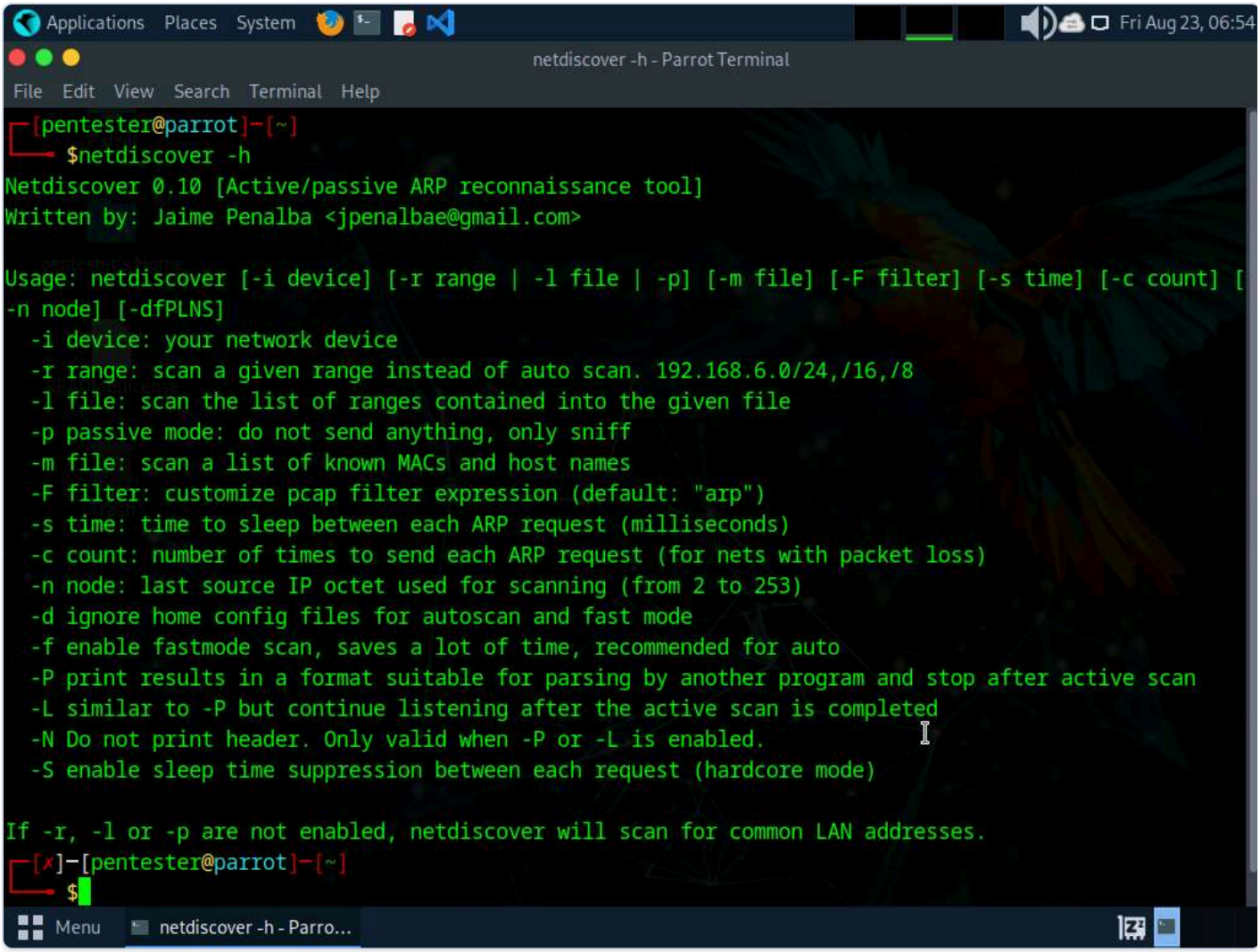
---

## Task 1: Discovering Network Devices with Netdiscover and Nmap

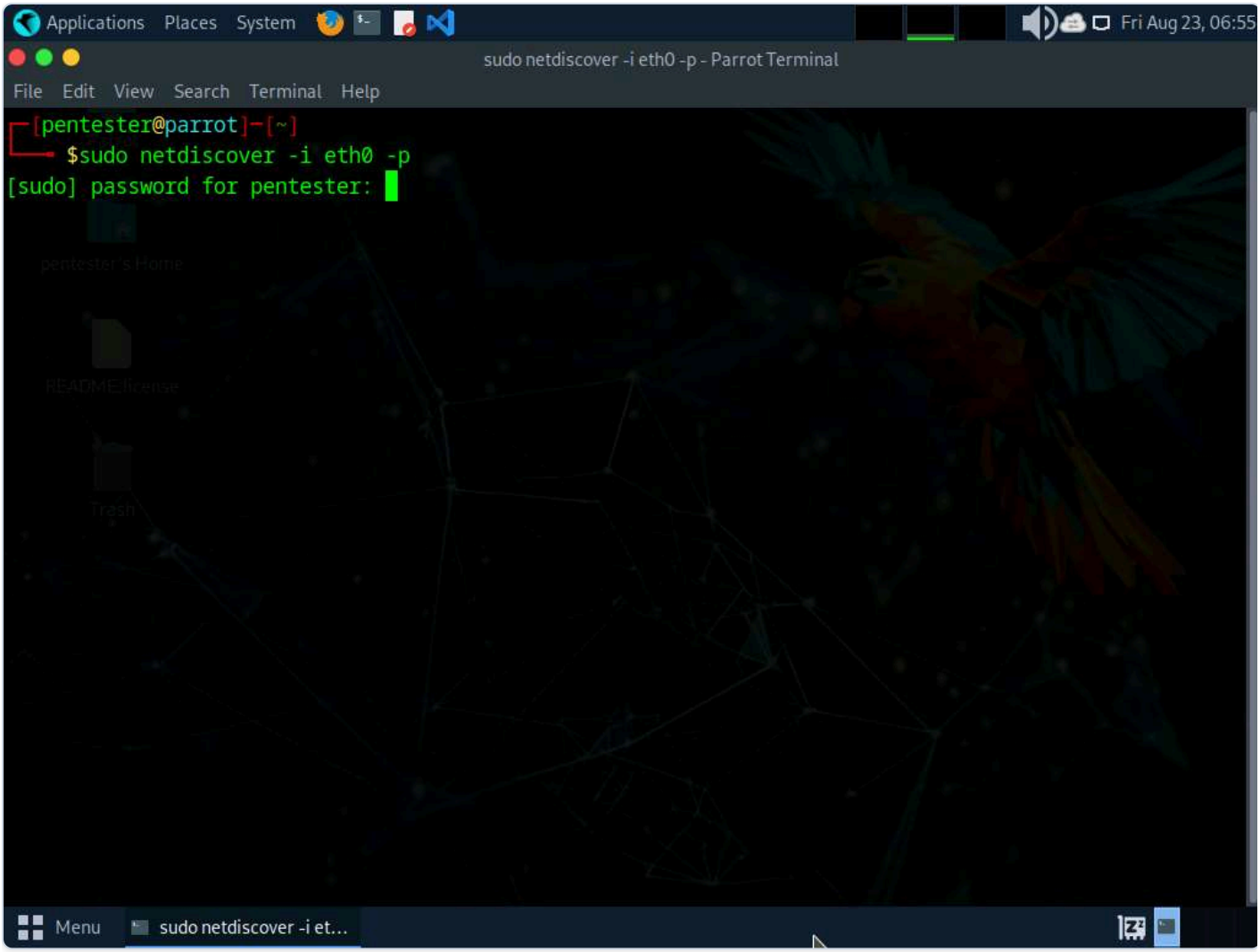
To begin the lab, a proficient tester may use any tool depending on his or her personal preference. The objective of this lab is to help students use the Netdiscover and Nmap tools. Netdiscover is a network address discovering tool, developed mainly for those wireless networks without a DHCP server, it also works on hub/switched networks. It is based on arp packets, it will send arp requests and sniff for replies.

### Lab Tasks

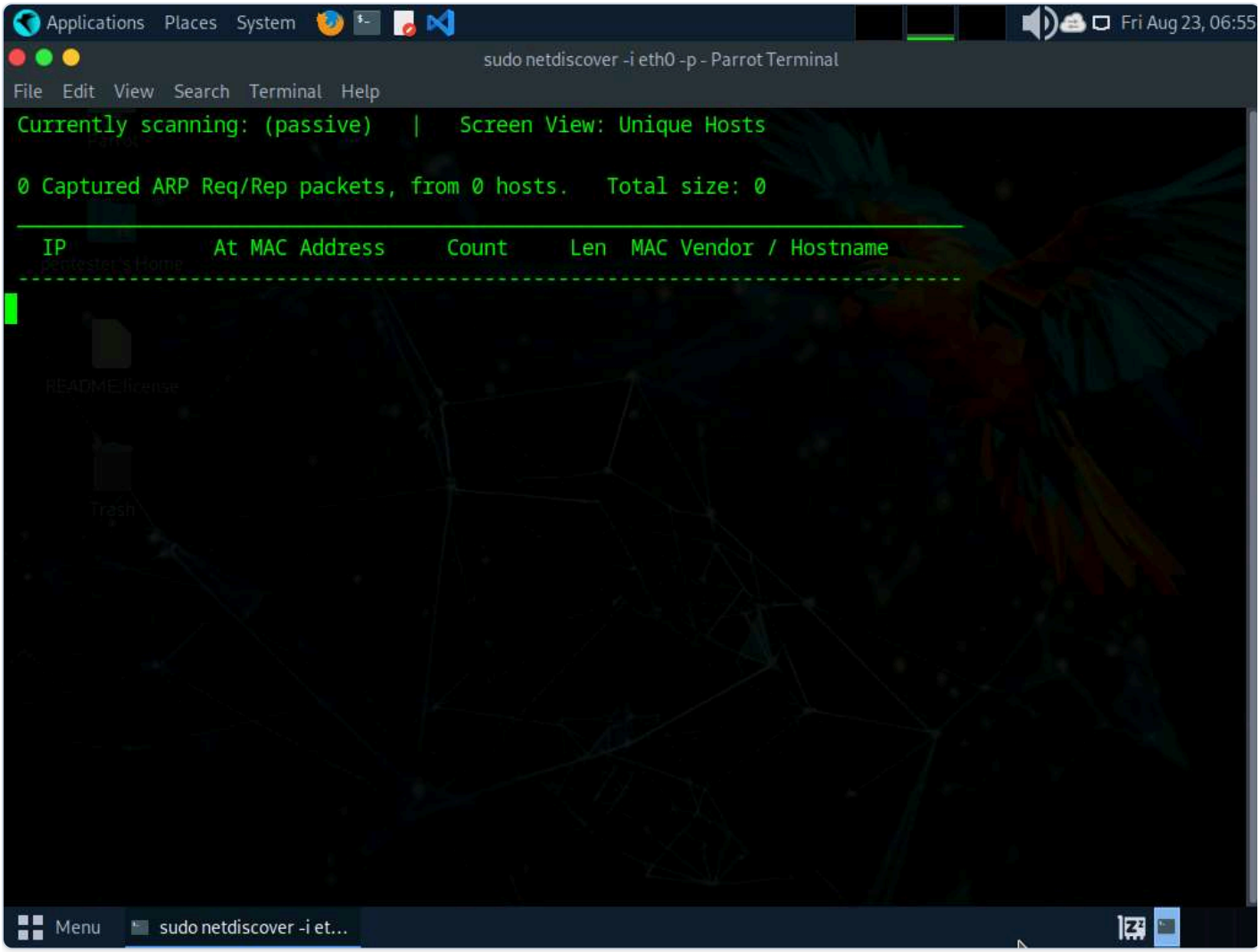
1. Click **Parrot Security**. By default pentester is selected as the user. Type **toor** in the Password field and press Enter.
2. Open a terminal window and enter **netdiscover -h**. This will display the netdiscover commands as shown in the screenshot:



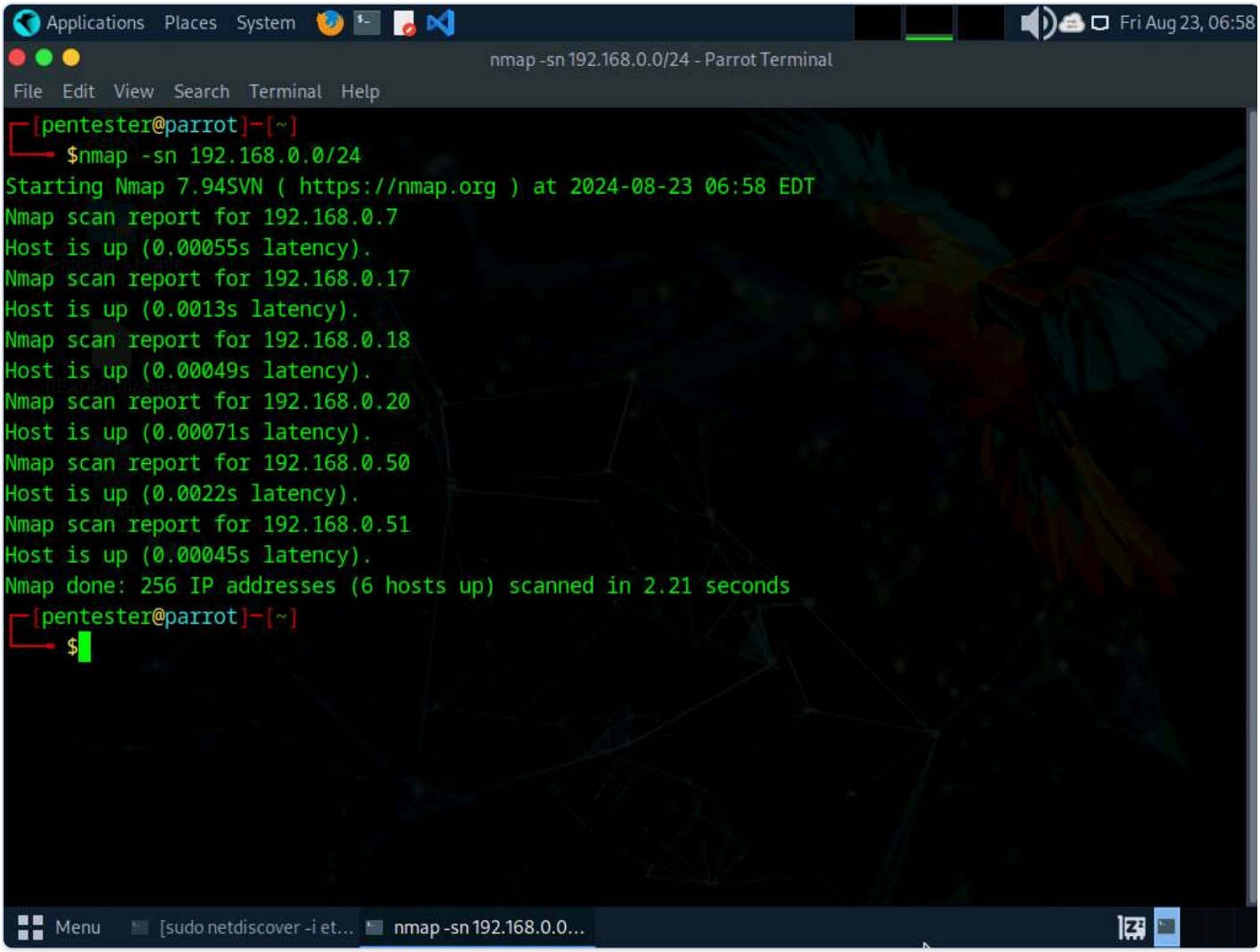

1. This tool allows the user to discover live systems. In the terminal window, enter **sudo netdiscover -i eth0 -p**. If you are asked to enter a password, enter **toor**.



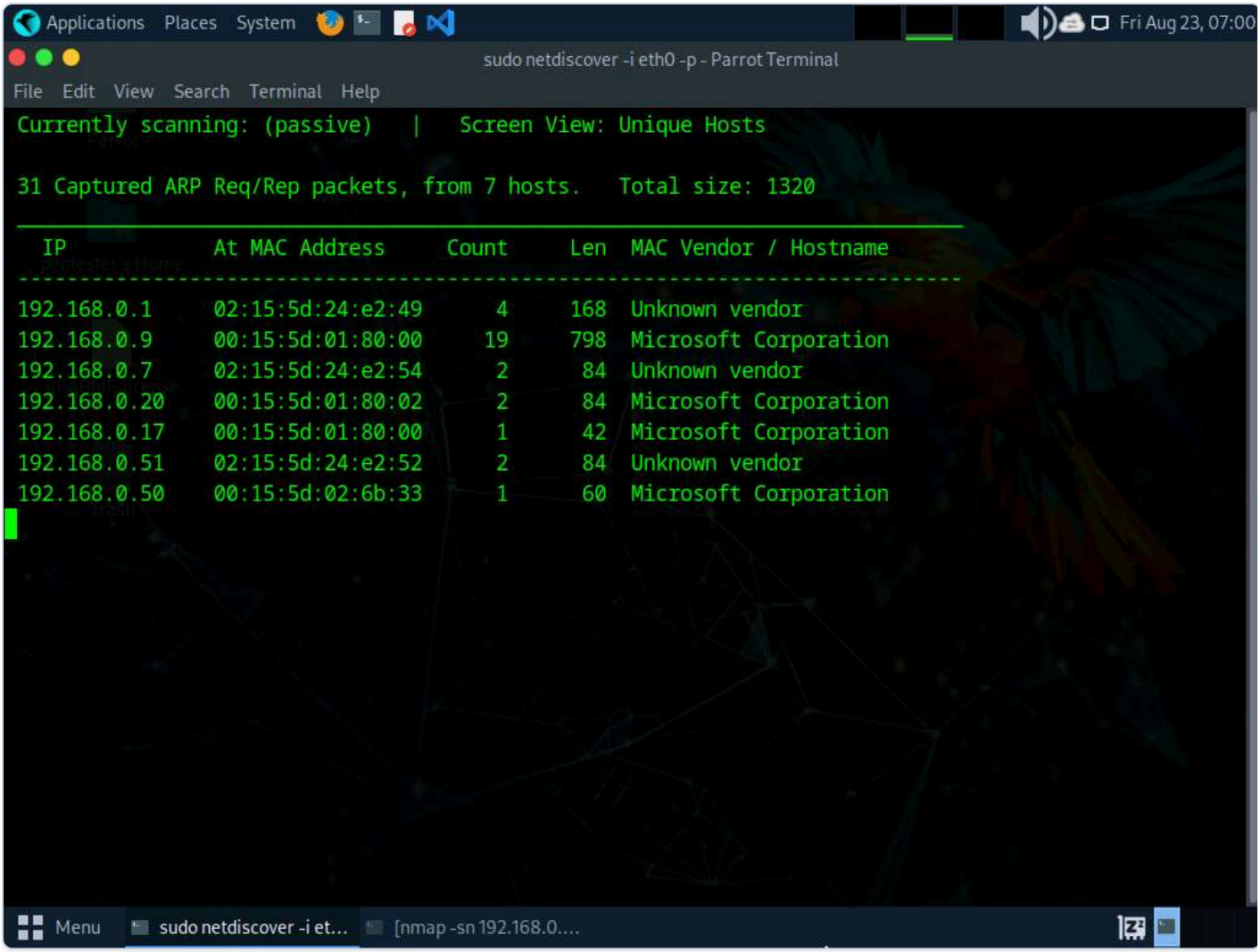

1. In the passive option, targets are generated slowly. It takes a lot of time to display the result. To save time, you can create your traffic by doing a ping sweep using nmap which is demonstrated in the next step.



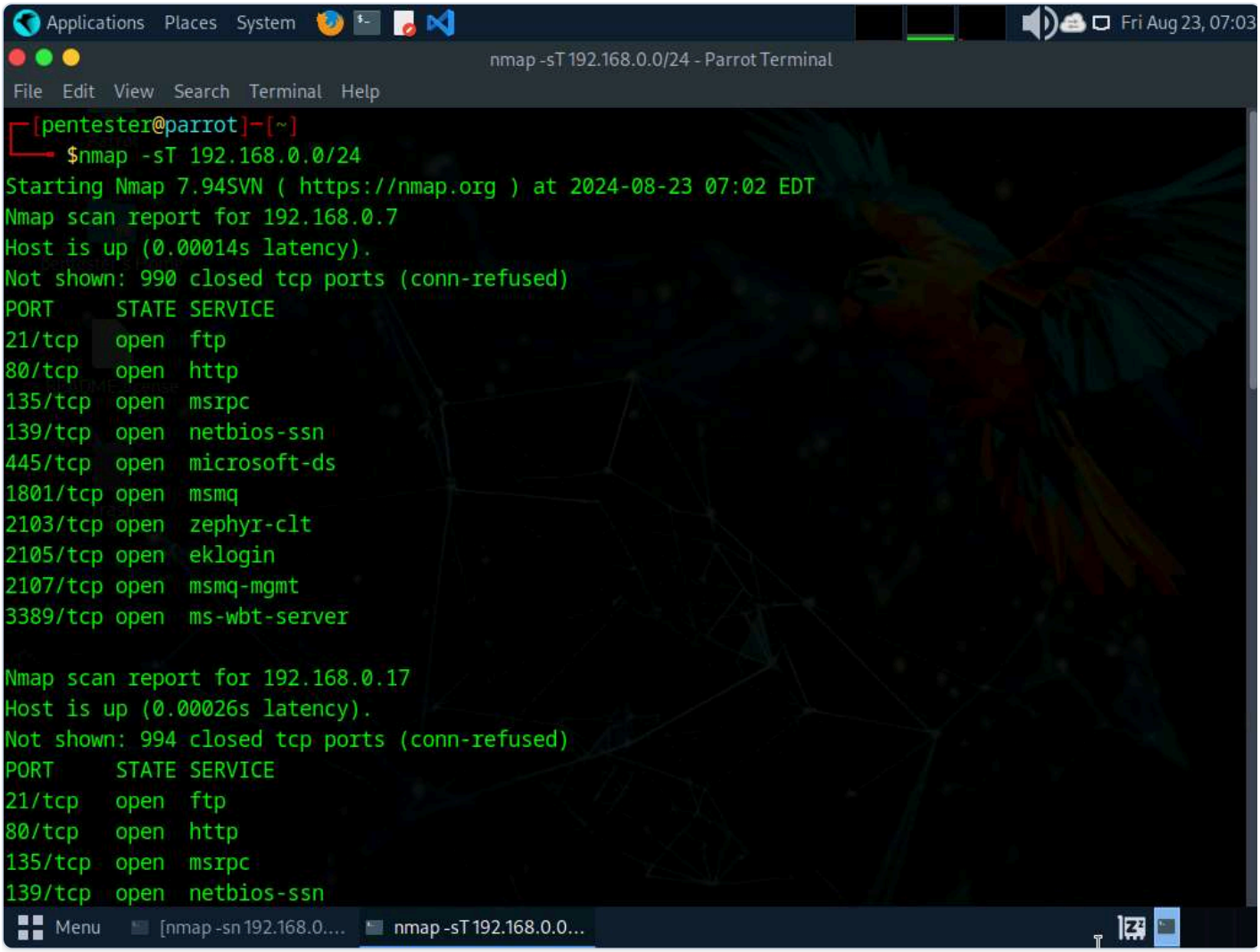

1. In a new terminal window, enter the nmap ping sweep command to generate traffic. To do a ping sweep, type **nmap -sn 192.168.0.0/24** and press Enter.



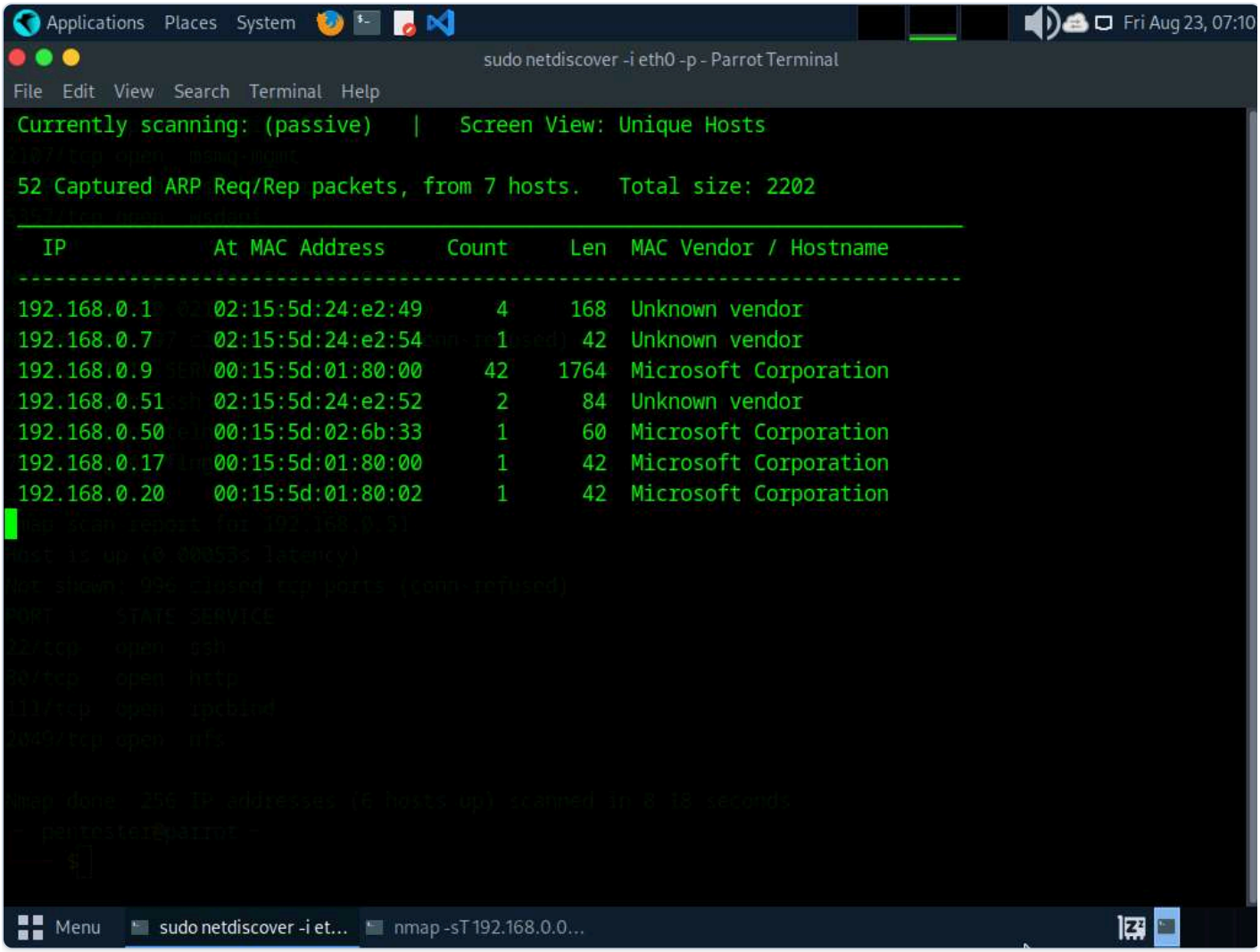

1. Switch back to netdiscover window to view the output.



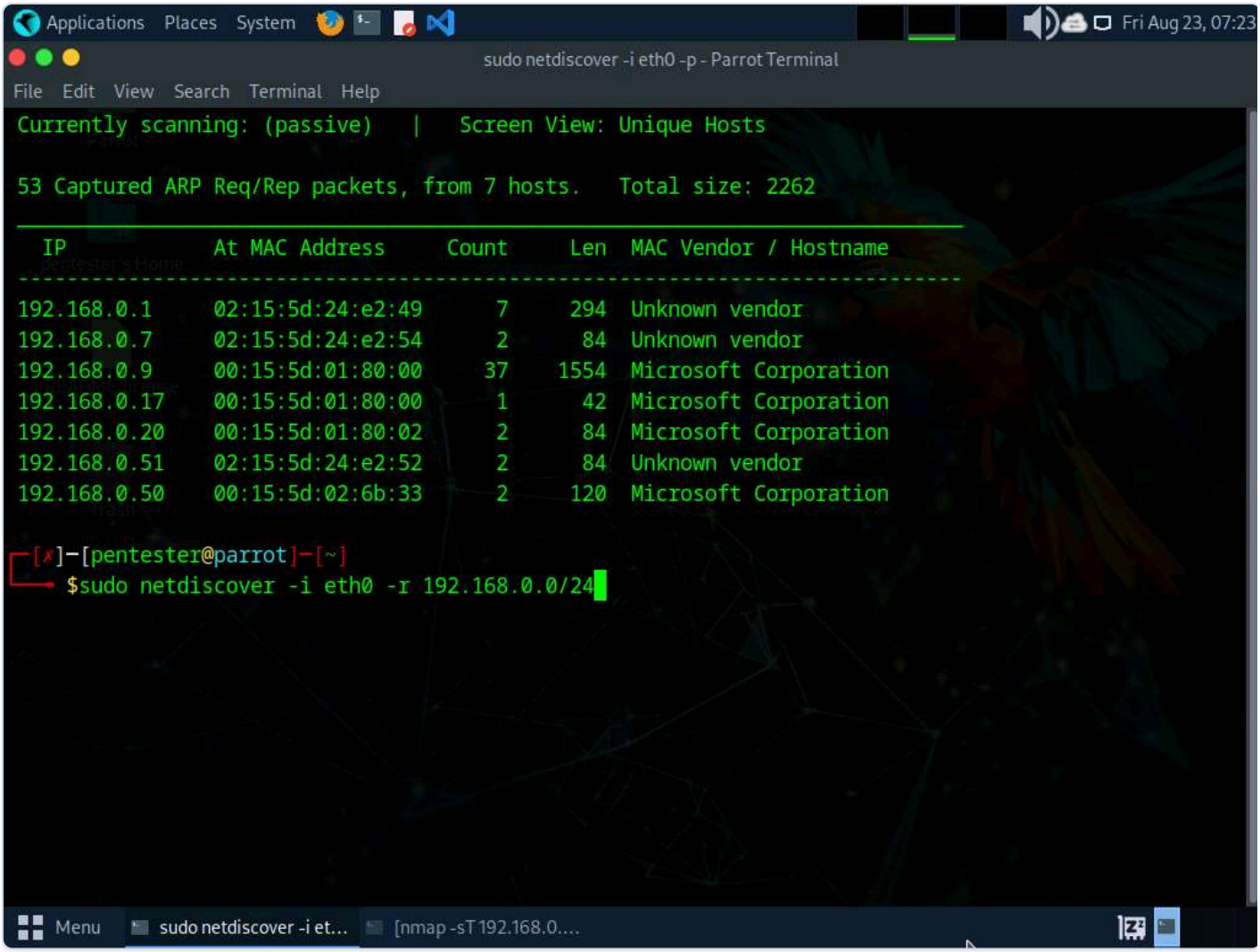

1. At times, some machines may not be discovered due to reasons such as the existence of a firewall or some other filter. In such a situation, you may use a Transmission Control Protocol (TCP) scan to confirm the existence of the new machine. To perform a TCP scan, enter the command **nmap -sT 192.168.0.0/24**.



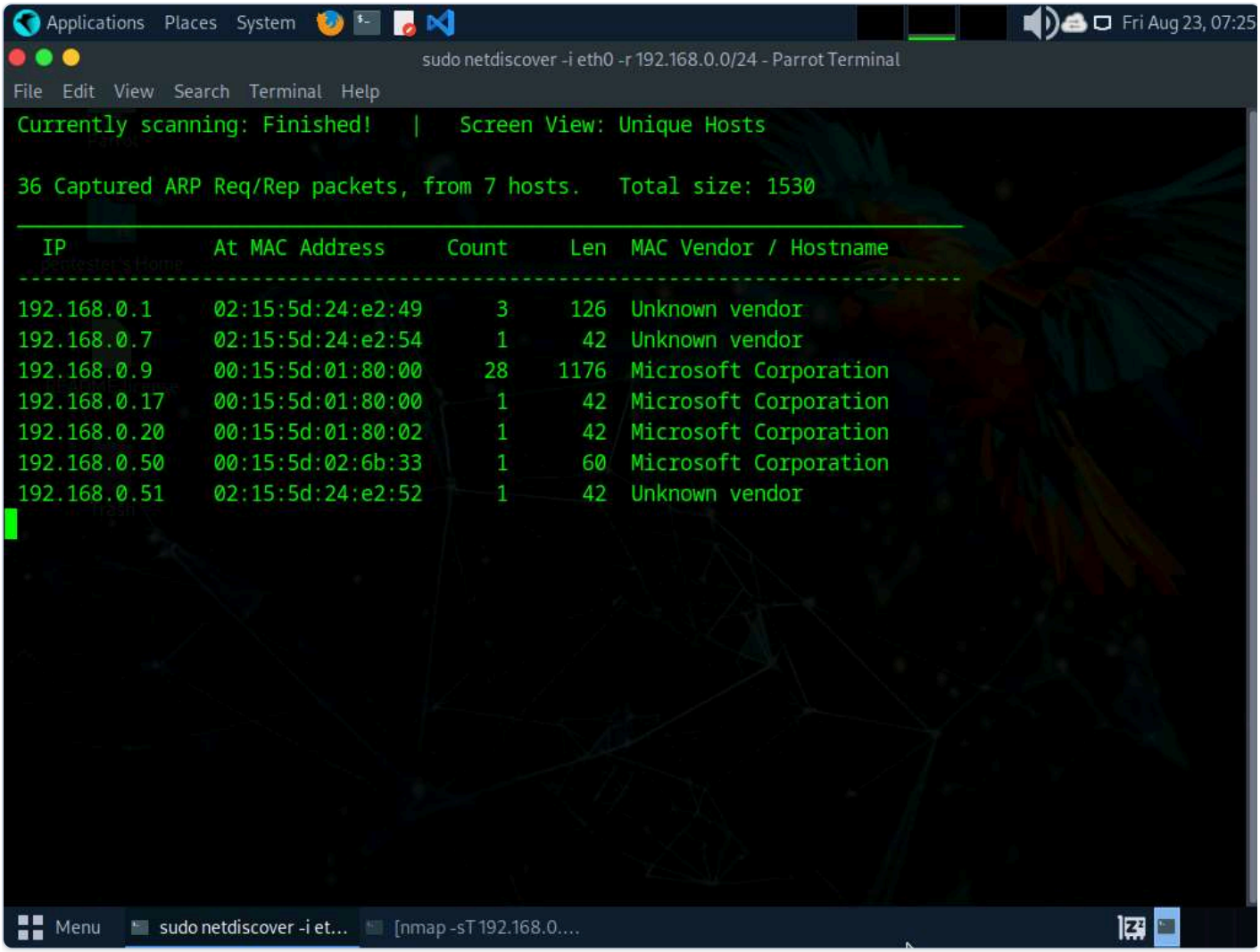

*(Note that you have not scanned all 65,536 ports, which is preferable. Depending on the target machines' settings, access to and data obtained from this machine may be limited. Upon scan completion, switch back to the netdiscover window to view the output. In this lab, the netdiscover output remains the same, as no new machines were discovered during the nmap scan.)*




1. If stealth is not part of the scope of the test and a passive scan is unnecessary, an active scan is the best choice. To discover targets, use Netdiscover as a scanner. To search for the network for targets, exit the current netdiscover scan, type **sudo netdiscover -i eth0 -r 192.168.0.0/24** in the terminal window, and press Enter. If you are asked to enter a password, enter **toor**.




1. The targets will be displayed on the screen after some time, as shown in the screenshot. *(To speed up the process, you can run a nmap ping sweep scan.)*




This new method validates your live and target machines. This concludes the lab exercise.

---

> **IMPORTANT:** ❓ **Question 3.5.1.1** On the Parrot Security machine, use Netdiscover and Nmap to identify network devices. Perform a TCP scan with Nmap to determine the number of open ports on the machine with the IP address **192.168.0.51**. [!SUCCESS] ✅ **Answer:** **4**

---

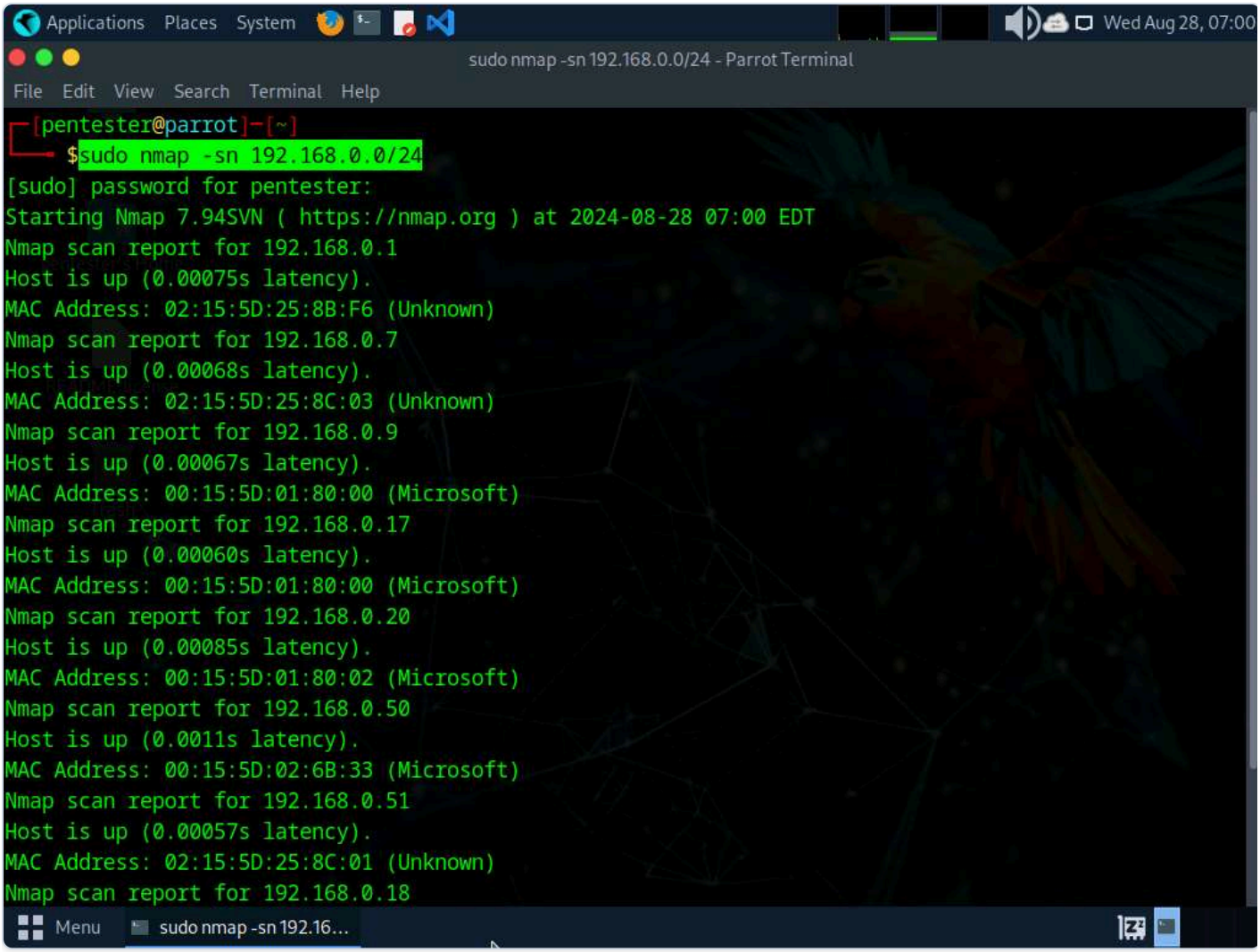
## Task 2: Performing Networking Scanning using DMitry Tool

To begin the lab, a proficient tester may use any tool depending on his or her personal preference. The objective of this lab is to help students use the DMitry tool. The following activities are included in this lab:
- Start the DMitry tool
- Setup the network environment
- Scan and review the data from the DMitry tool

### Lab Tasks

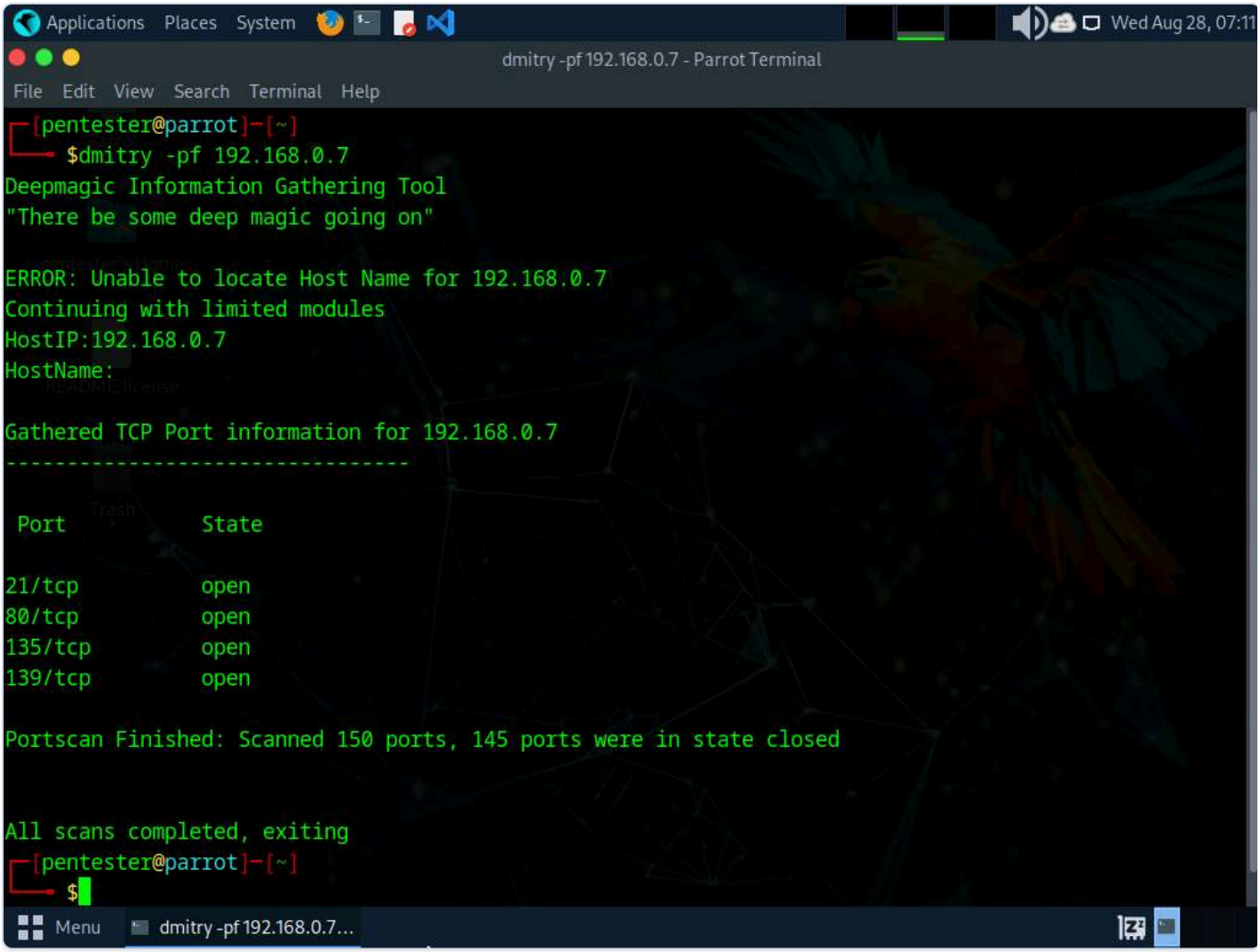
Obtain the list of targets using the following scanning methodology: Live Systems, Ports, Services, Enumeration, Identify vulnerabilities, Exploitation.

1. Open a new terminal, enter **sudo nmap -sn 192.168.0.0/24**. Type **toor** if you are asked to enter the password. An example of a partial output from the command is shown in the screenshot.



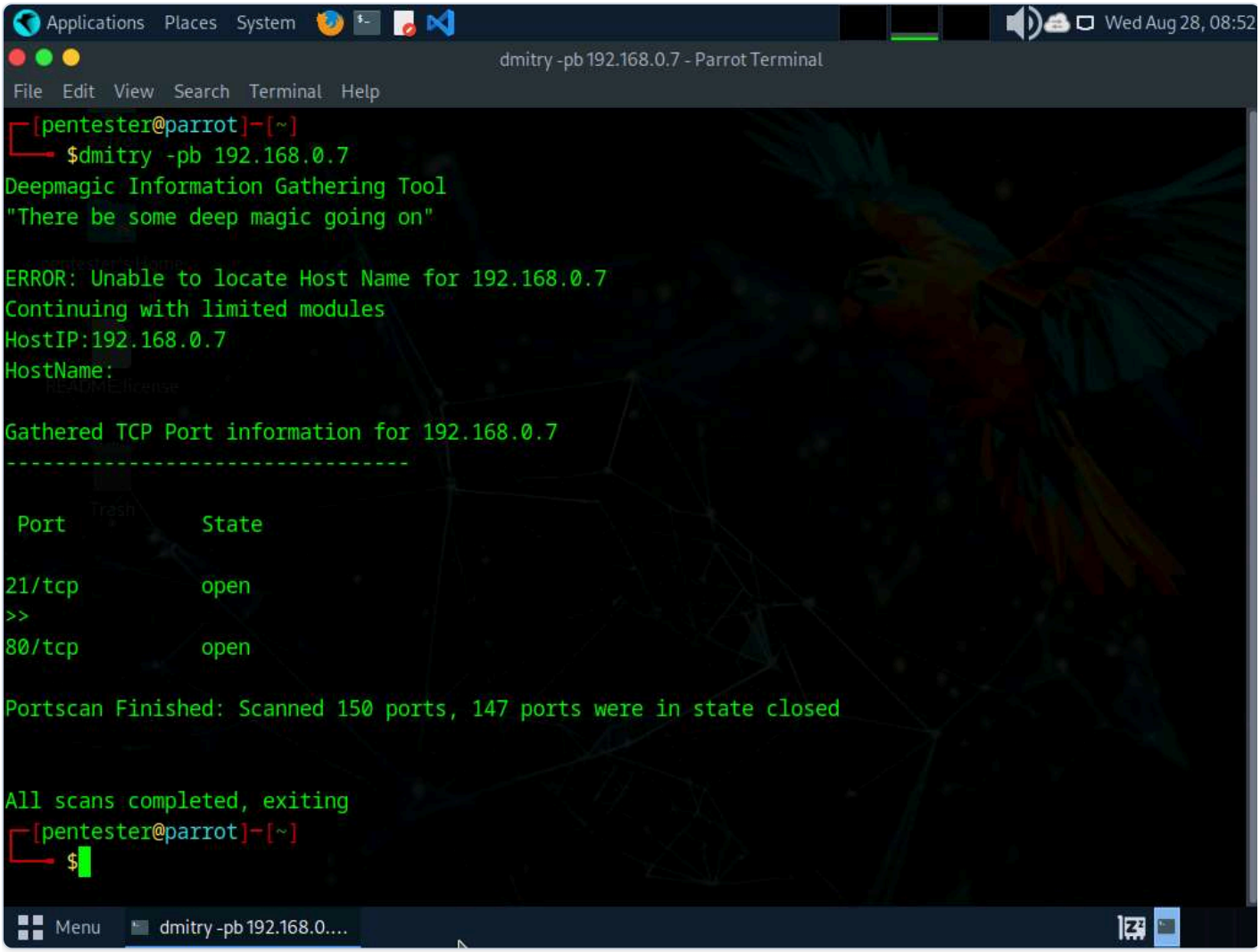

*(The scan reveals a selection of targets, records information about the targets, and determines which ones to target. Since you have used the Nmap tool, switch to another tool. Note that this module requires proficiency in at least two to three tools for each step of the process.)*

1. Open a terminal window and enter **dmitry -pf 192.168.0.7**, as shown in the screenshot.




*(The DMitry tool, a port scanner, provides all port information; for more information about the tool, please see the man page.)*

1. In the terminal window, enter **dmitry -pb 192.168.0.7**, as shown in the screenshot.




*(You are now viewing a banner grab as well as a port scan, as shown in the above screenshot.)*

If there is time, continue using the tool and explore more options. This concludes the lab.

---

> **IMPORTANT:** ❓ **Question 3.5.2.1** On the Parrot Security machine, use the Dmitry tool to perform a port scan on the **192.168.0.51** host and record the number of open ports detected. [!SUCCESS] ✅ **Answer:** **3**

---

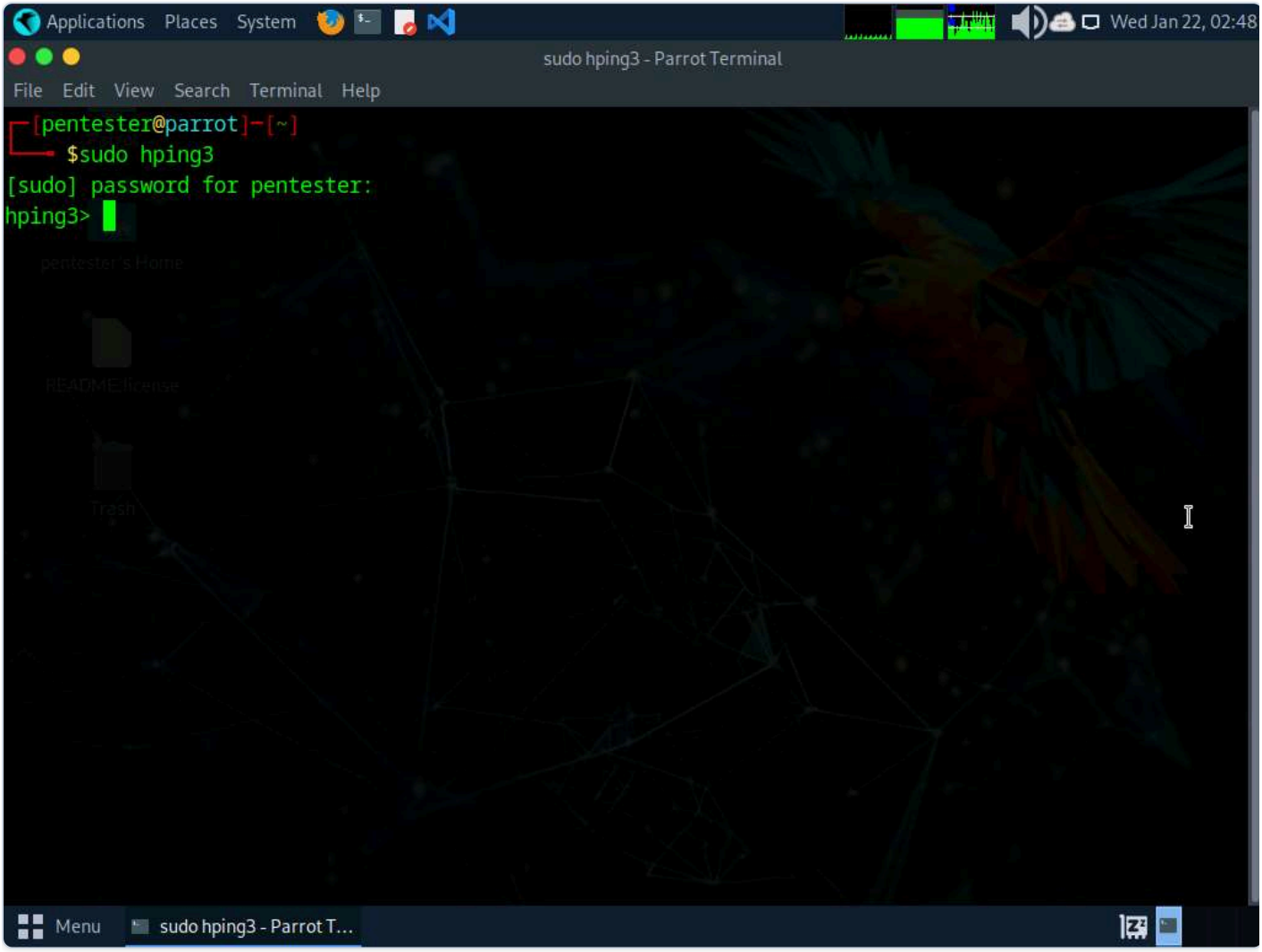
## Task 3: Scanning and Scripting with hping3

To begin the lab, a proficient tester may use any tool depending on his or her personal preference. The objective of this lab is to help students use the hping3 tool.

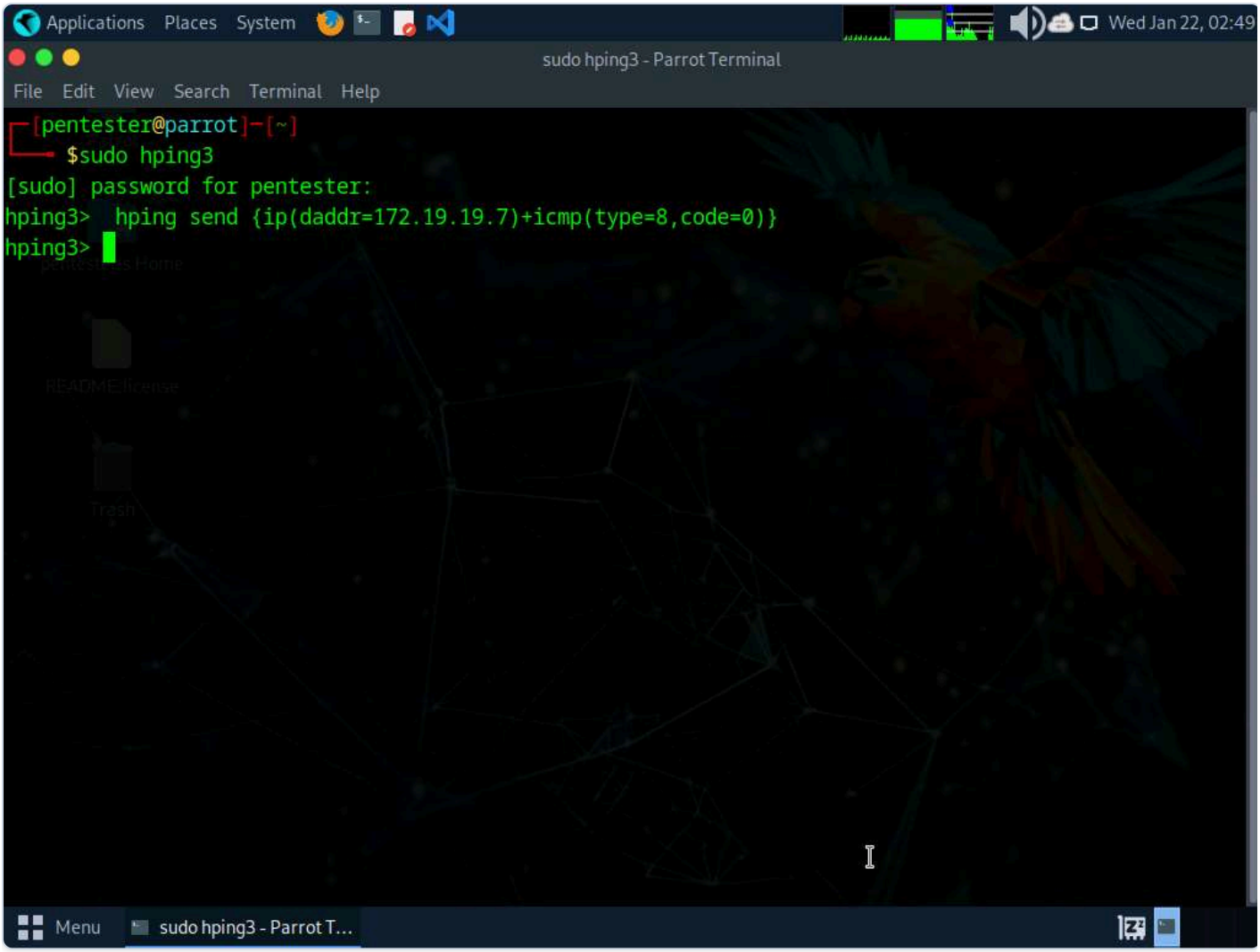
In this lab, you will:
- Start the hping3 tool
- Conduct a query with hping3
- Check hping3 capabilities
- Execute a simple script within the hping3 command environment
- Capture packets with hping3
- Conduct a hping3 scan
- Review the data from the scan
- Send files using ICMP

## Lab Tasks

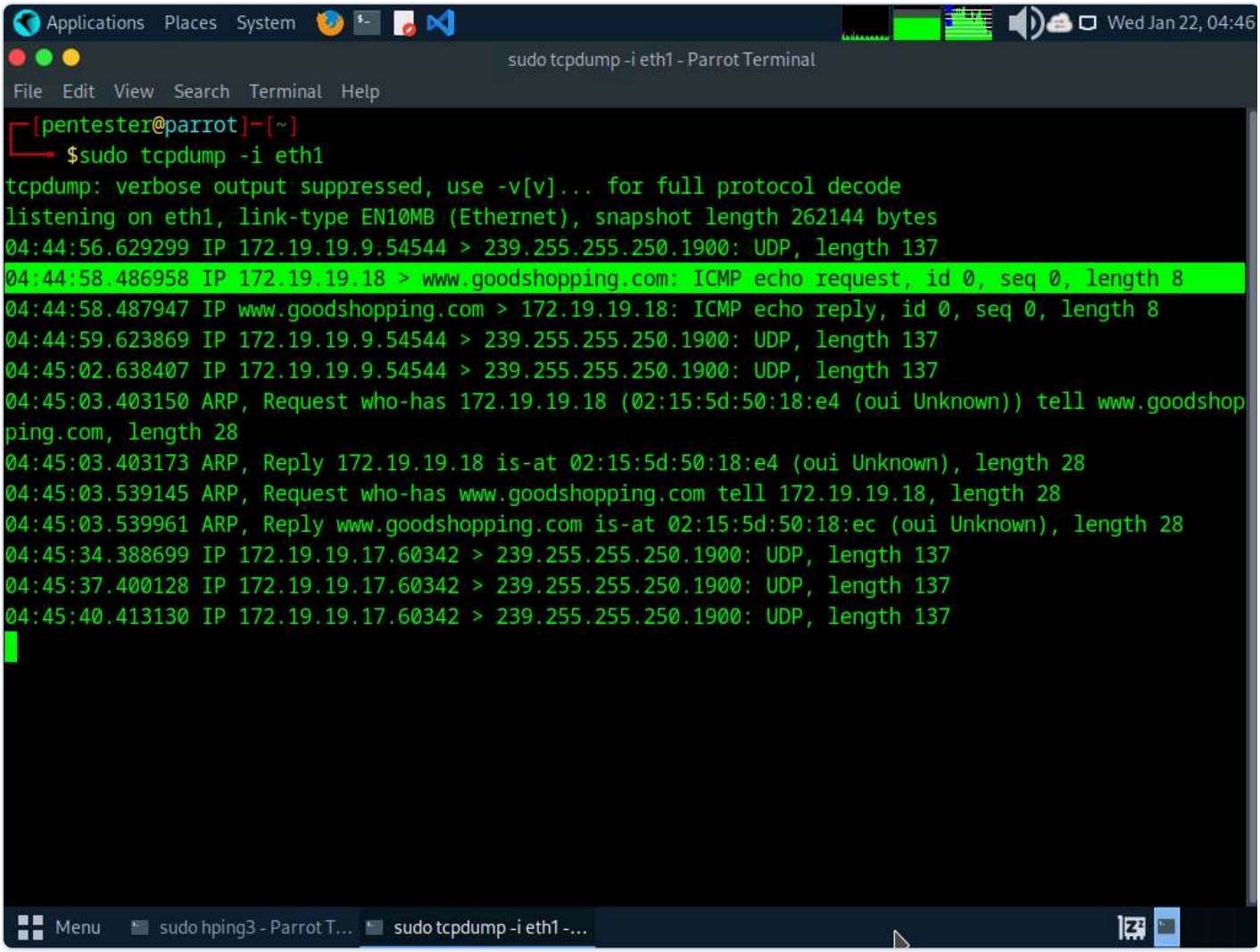
1. Click **Parrot Security**. The Parrot lock screen appears. By default pentester is selected as the user. Type **toor** in the Password field and press Enter.
2. Hping3 is a powerful tool. It is a TCL scripting engine contained within a shell. For the first attempt, practice with a few commands.
3. To begin the lab, launch hping3 by issuing the command **sudo hping3** in a command line terminal. If you are asked to enter a password, type **toor** and press Enter.



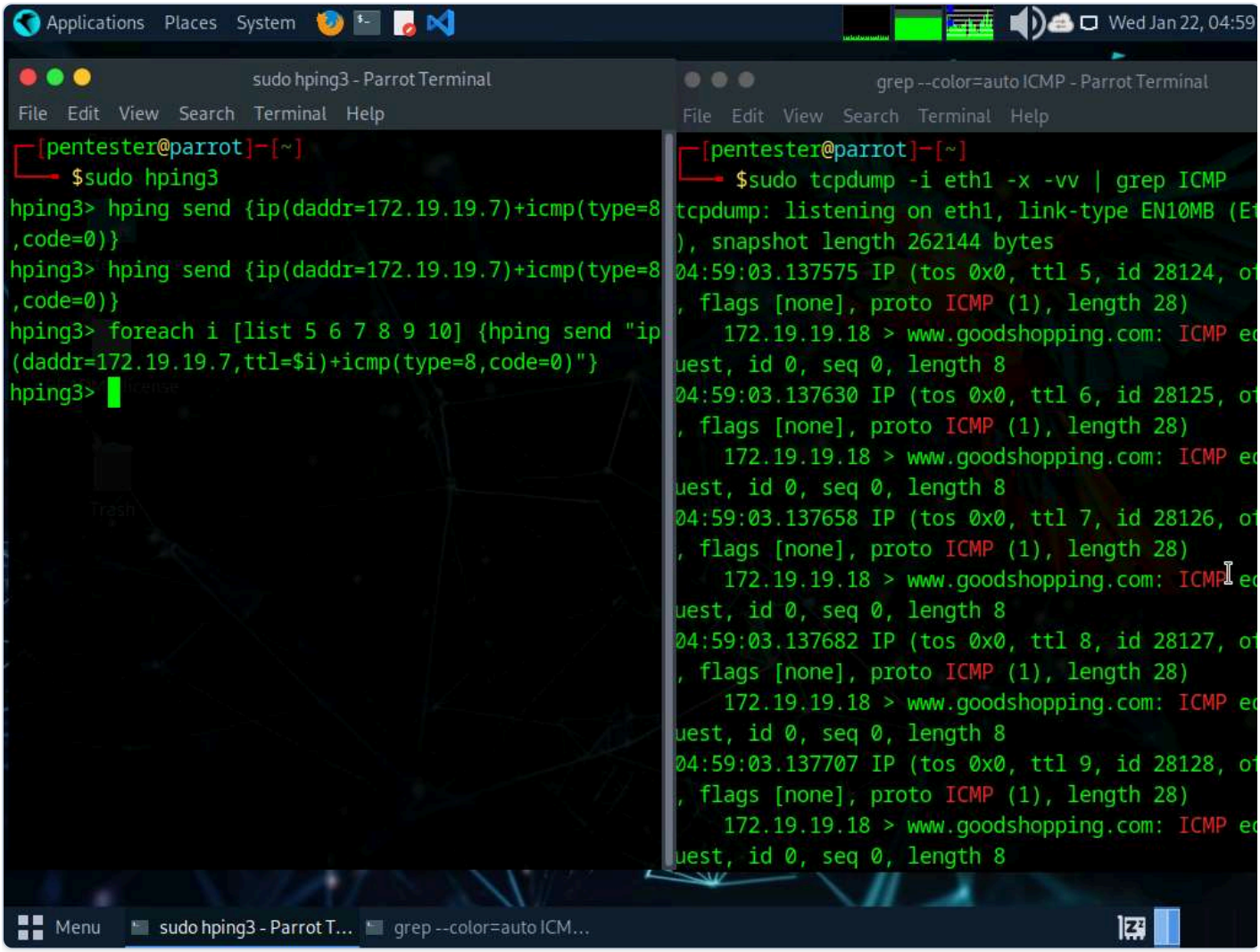

1. The first command will send a simple Internet Control Message Protocol (ICMP) echo request to a target. Select one of the available targets you have discovered and enter the following command, replacing the IP address with that of the machine you are targeting. In this lab, we are targeting **172.19.19.7**. So, type:
   **hping send {ip(daddr=172.19.19.7)+icmp(type=8,code=0)}**
   Press Enter. This command will send an ICMP type 8 code 0 echo request to a target, as shown in the screenshot.




1. If the ICMP echo request is not visible, verify it by opening a new terminal window; type **sudo tcpdump -i eth1** and press Enter. If you are asked to enter a password, type **toor** and press Enter. This will capture the network traffic. Run the command again and watch the output of the tcpdump command. Here, we will get reply from **www.goodshopping.com** as it is hosted on **172.19.19.7** machine.




1. Start a query using the scripting capability of the TCL language. In the hping3 terminal window, type the following command (all on one line) and press Enter:
   **foreach i [list 5 6 7 8 9 10] {hping send "ip(daddr=172.19.19.7,ttl=$i)+icmp(type=8,code=0)"}**
   This command will set the time-to-live (TTL) at 5, and then increment it by 1 when it sends an ICMP echo request. The output will take time to appear; you may run tcpdump and capture it by entering **sudo tcpdump -i eth1 -x -vv | grep ICMP**, as shown in the screenshot.

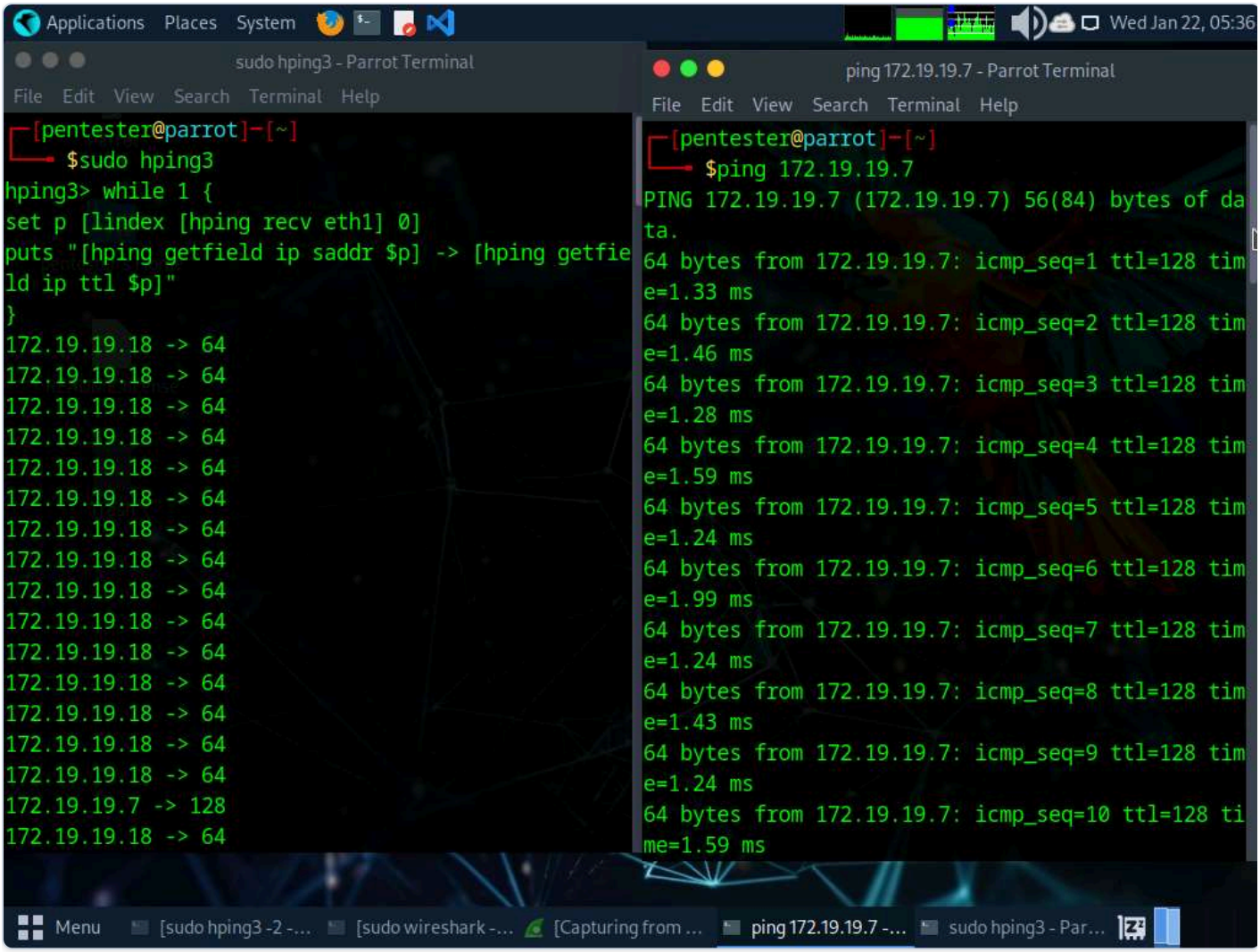


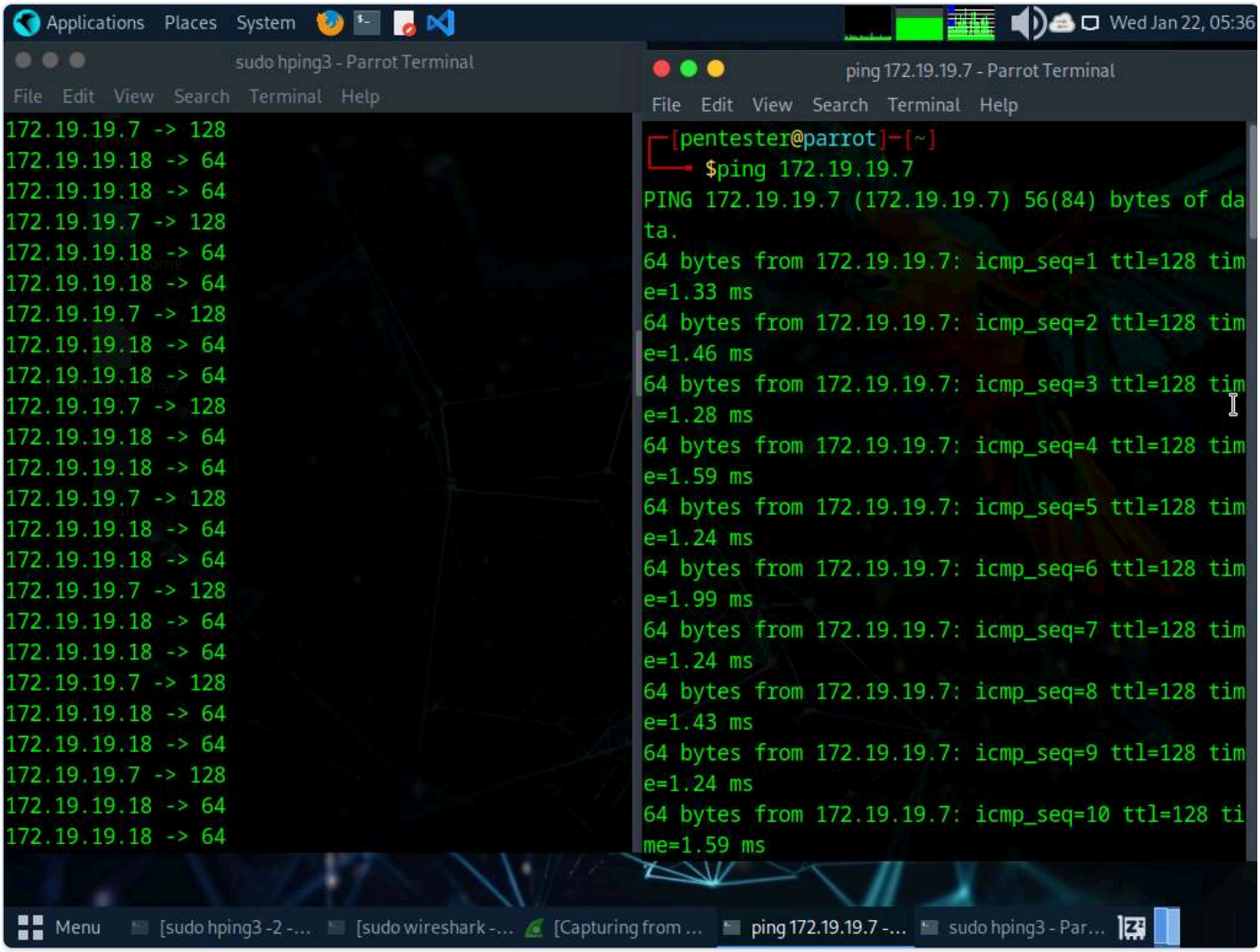

1. Next, identify the capability of hping3 to receive packets. Enter a simple loop to receive packets. In the hping3 terminal window, enter the following command:

   ```
   tcl while 1 { set p [lindex [hping recv eth1] 0] puts "[hping getfield ip saddr $p] -> [hping getfield ip ttl $p]" }
   ```

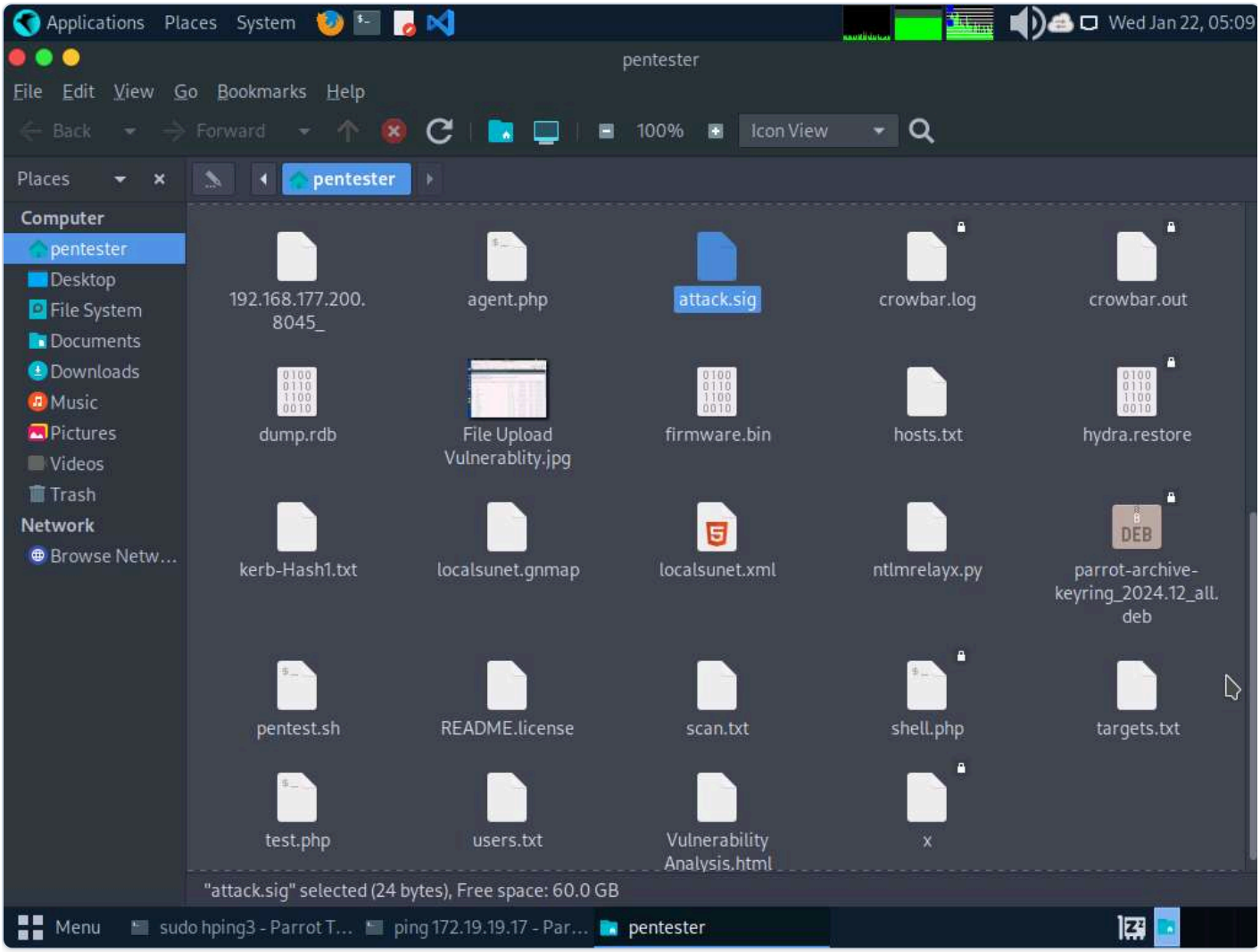
   The command shown above will help loop and receive packets until you press Ctrl+C to stop the loop.

2. Enter the commands exactly as shown above to keep the codes valid. To scroll through the packet view, open a new terminal window and ping a target by typing **ping 172.19.19.7**, as shown in the screenshot.

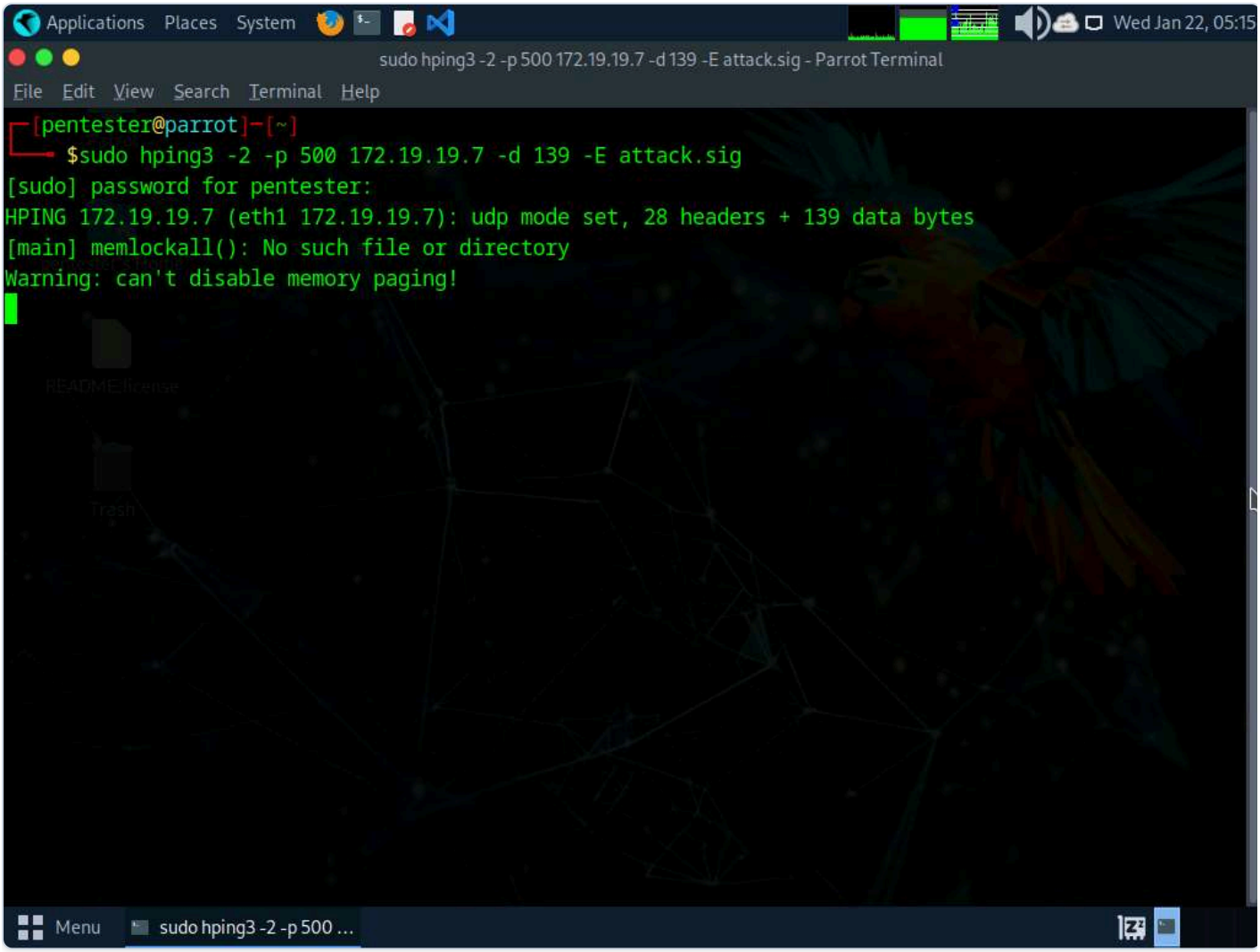

Applications Places System
Wed Jan 22, 05:36
sudo hping3 - Parrot Terminal
File Edit View Search Terminal Help
[pentester@parrot]-[~]
$sudo hping3
hping3> while 1 {
set p [lindex [hping recv eth1] 0]
puts "[hping getfield ip saddr $p] -> [hping getfie
ld ip ttl $p]"
}
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.18 -> 64
172.19.19.7 -> 128
172.19.19.18 -> 64
ping 172.19.19.7 - Parrot Terminal
File Edit View Search Terminal Help
[pentester@parrot]-[~]
$ping 172.19.19.7
PING 172.19.19.7 (172.19.19.7) 56(84) bytes of da
ta.
64 bytes from 172.19.19.7: icmp_seq=1 ttl=128 tim
e=1.33 ms
64 bytes from 172.19.19.7: icmp_seq=2 ttl=128 tim
e=1.46 ms
64 bytes from 172.19.19.7: icmp_seq=3 ttl=128 tim
e=1.28 ms
64 bytes from 172.19.19.7: icmp_seq=4 ttl=128 tim
e=1.59 ms
64 bytes from 172.19.19.7: icmp_seq=5 ttl=128 tim
e=1.24 ms
64 bytes from 172.19.19.7: icmp_seq=6 ttl=128 tim
e=1.99 ms
64 bytes from 172.19.19.7: icmp_seq=7 ttl=128 tim
e=1.24 ms
64 bytes from 172.19.19.7: icmp_seq=8 ttl=128 tim
e=1.43 ms
64 bytes from 172.19.19.7: icmp_seq=9 ttl=128 tim
e=1.24 ms
64 bytes from 172.19.19.7: icmp_seq=10 ttl=128 ti
me=1.59 ms
Menu
[sudo hping3 -2 -...
[sudo wireshark -...
[Capturing from ...
ping 172.19.19.7 -...
sudo hping3 - Par...



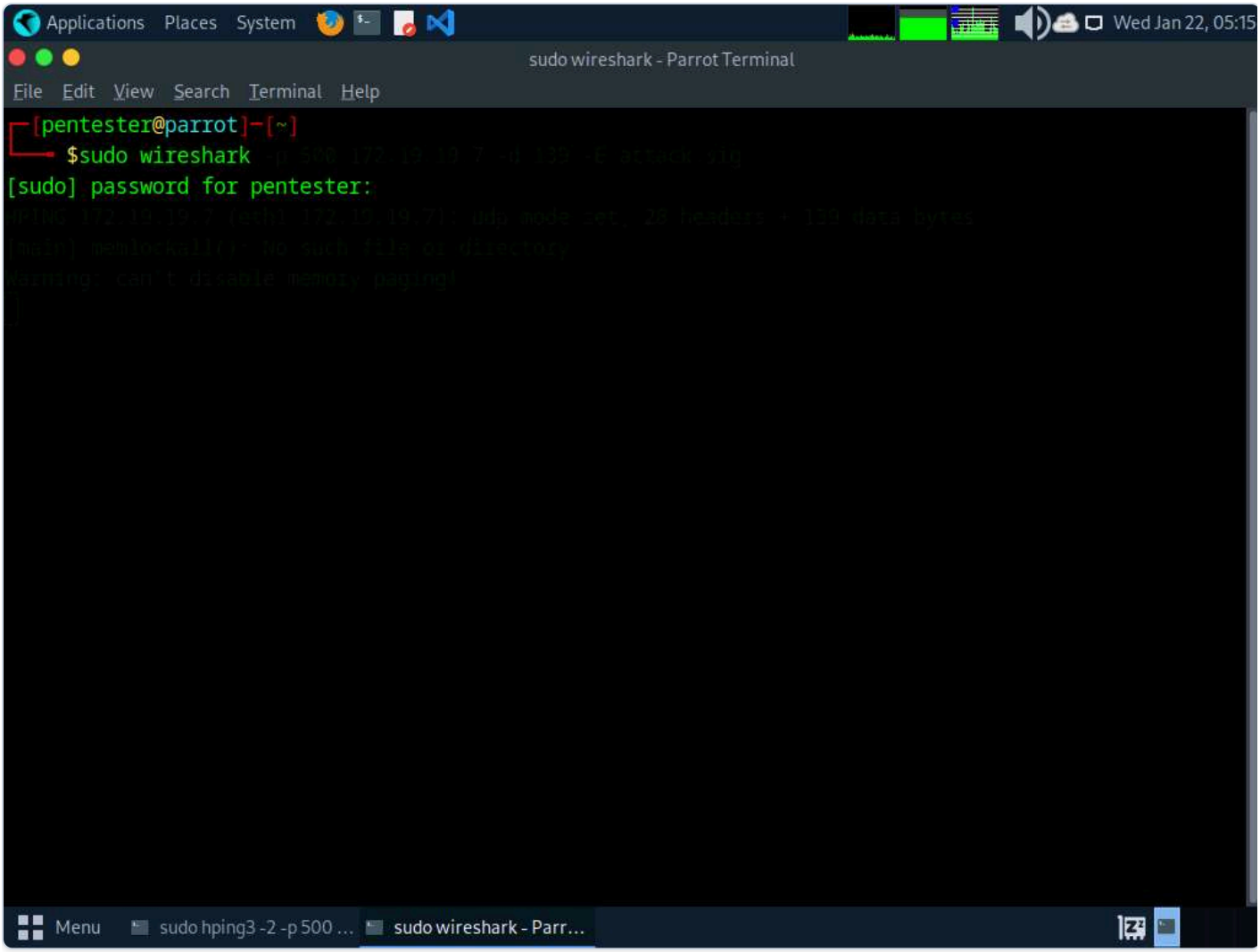

1. Using your chosen text editor, type `"You are under attack!"` and save the file as **attack.sig** in Home folder.



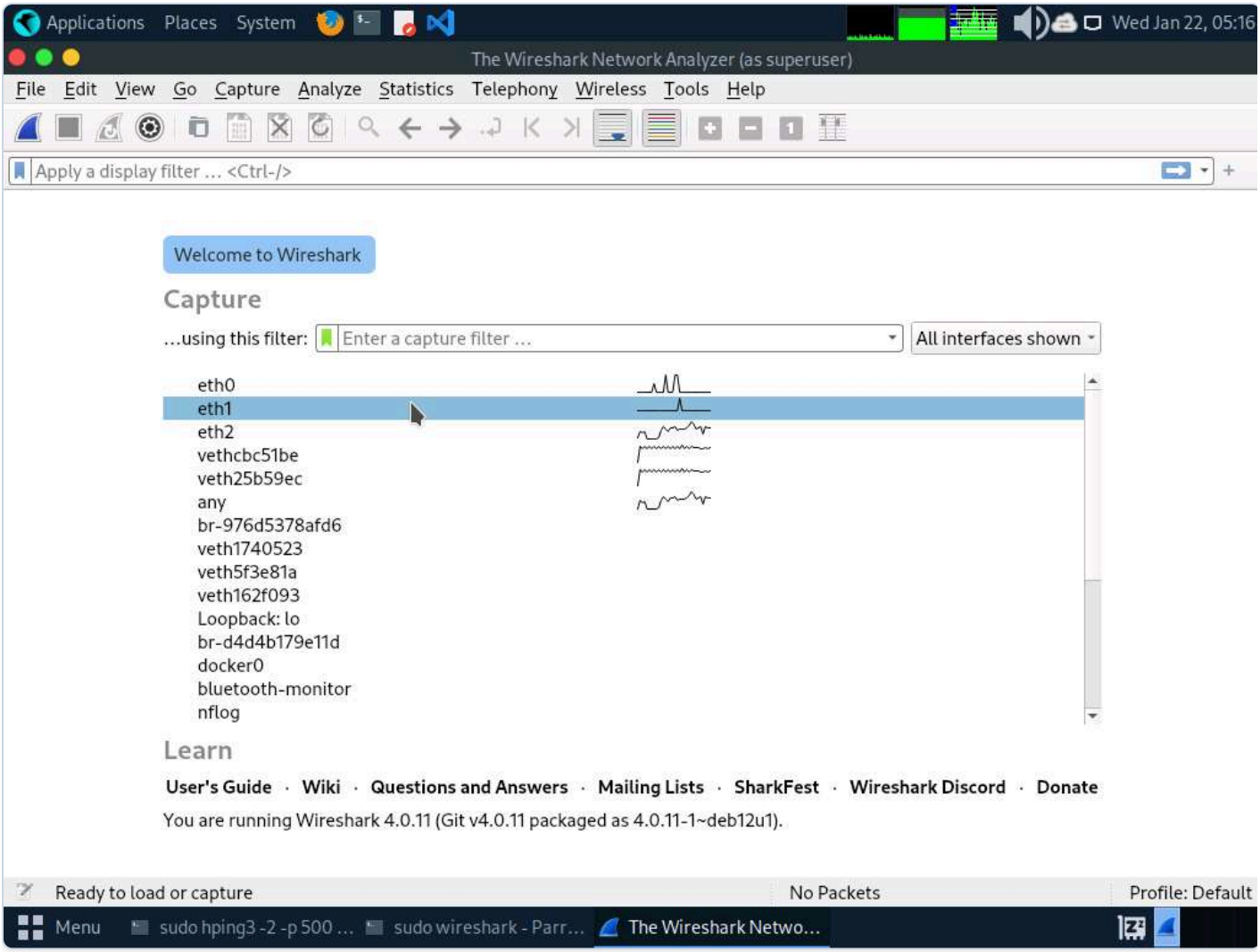

1. The hping3 tool allows users to send messages. Accordingly, send the message as a string. Open a new terminal window, type **sudo hping3 -2 -p 500 172.19.19.7 -d 139 -E attack.sig**, and press Enter. Type **toor** in the password field and press Enter. This will send the packet to port 139 from port 500.



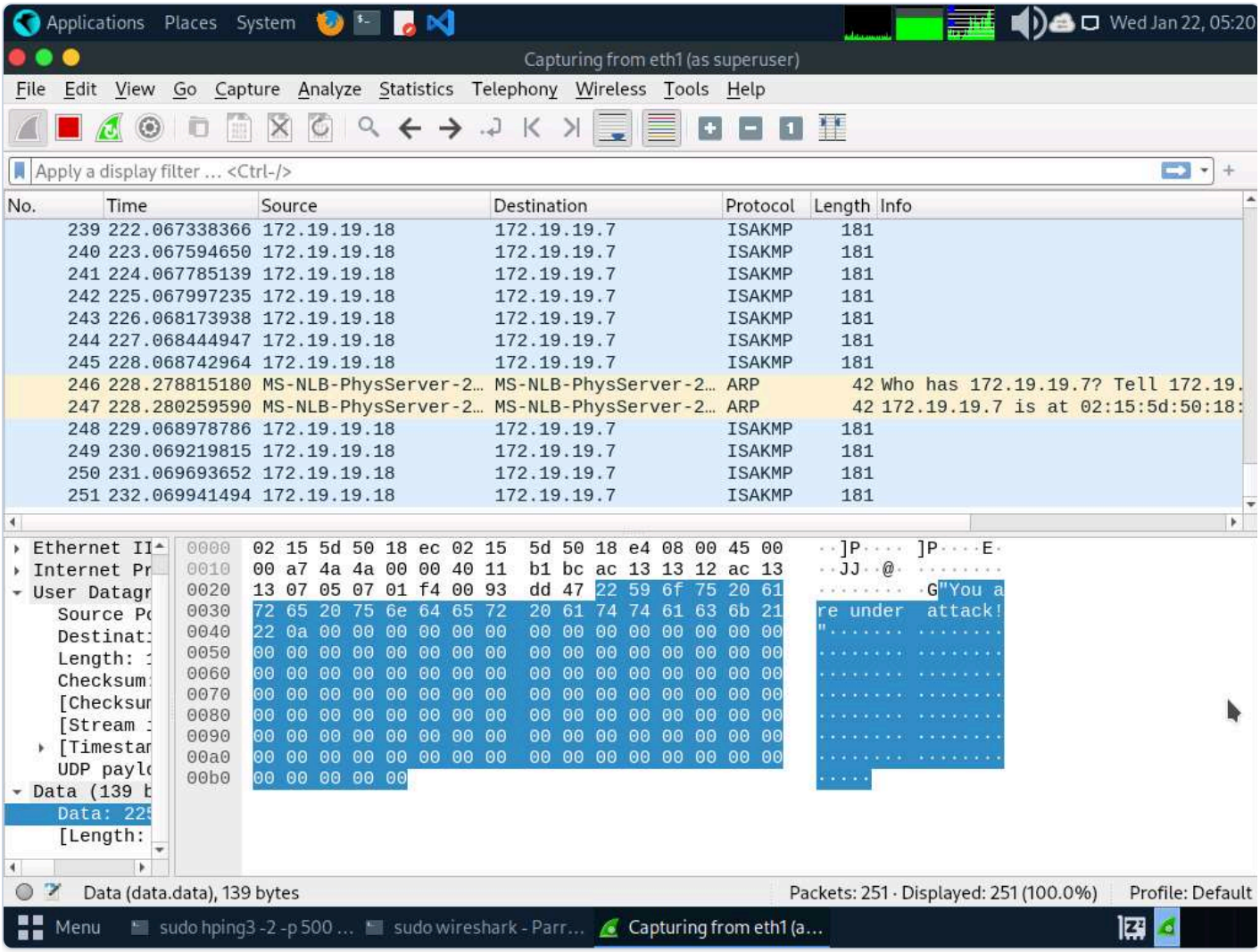

1. Use Wireshark to view the packet information. In a new terminal window, type **sudo wireshark** and press Enter. If you are asked to enter the password, enter **toor**.



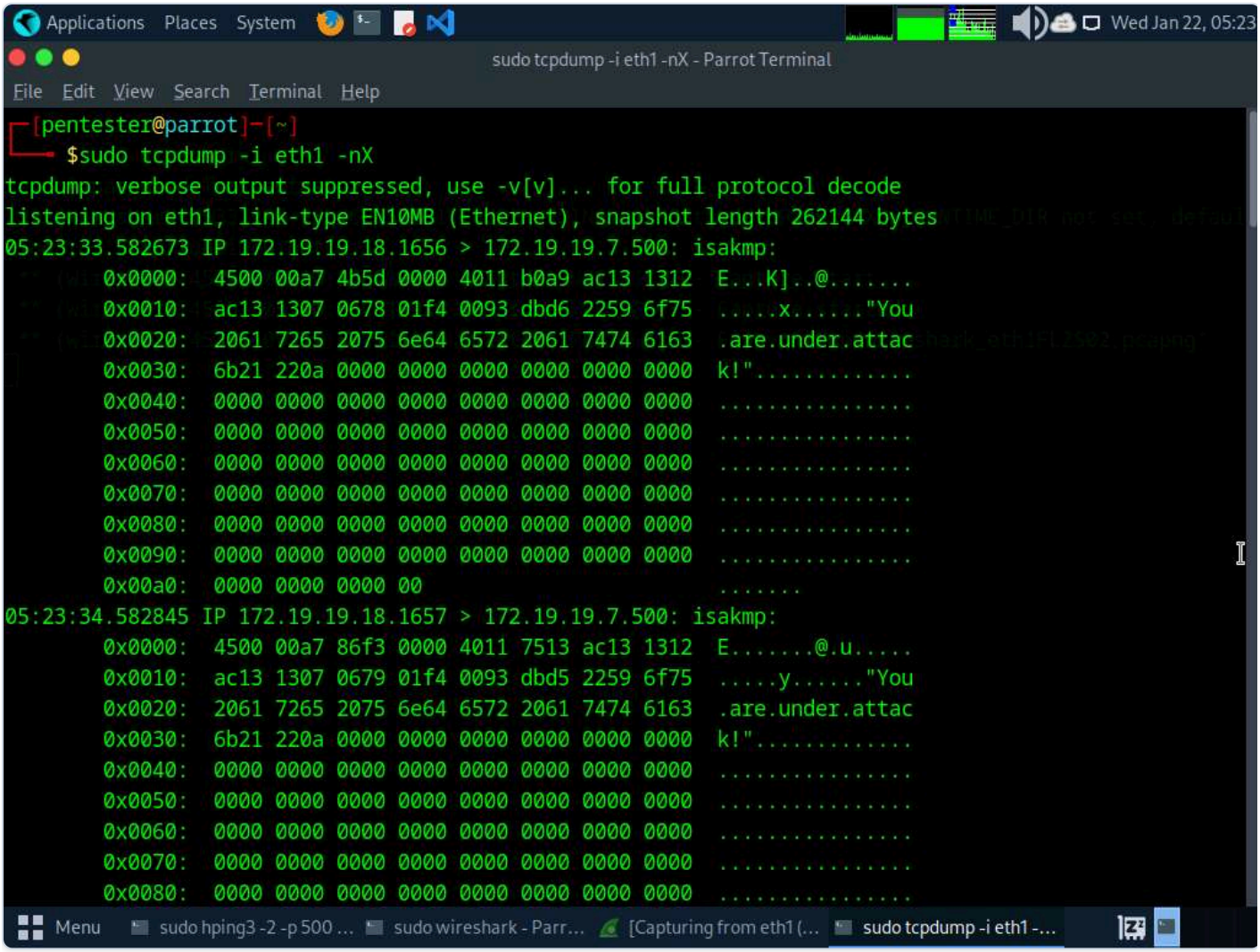

1. Wireshark GUI appears, select **eth1** interface.



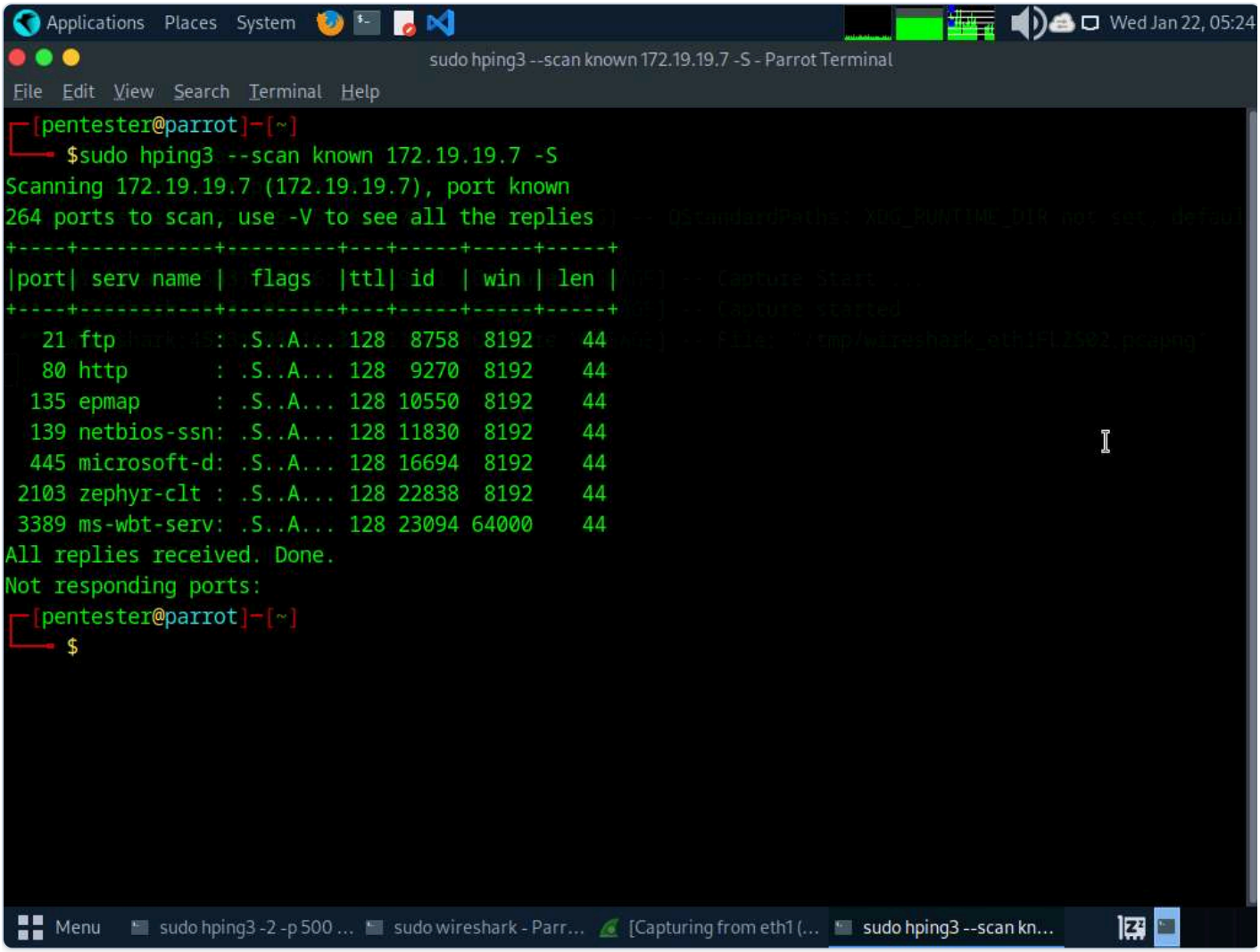

*(The window shows the Internet Security Association and Key Management Protocol (ISAKMP) traffic, as you are using User Datagram Protocol (UDP) port 500. The lower window also shows that the message you specified is carried within the packet.)*




1. The message in the packet can also be displayed using tcpdump: Type **sudo tcpdump -i eth1 -nX** in the terminal window. If you are asked to enter the password, enter **toor**.

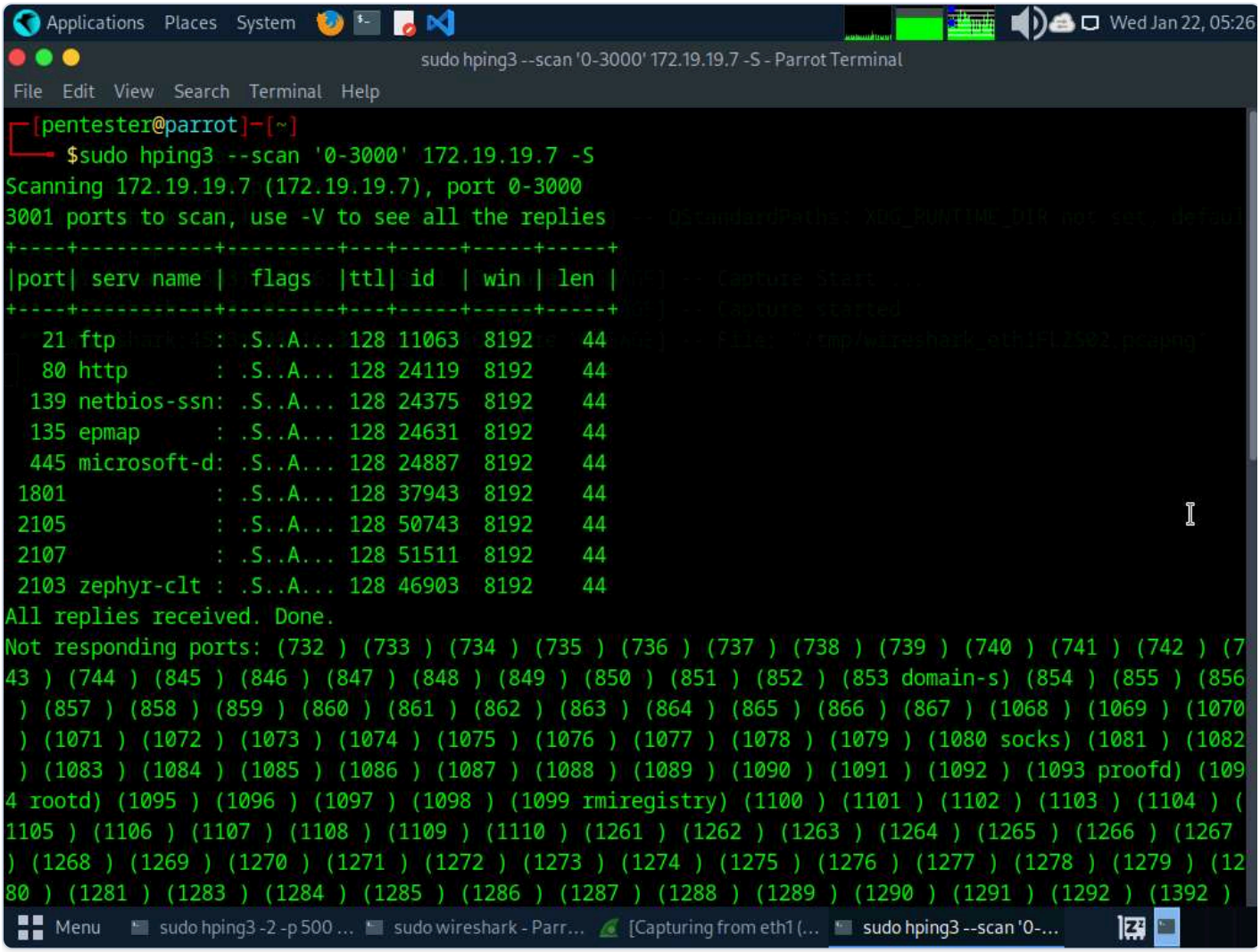



1. Scan a target using hping3. Open a new terminal window and enter **sudo hping3 --scan known 172.19.19.7 -S**. This command displays the list of open ports/services running on the target.

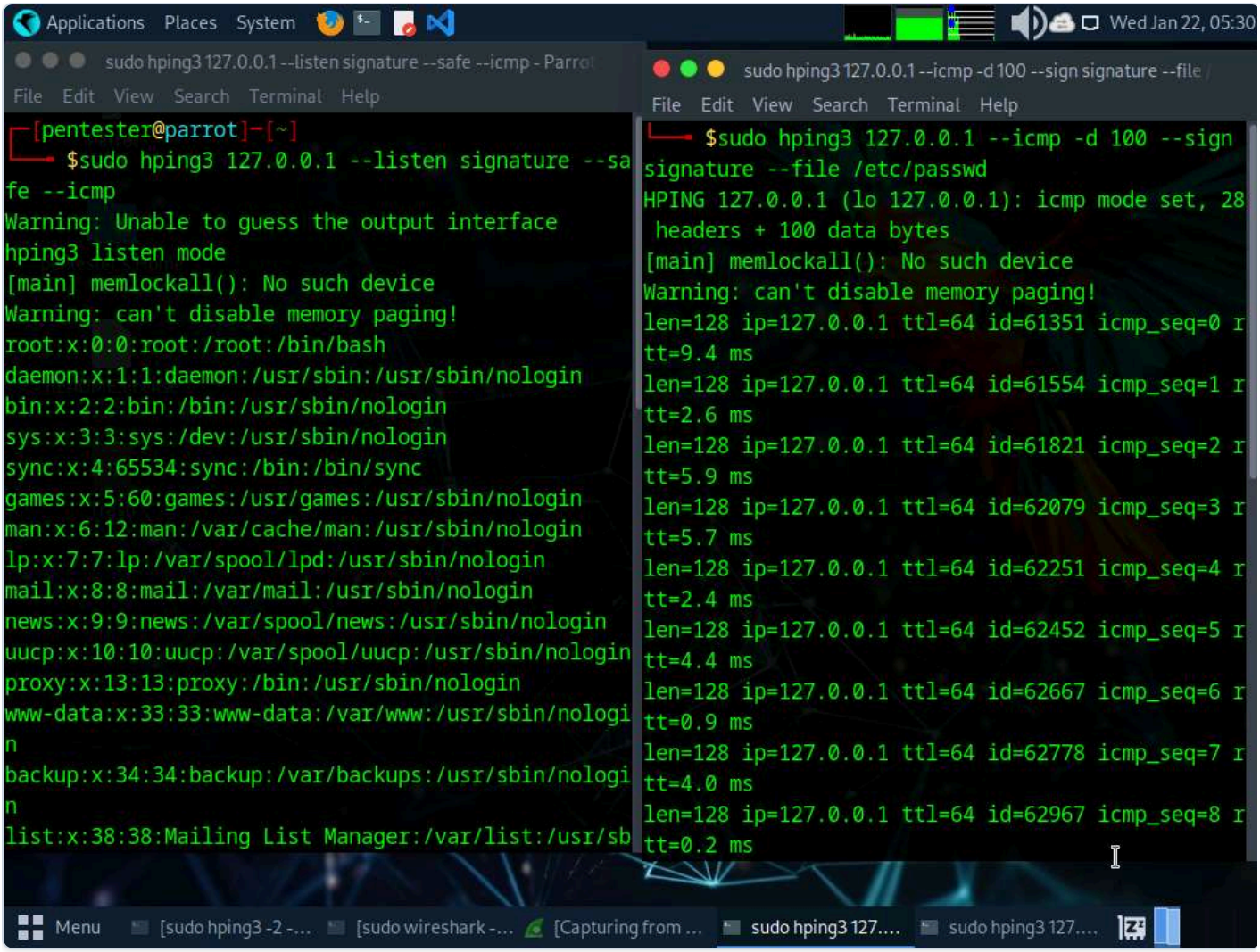



*(Hping3 is a powerful scanning tool that, in the previous example, only showed the known option for the ports listed in /etc/services.)*

1. Next, specify a range to scan. In the terminal window, enter **sudo hping3 --scan '0-3000' 172.19.19.7 -S**, as shown in the screenshot.




1. Finally, send files using the ICMP. Open two terminal windows and position them side-by-side.
   - In the first terminal window, enter **sudo hping3 127.0.0.1 --listen signature --safe --icmp**. Enter **toor** as the password if asked.
   - In the second terminal window, type **sudo hping3 127.0.0.1 --icmp -d 100 --sign signature --file /etc/passwd**. Enter **toor** as the password if asked.
   - The file contents begin to appear in the first terminal as shown in the following screenshot:




*(The file has been transmitted successfully. Note that this could be any ASCII file and the process can be used for several different actions. This concludes the lab exercise.)*

---

> **IMPORTANT:** ❓ **Question 3.5.3.1** On the Parrot Security machine, use the hping3 tool to perform various network tasks, including querying with hping3, executing scripts within its command environment, capturing packets, conducting scans, and transferring files via ICMP. Perform a scan on **172.19.19.51** using hping3 to identify open ports, and record the total number of discovered open ports. [!SUCCESS] ✅ **Answer:** **4**

---

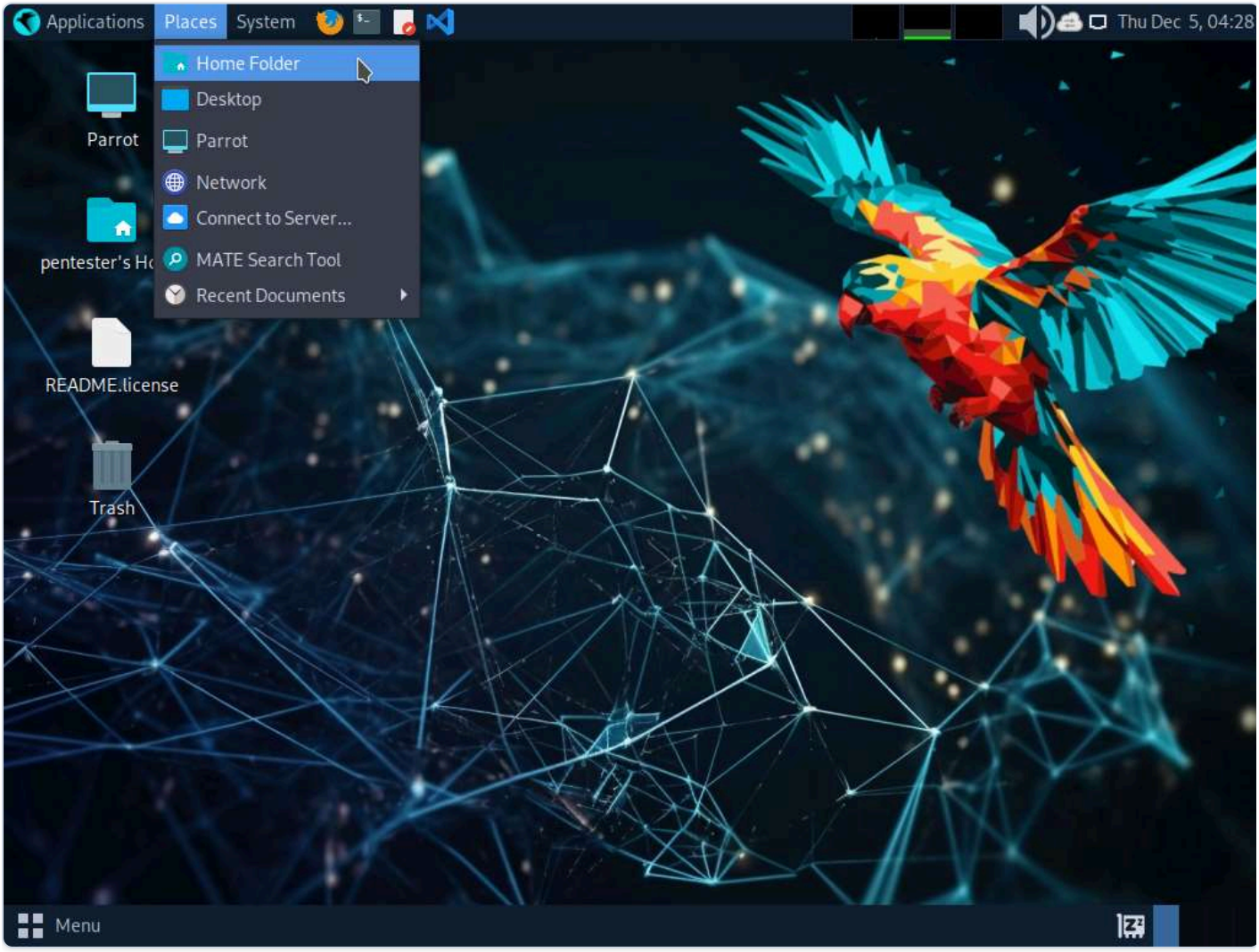
## Task 4: Automating Penetration Testing Tasks Using Bash Scripting

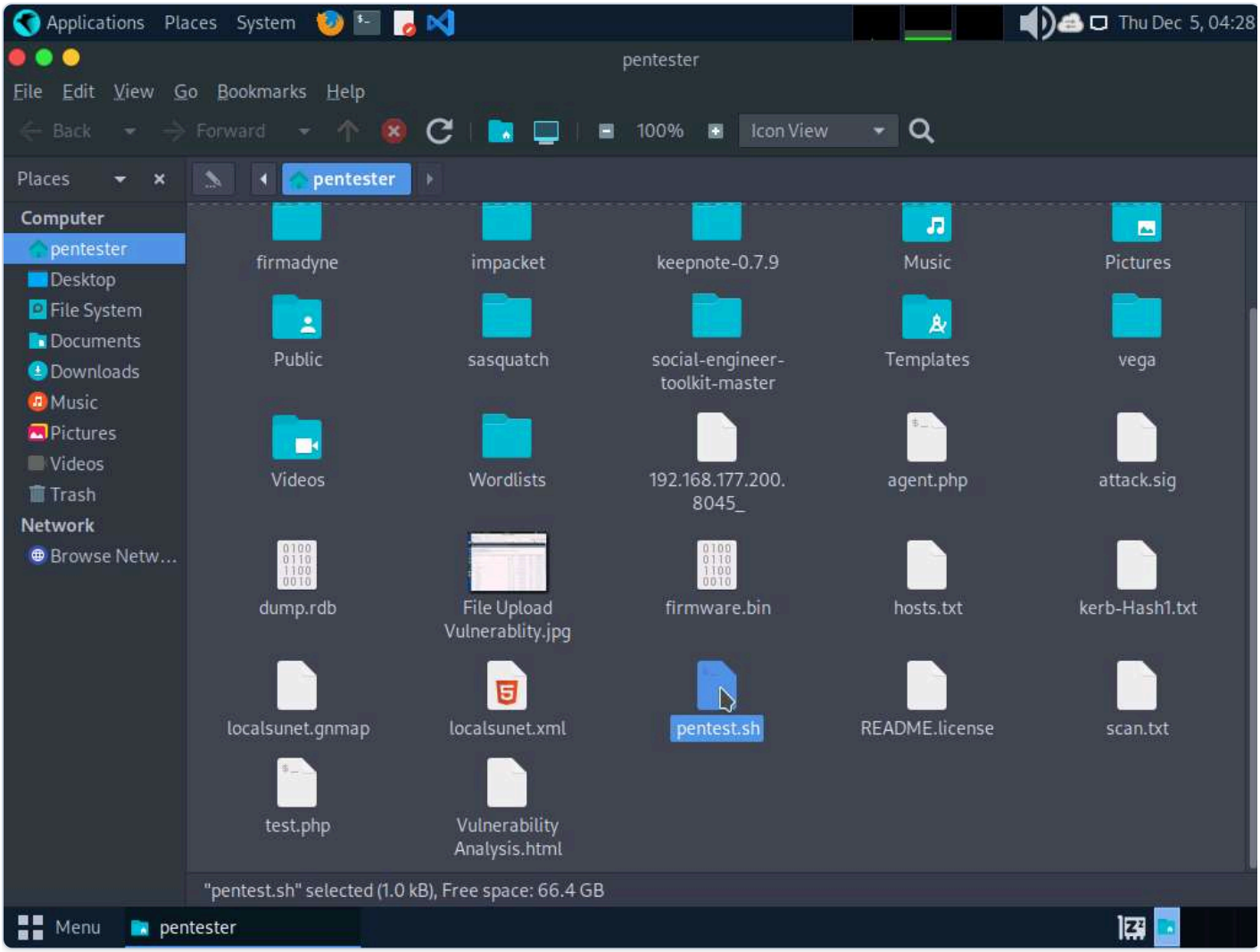
Bash is a command processor that typically runs in a text window, where the user types commands that cause actions. Bash can also read commands from a file, called a script. Like all Unix shells, it supports filename globbing (wildcard matching), piping, here documents, command substitution, variables, and control structures for condition-testing and iteration. The keywords, syntax, and other basic features of the language were all copied from sh.

Bash Scripting aids pentesters during the penetration testing process as they can perform multiple tasks such as running Nmap commands, running FTP commands, etc all at a time, thereby avoiding the need to run each command individually.

### Lab Tasks

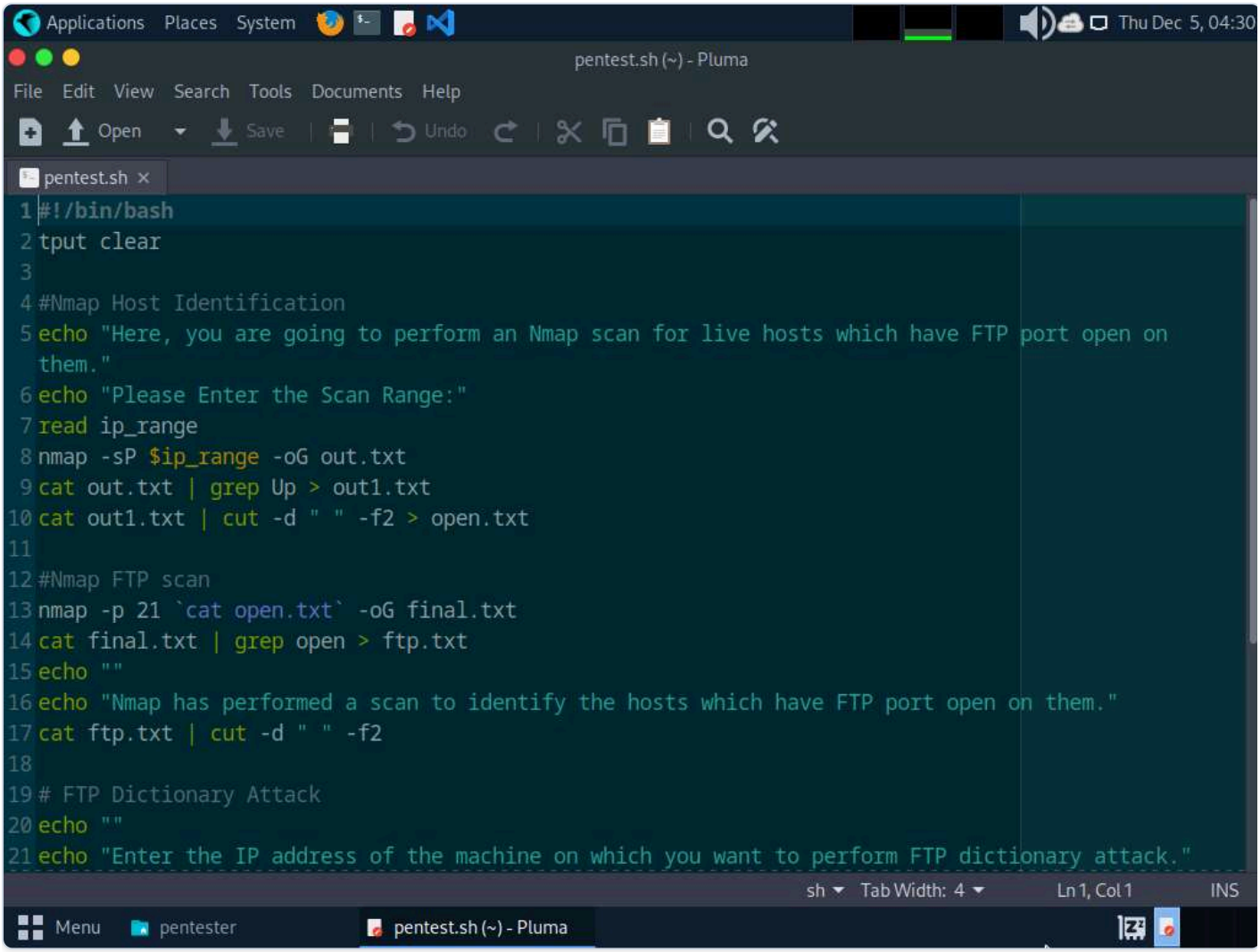
1. Click **Parrot Security**. Parrot lock screen appears. By default pentester is selected as the user. Type **toor** in the Password field and press Enter.
2. Navigate to **Places** and click **Home Folder**. The Home Folder directory window appears, double-click on the **pentest.sh** file to open and view the bash script.



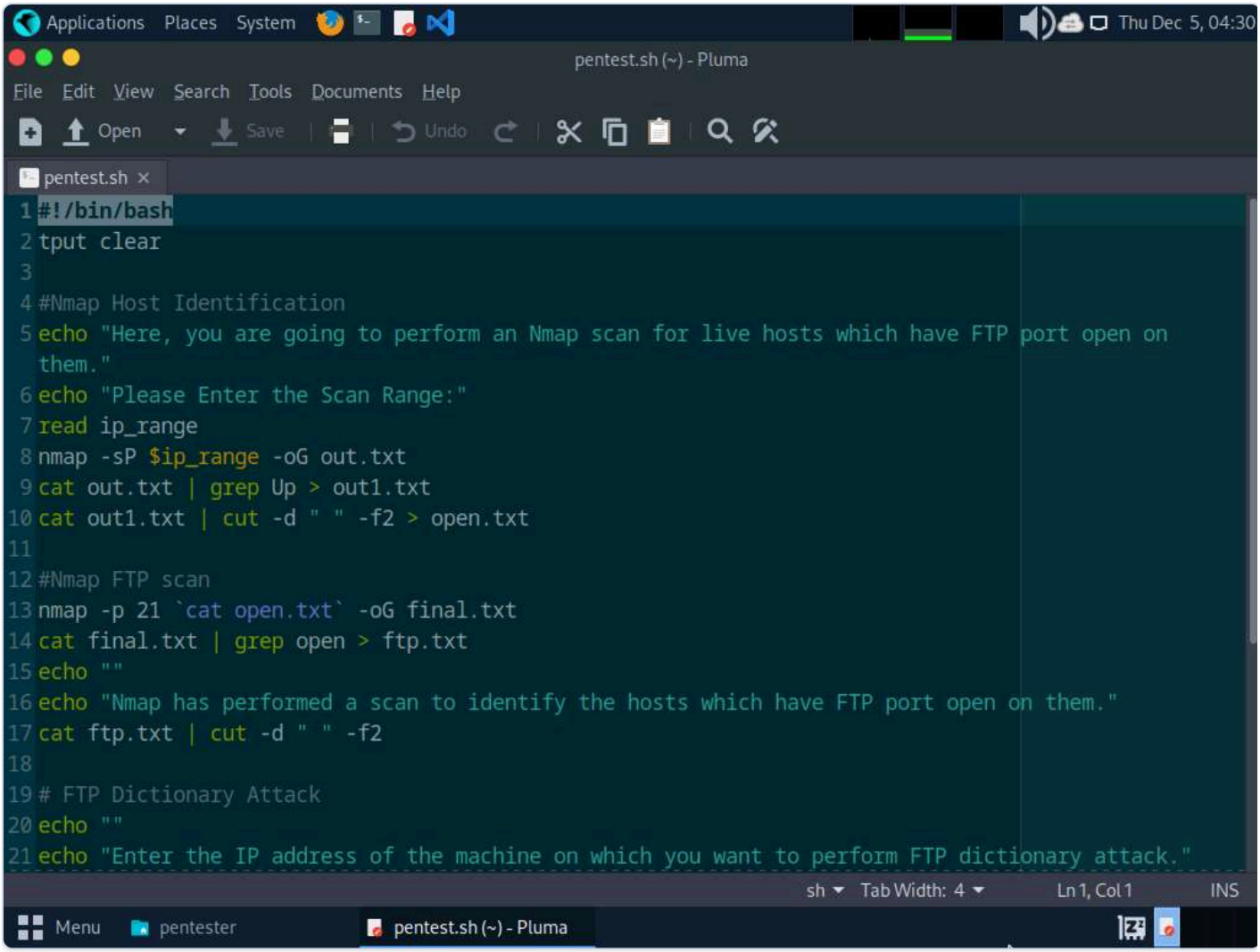



This bash script is used to perform:

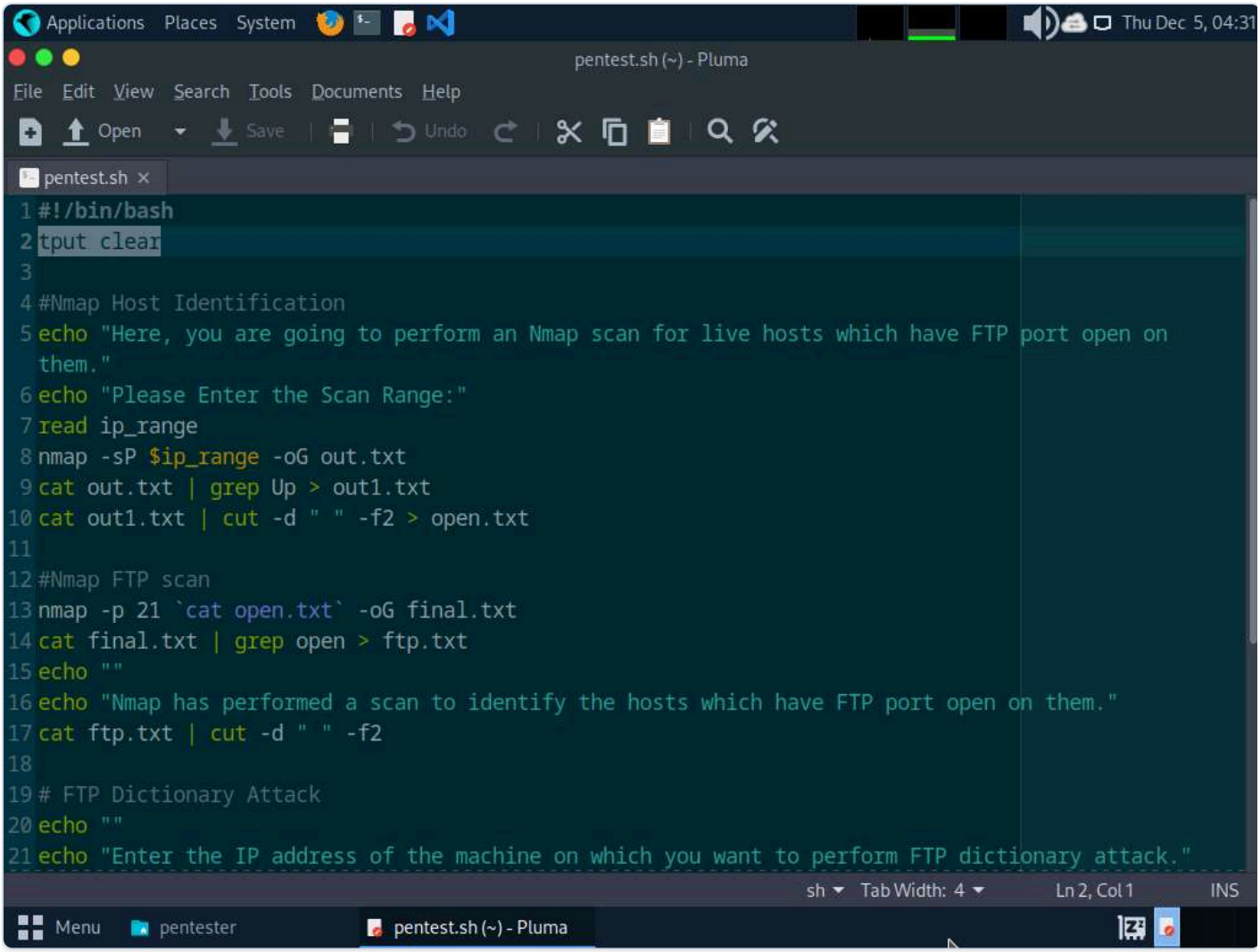
- Automated reconnaissance on a specified network range for live machines with FTP port open
- Dictionary attack on selected IP Address and reveal user credentials
- Login to the FTP server using the attained credentials



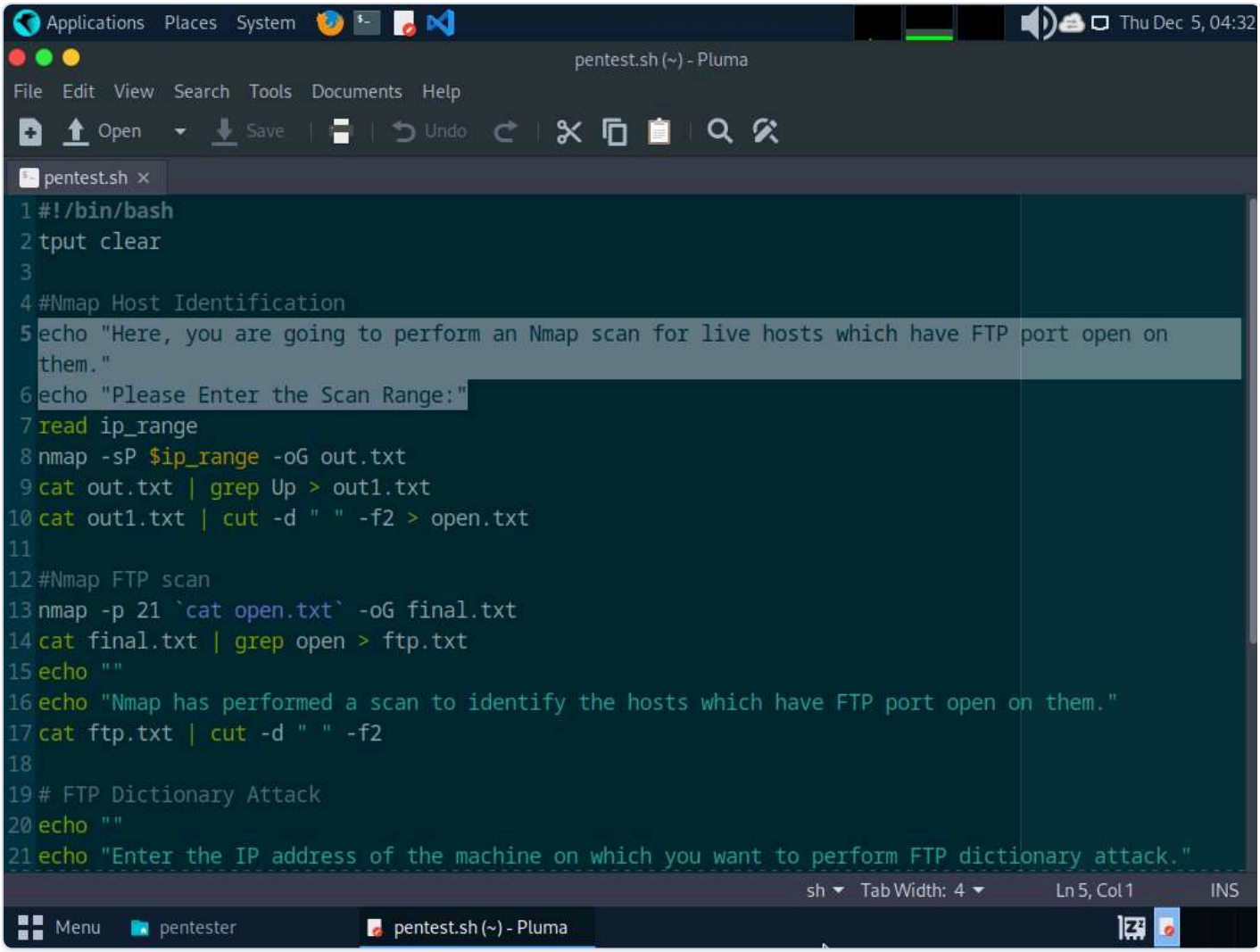

1. The first line of the bash script is `#!/bin/bash`, meaning that the script should always be run with bash, rather than another shell.



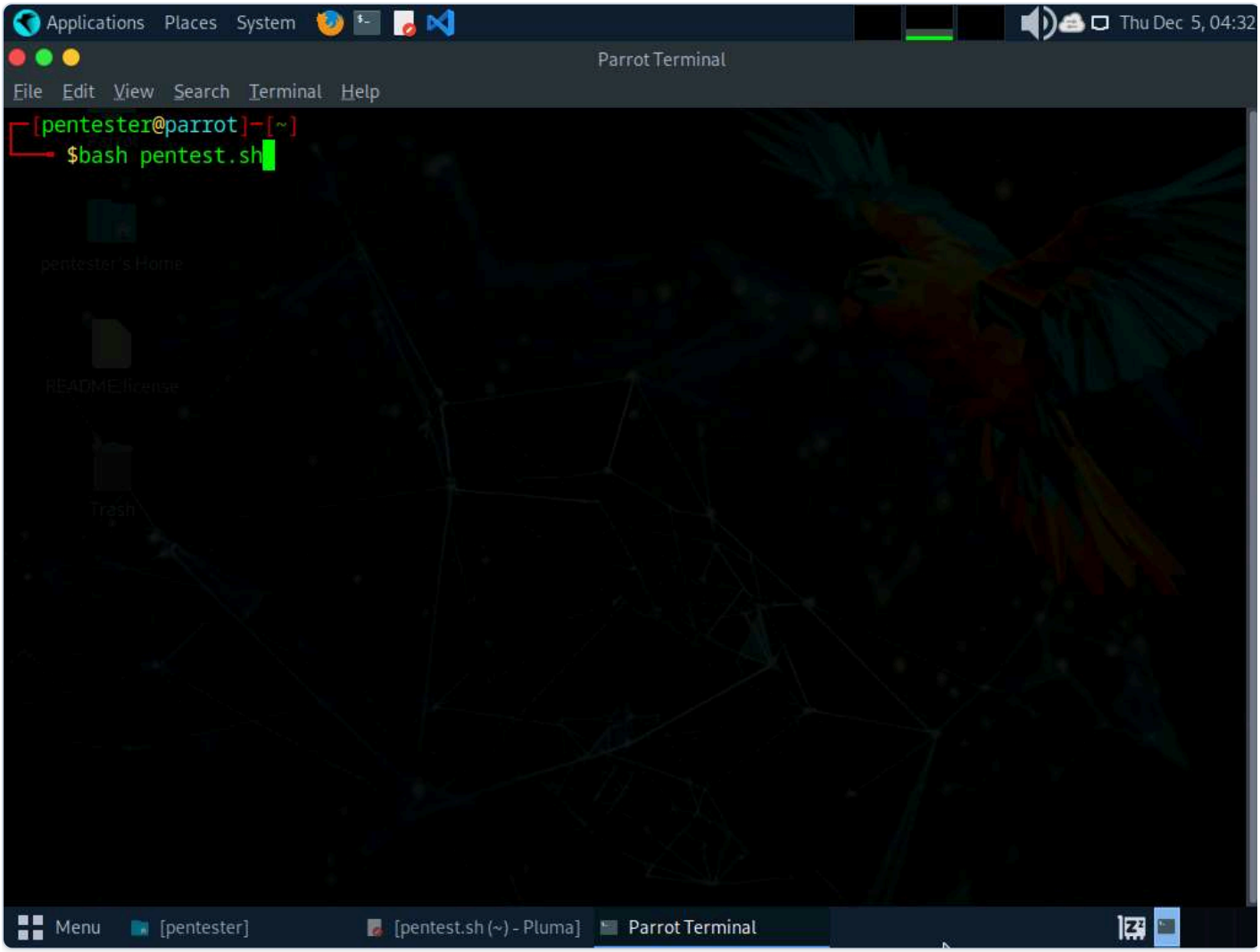

1. The `tput clear` command in the second line clears the screen and puts you at the top of the terminal screen.



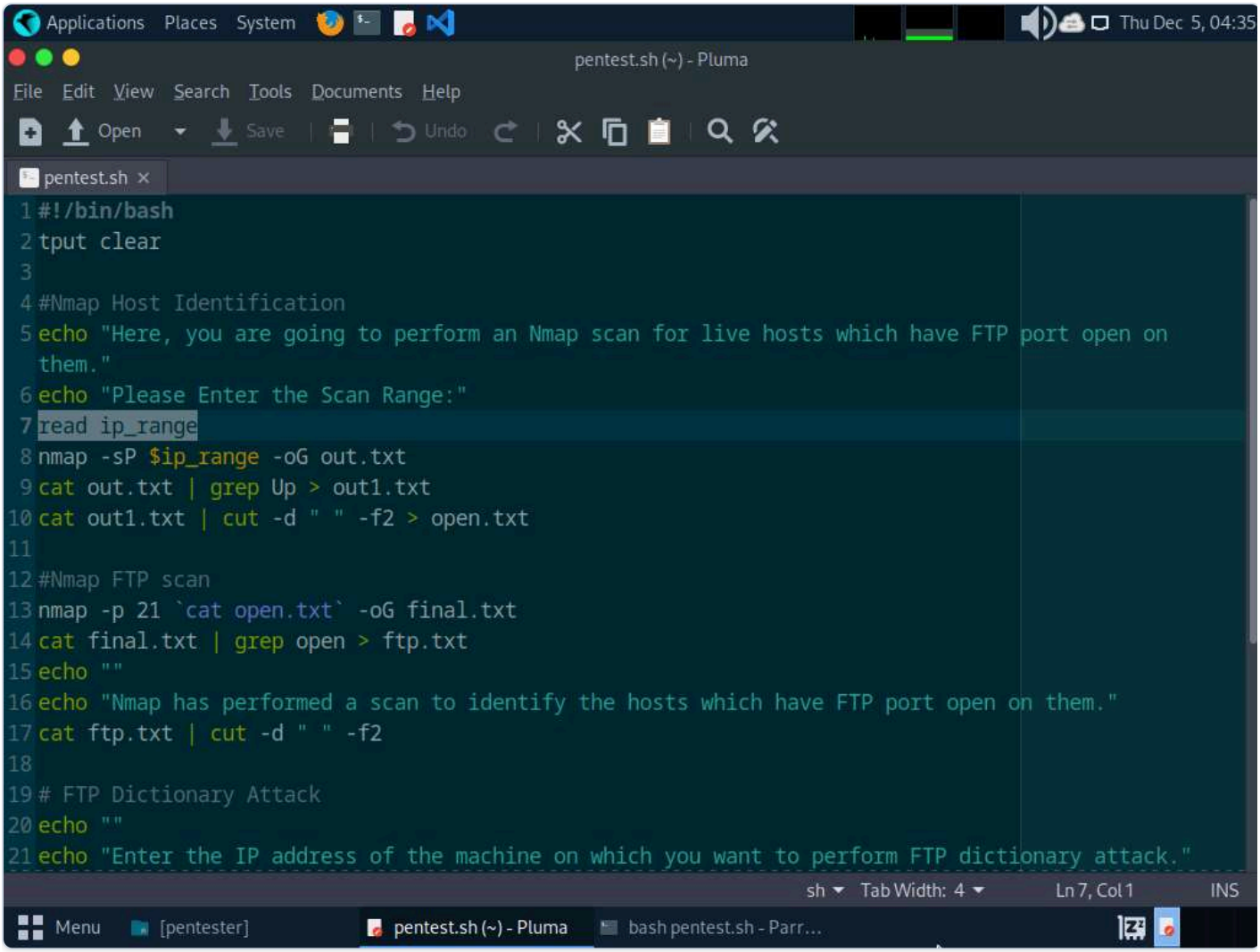

1. The `echo` command is used to display a line of text/string on a standard output or a file. So, whatever you type in between double quotes will be printed on the screen. In this lab, we are performing a Nmap scan for live host and FTP open port identification. So, you can observe the text written in the echo command as shown in the screenshot:



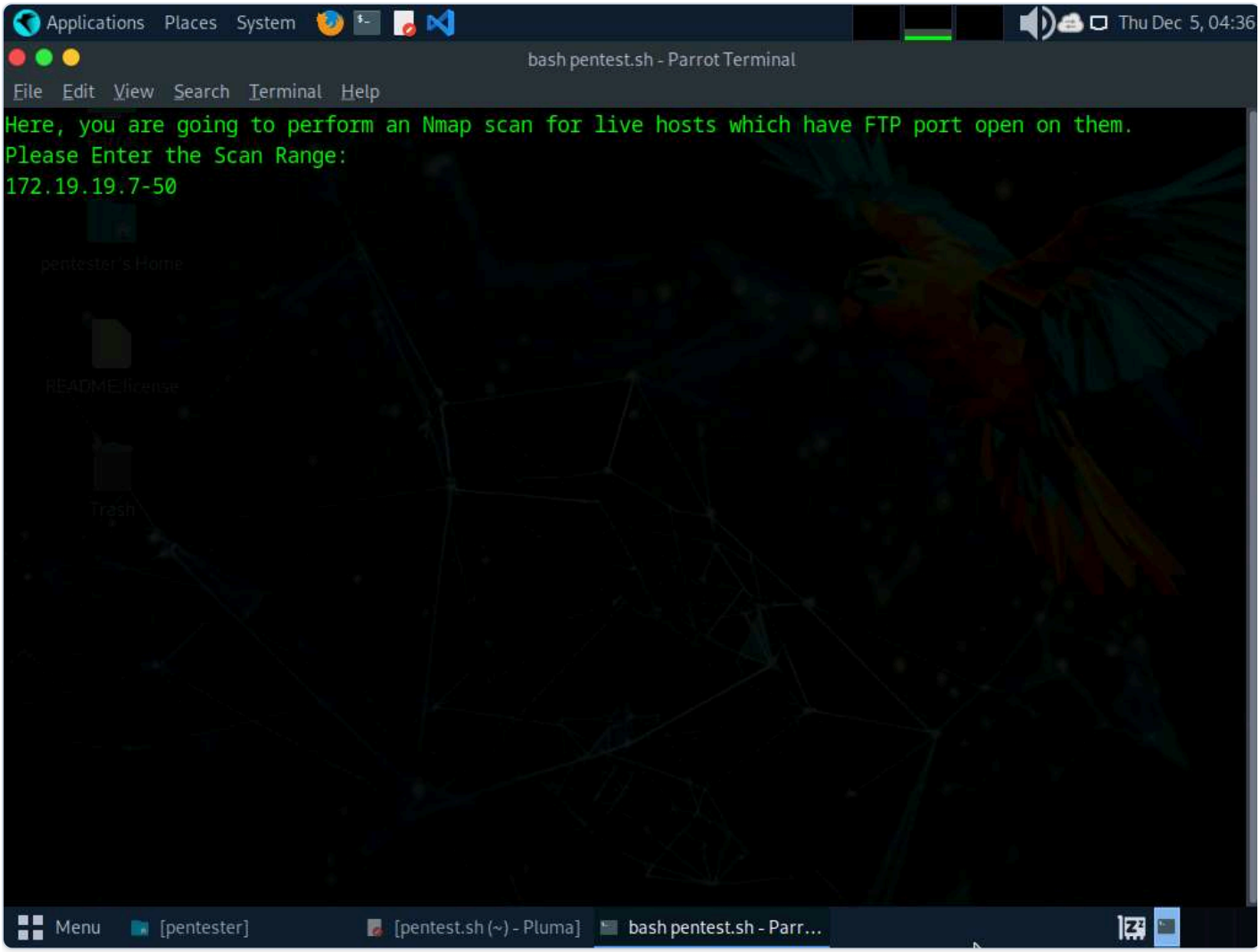

1. Minimize the **pentest.sh** file window. Now, let us run the bash script. Launch a command line terminal, type **bash pentest.sh**, and press Enter.



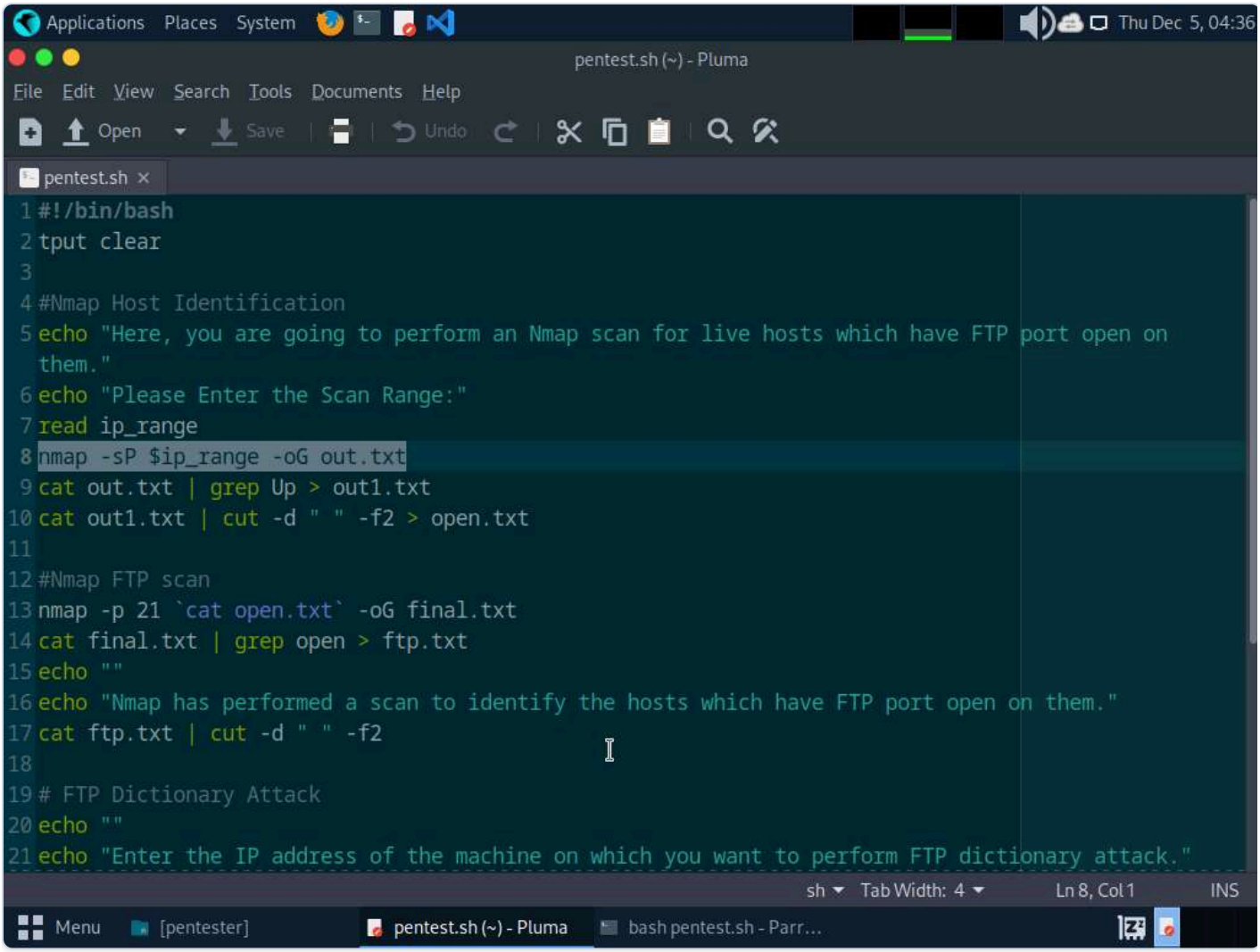

1. Minimize the command line terminal and maximize the Leafpad window. The `read` command allows you to read a line from standard input. It accepts the input from the keyboard and assigns it to a variable. In this lab, we are using the read command to enter the IP Address range on which we will be performing a Nmap scan for live host detection. In this lab, the variable used for addressing the IP Address range is `ip_range`.



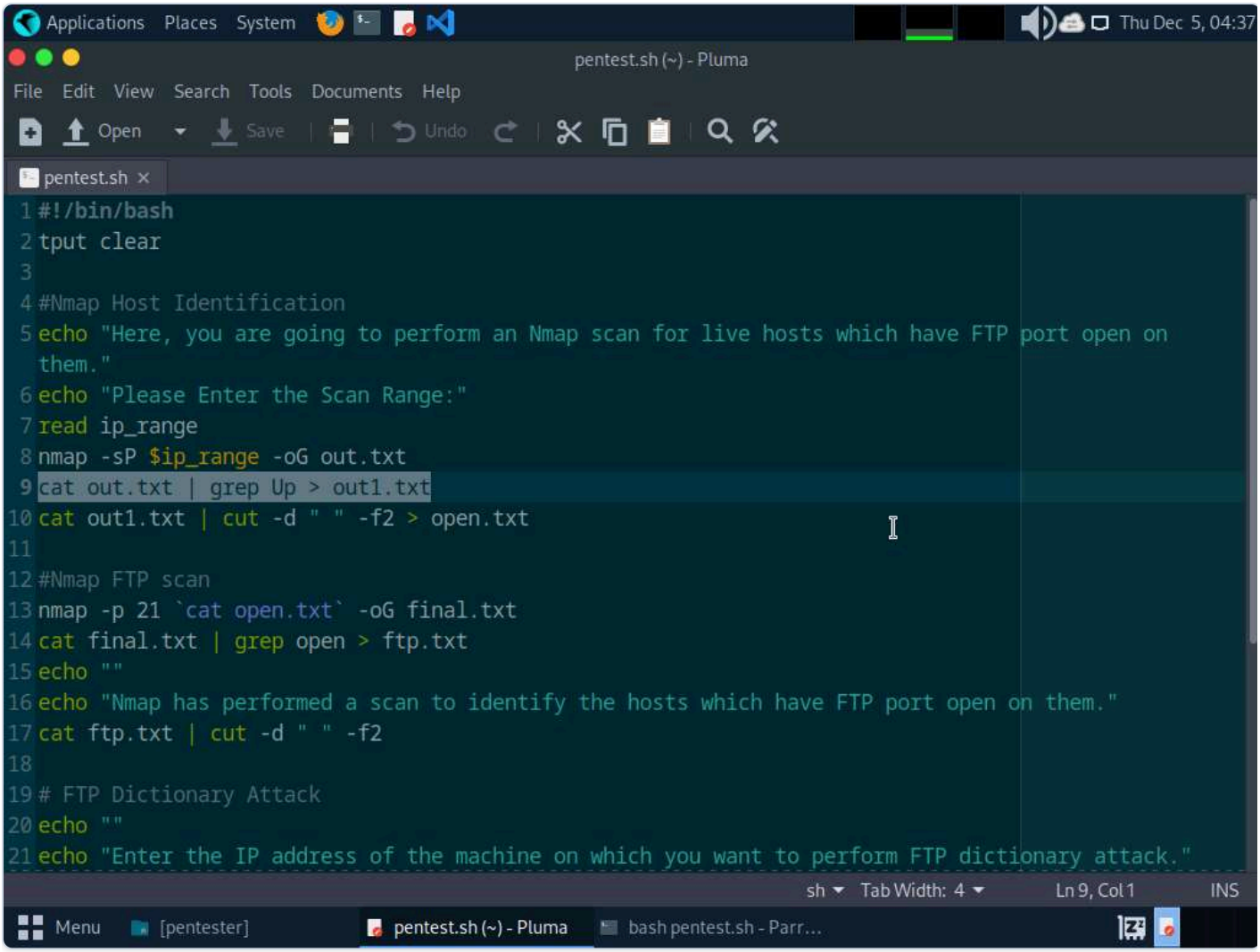

1. Minimize the Leafpad window and maximize the command line terminal. As described in the earlier steps, the `tput clear` command clears the screen and points the mouse cursor at the top of the terminal, followed by the `echo` command. Type **172.19.19.7-50** and press Enter. We selected the IP range from 7-50 to ease the process and save time.



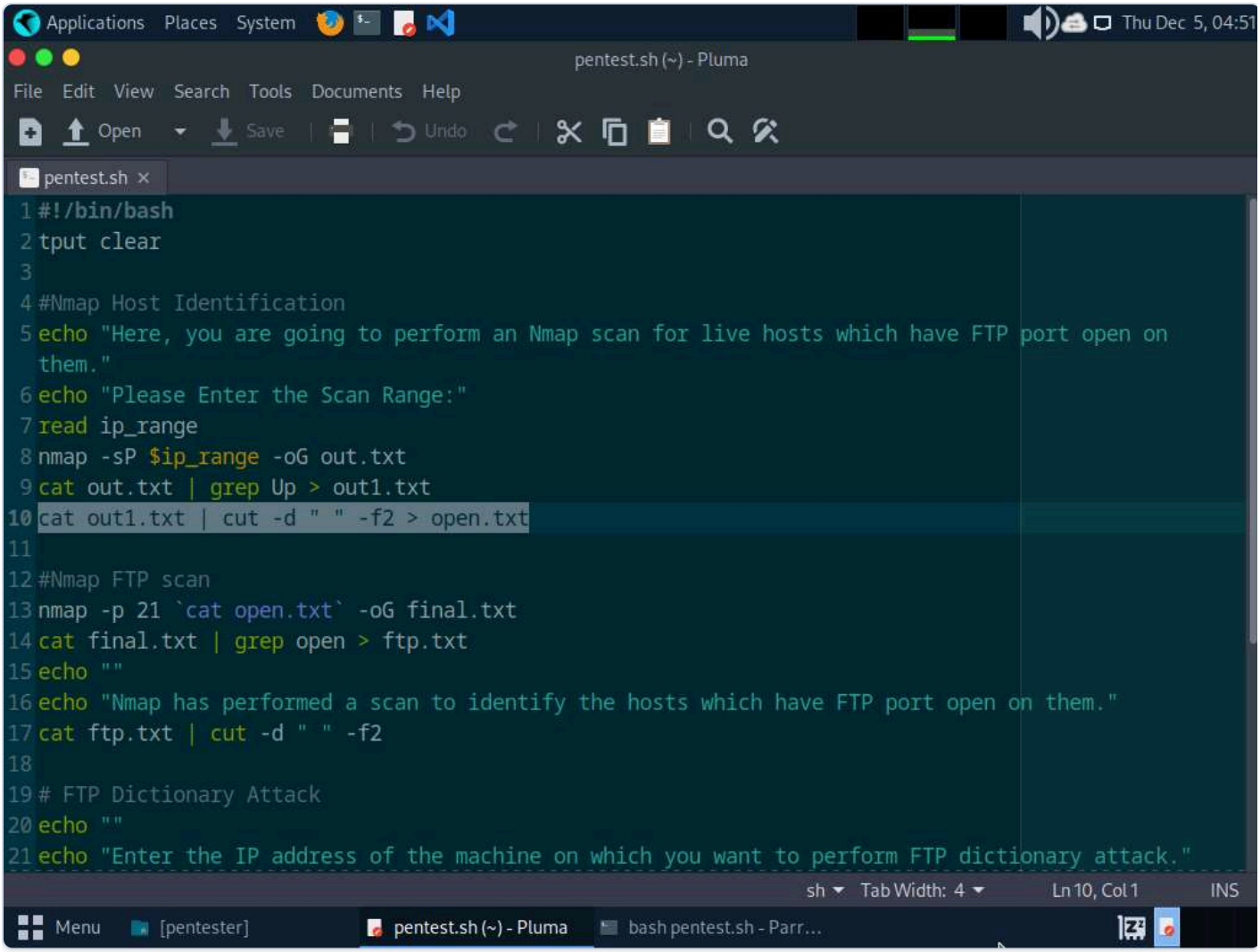

1. Minimize the command line terminal and maximize the text editor window. `nmap -sP $ip_range -oG out.txt` : `-sP` is used to identify live hosts in the entered IP Address range. `$ip_range` grabs the value (IP Address range) you entered in the read command. `-oG` represents greppable output. It is a simple format that lists each host on one line and can be trivially searched and parsed with standard Unix tools such as grep. Once the Nmap scan is completed, its output is stored in the **out.txt** file. So, by entering `nmap -sP $ip_range -oG out.txt` , nmap is going to perform live host detection and send the greppable output to **out.txt** file. You can view the **out.txt** file created in the root folder for a better understanding.



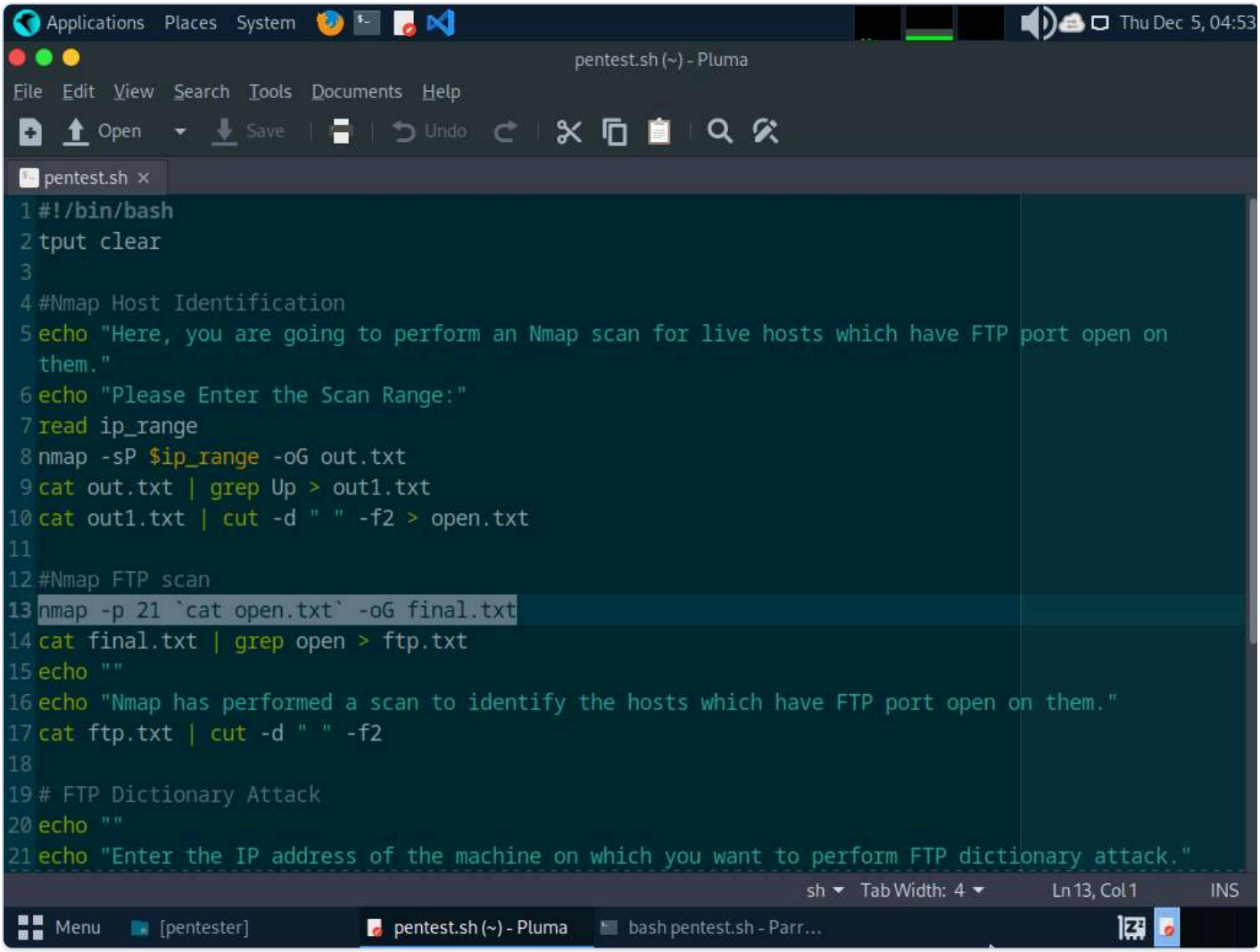

1. The `cat` (in short "concatenate") command allows you to view the contents of single/multiple files, create files, concatenate files, and redirect the output to the terminal or files. The pipe `|` redirects the output of `cat out.txt` to the `grep` command. The `grep` command is used to search the given file (**out.txt**) for lines containing a match to the given string (`Up`). So, by entering the script `cat out.txt | grep Up > out1.txt`: A search is performed in the **out.txt** file for all the lines containing the status of the IP addresses as Up and these IP Addresses are saved to **out1.txt**. You can view the **out1.txt** file created in the root folder for better understanding.



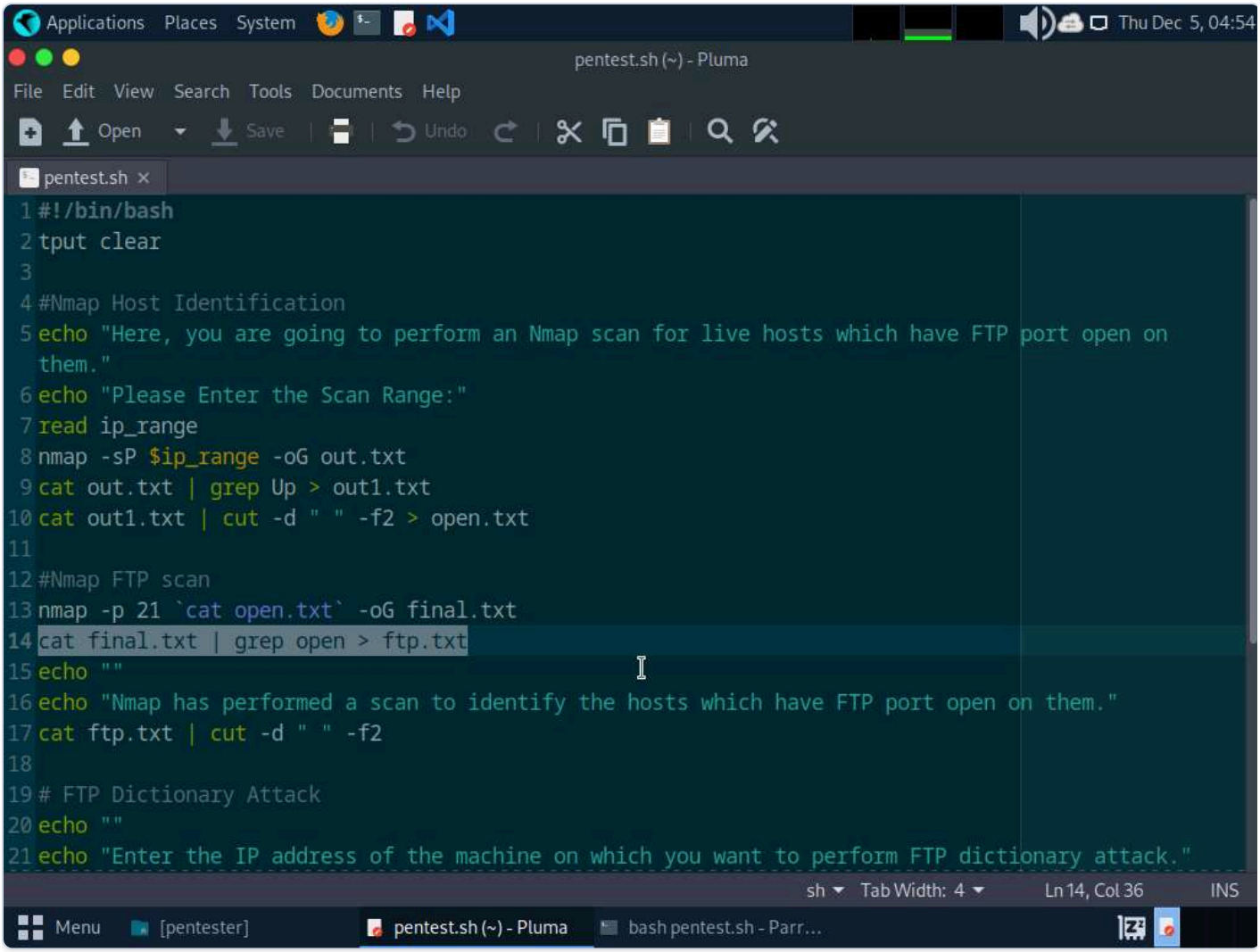

1. The `cut` command is used to select a portion of text from each line of a file. You can use the cut command to select fields or columns from a line by specifying a delimiter. By entering the script `cat out1.txt | cut -d " " -f2 > open.txt`: The content of **out1.txt** is redirected to the cut command, where the delimiter is `" "` (space). So, field 2 will be selected from each line of **out1.txt** in between the spaces; and the output will be saved to the **open.txt** file. For a better understanding, you may view the **open.txt** file created in the root folder.



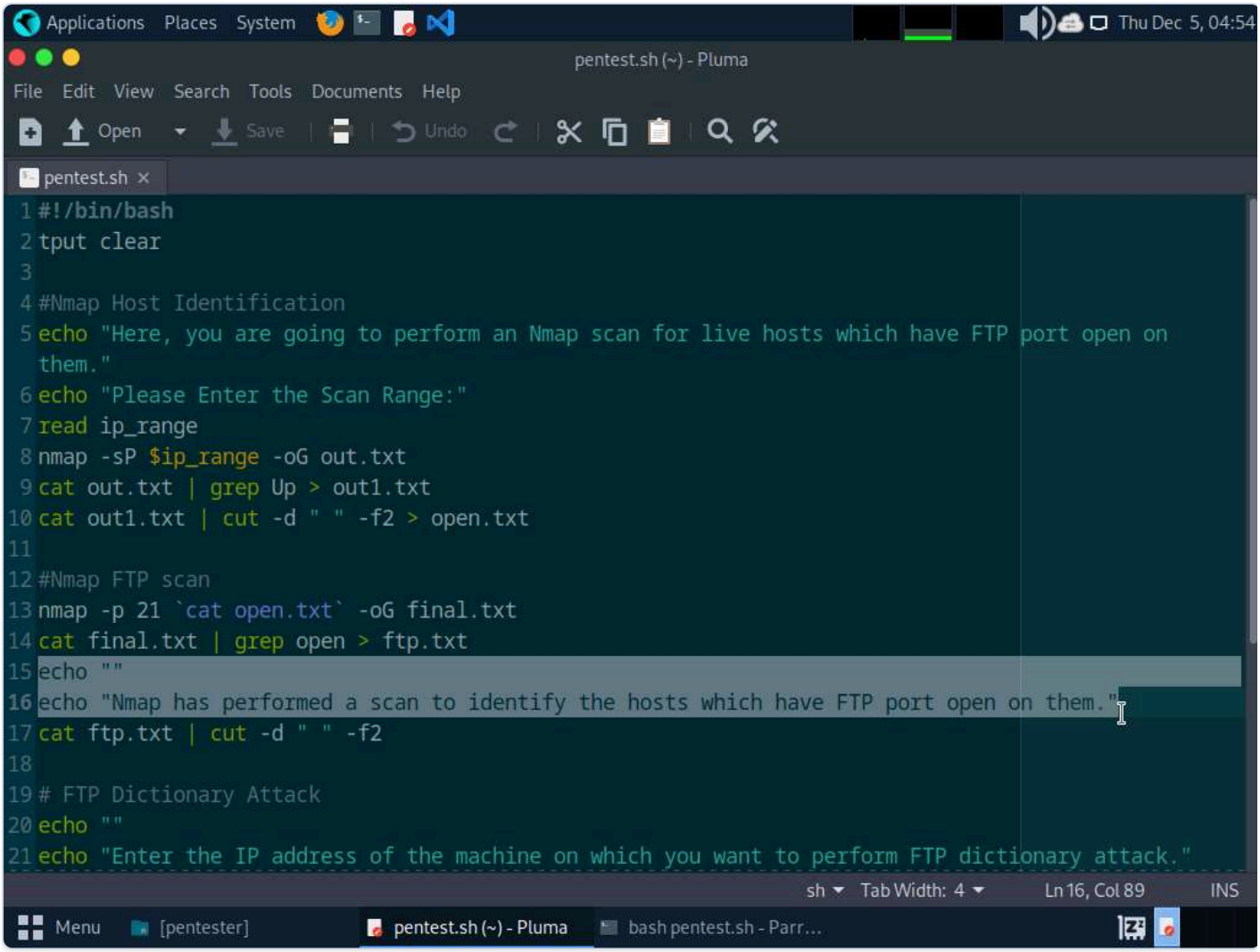

1. By entering the script `nmap -p 21 'cat open.txt' -oG final.txt`: Nmap performs a scan on the IP addresses present in the **open.txt** file and saves the greppable output to the **final.txt** file. You may view the **final.txt** file created in the root folder for a better understanding.



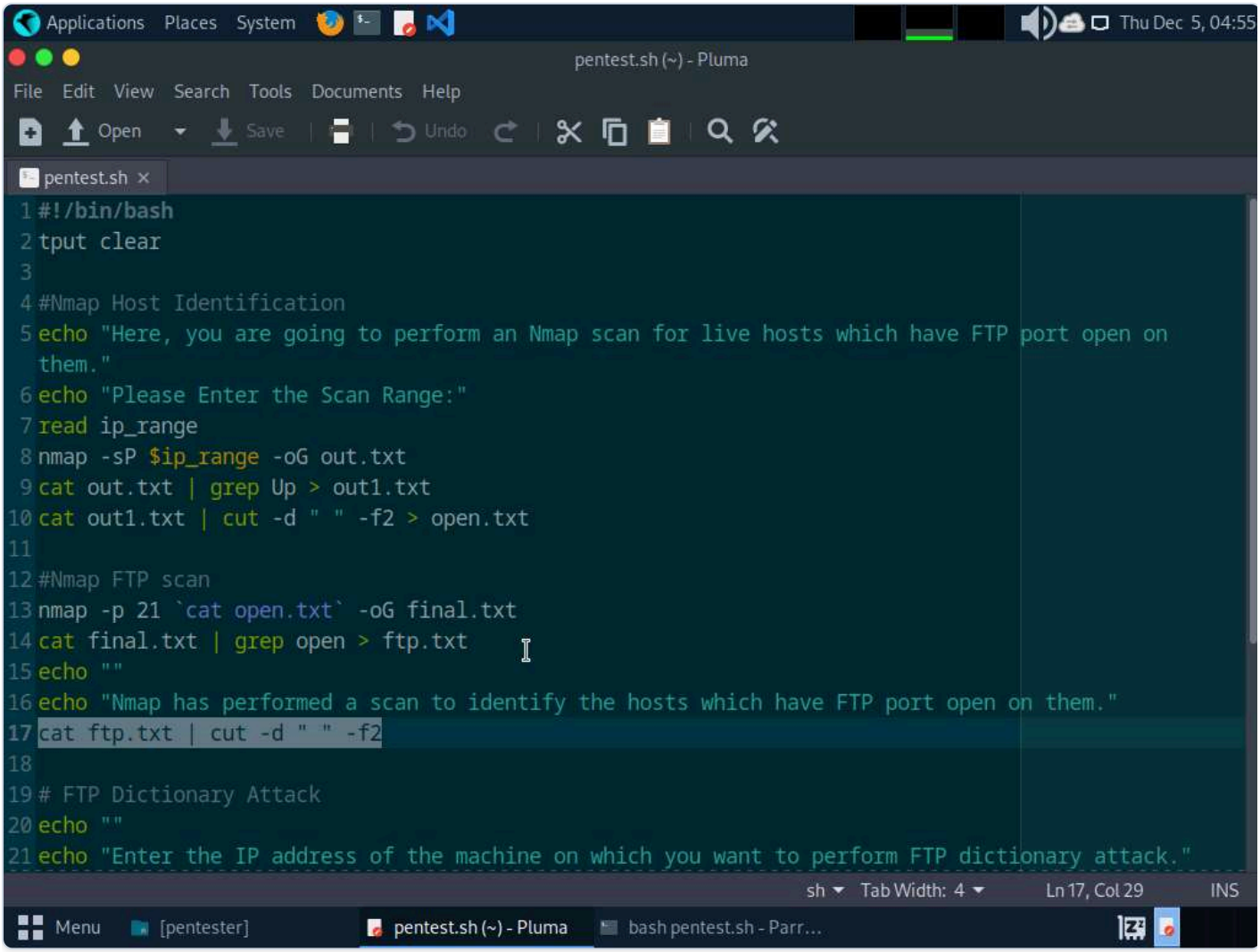

1. So far, Nmap has performed live host and FTP open port identification. The script `cat final.txt | grep open > ftp.txt` is used to view the output stored in **final.txt**, find the lines containing the string `"open"` and save those lines to a file named **ftp.txt**. You may view the **ftp.txt** file created in the root folder for a better understanding.



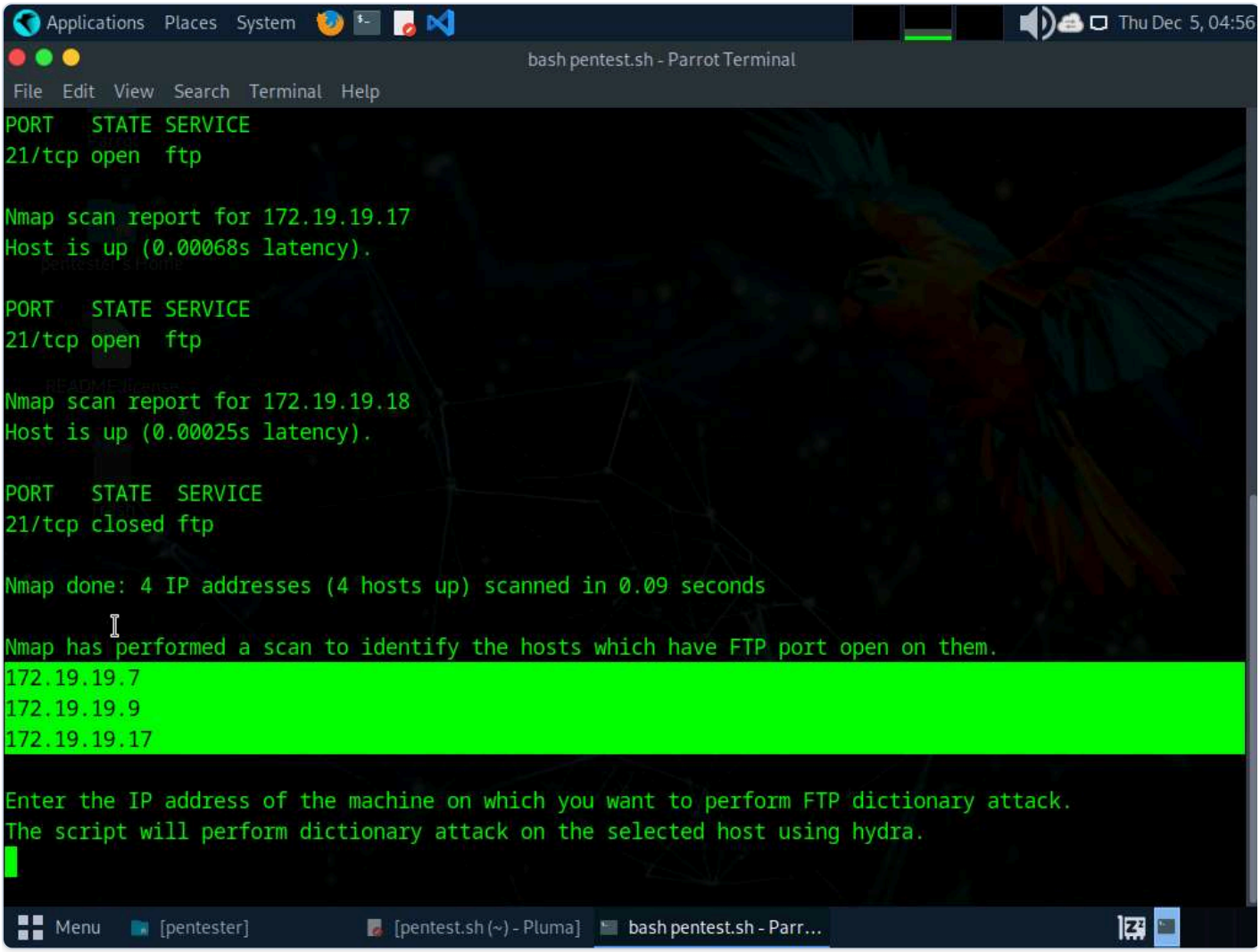

1. So far, we have obtained machines that are up and have the FTP port open. Now, we shall echo the IP Addresses of these machines on the screen. The `echo ""` represents an empty line. In the next line, we are writing something stating that the scan has been performed. This will be returned on the screen as we are using the echo command.



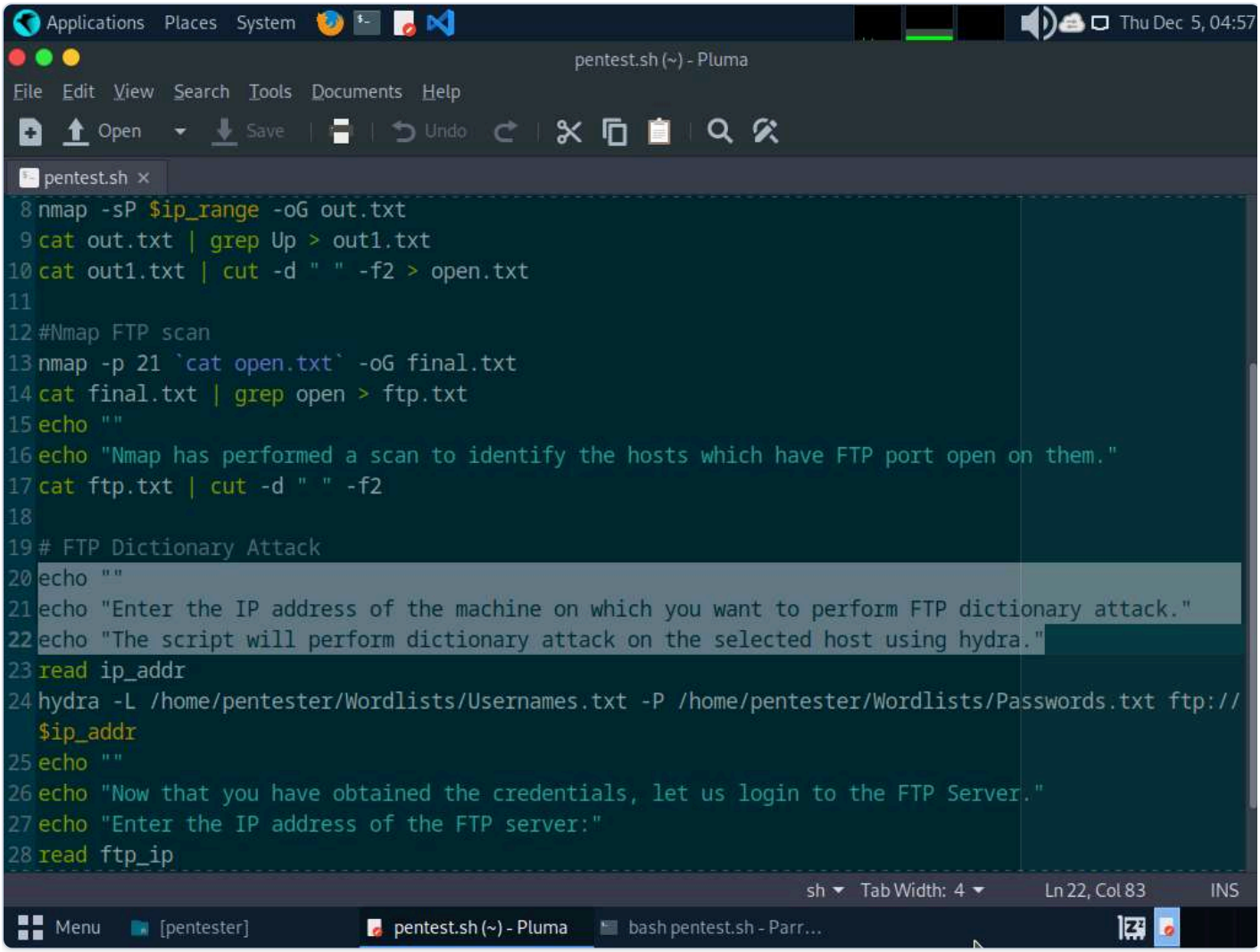

1. Note that our aim is to view only the IP Addresses in the file **ftp.txt**. To view only the IP Address, we shall be using the script `cat ftp.txt | cut -d " " -f2`. Here, field 2 will be selected from each line of the **ftp.txt** file in between the spaces; and the output (i.e., only the IP Address) will be displayed on the screen.



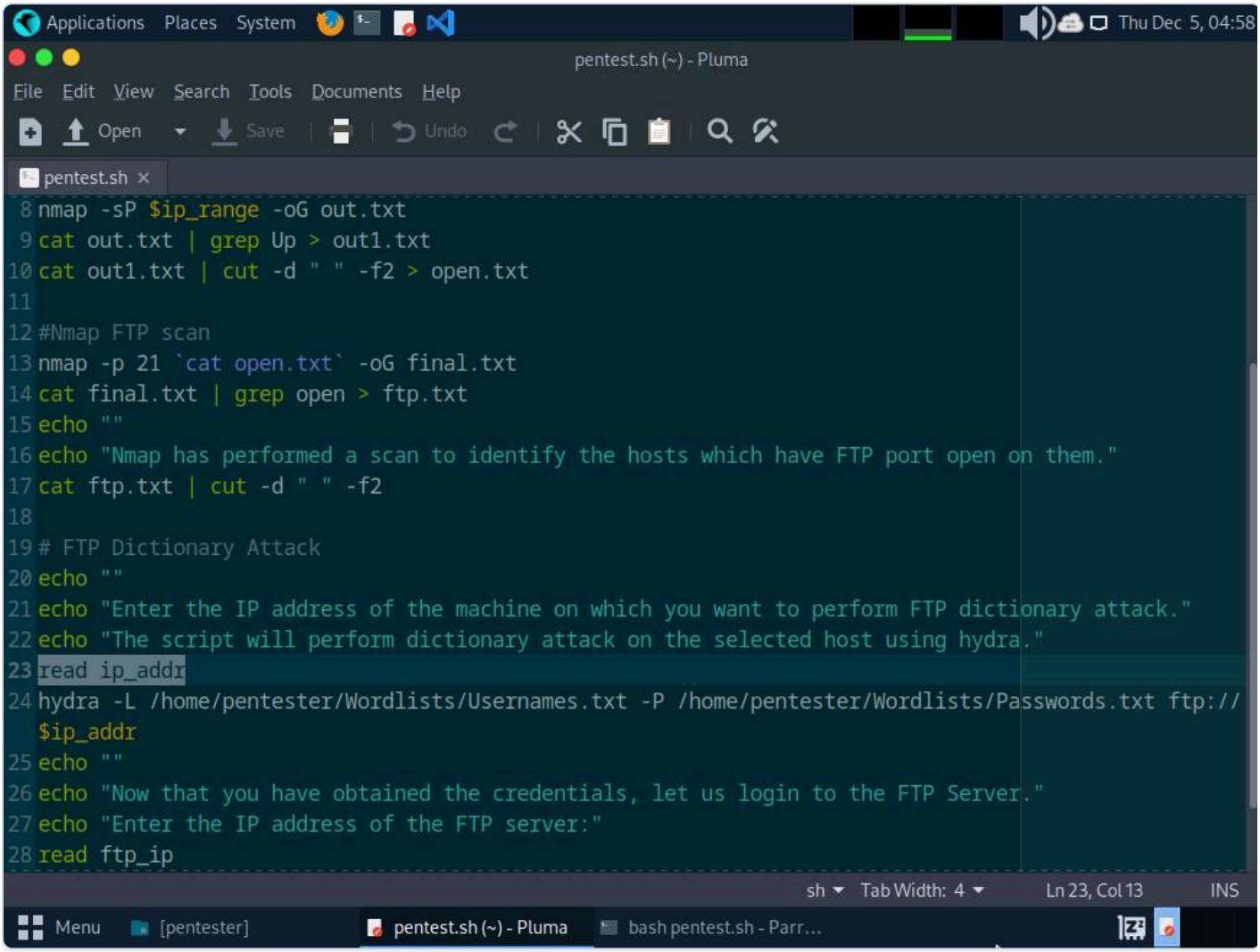

1. Now, minimize the text editor window and maximize the command line terminal. Nmap has performed live host identification on the given IP Address range. Once the live hosts are identified, the script is written in such a way, that a new nmap scan is initiated to find the machines (among the identified live hosts) that have the FTP port open. The live machines with the FTP port open are displayed as shown in the screenshot.



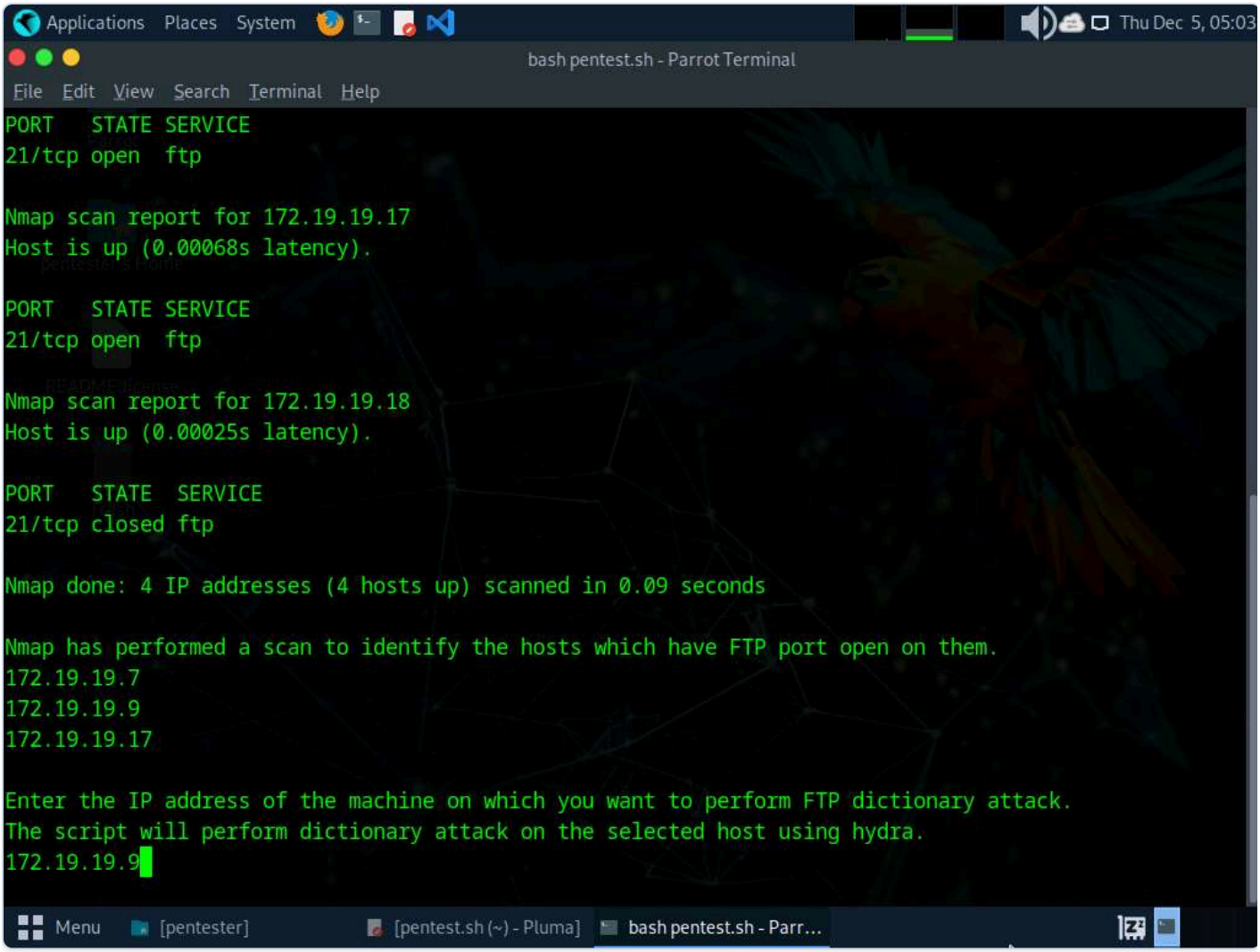

1. Minimize the command line terminal and maximize the text editor window. So far, the above-explained scripts are used to perform live host and FTP port identification. Now, we shall use a machine obtained from the Nmap scanning; and perform a dictionary attack to crack user credentials that have weakly implemented passwords. Before that, we shall use the echo command to write some content related to the dictionary attack, for better understanding.



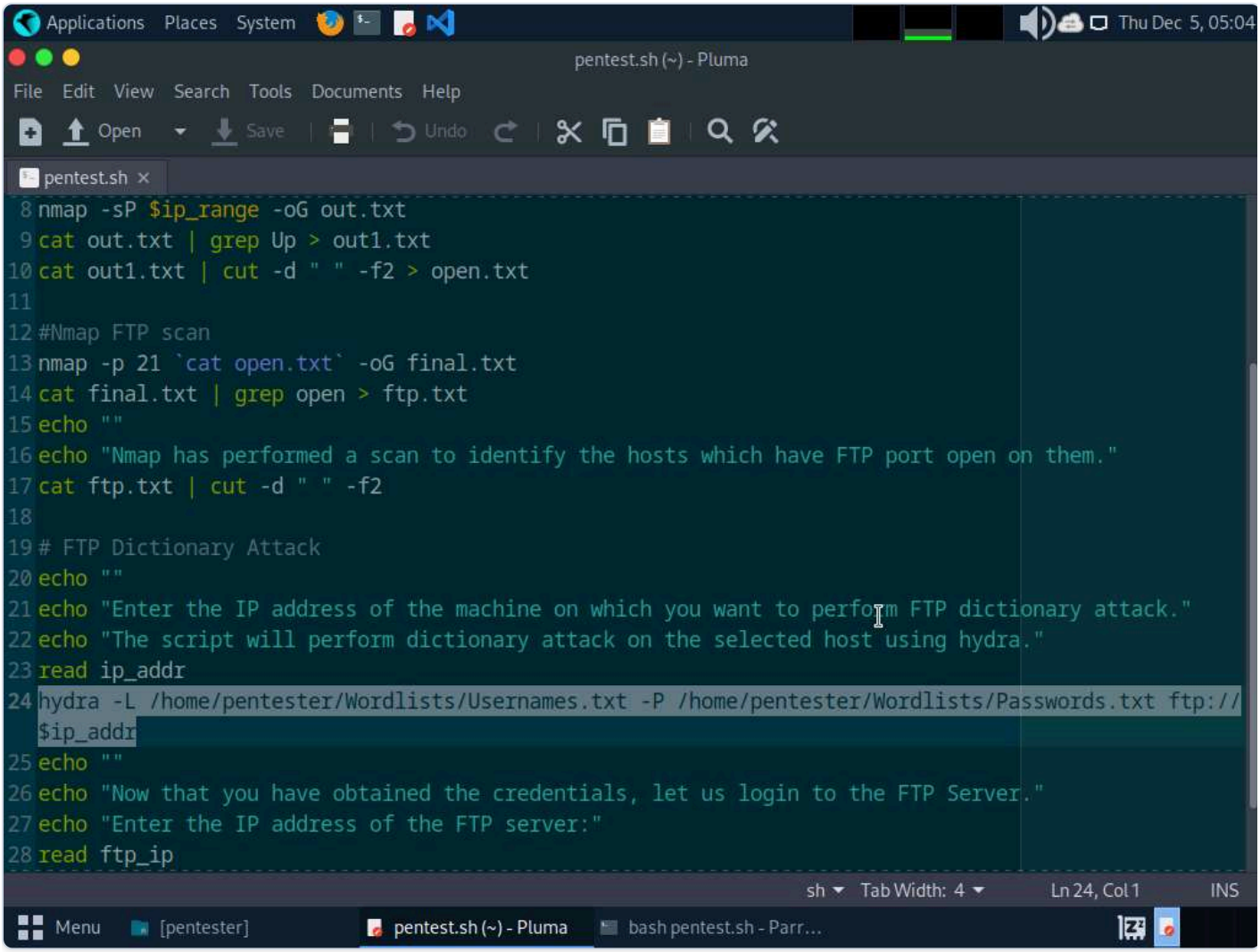

1. As discussed before, regarding the read command, we shall use this command to enter the target machine's IP Address. In this lab, the variable used for addressing the IP Address range is `ip_addr`.



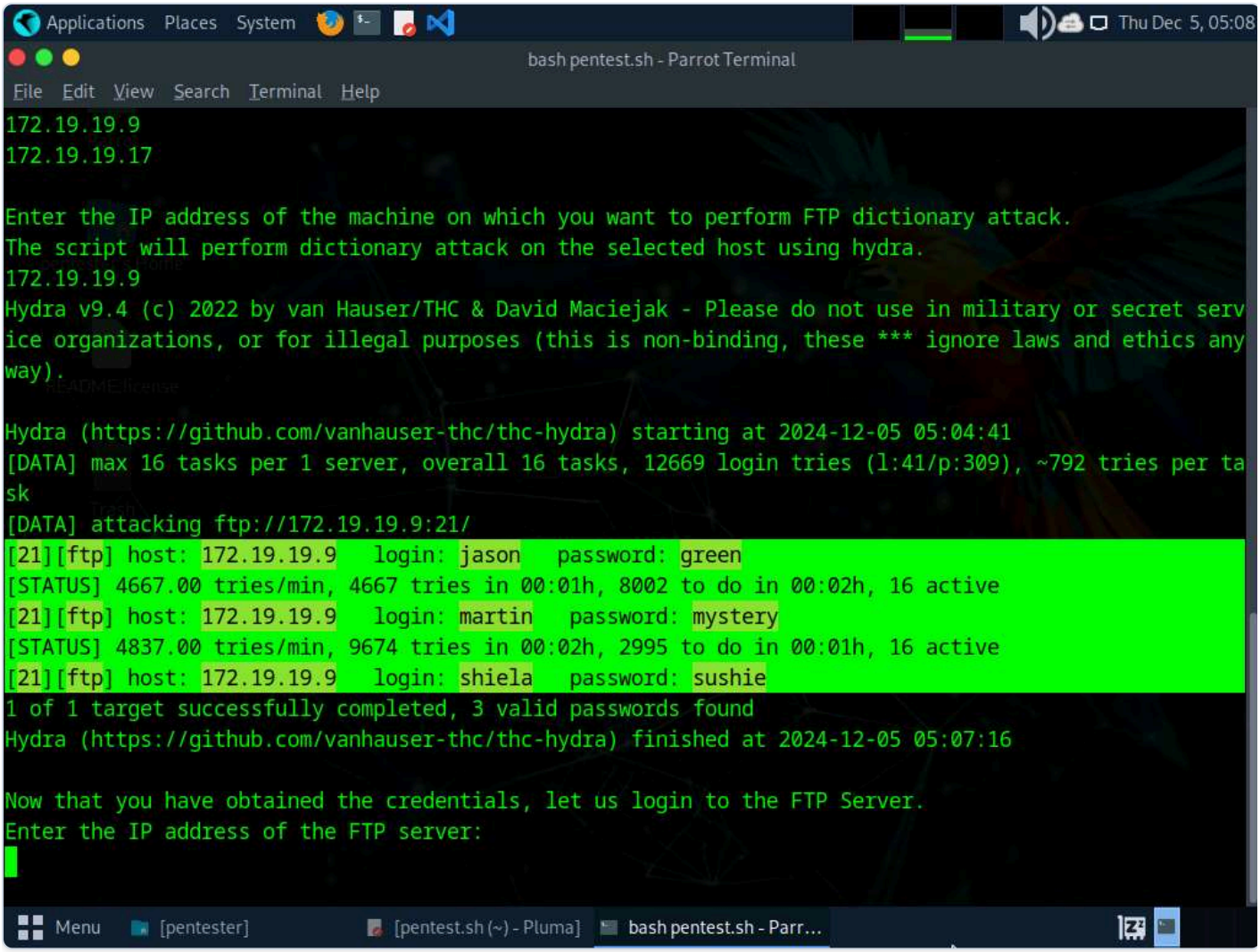

1. Minimize the text editor window and maximize the command line terminal. Since we have obtained the machines whose FTP ports are open, we shall enter the IP Address of the machine on which you would like to perform a dictionary attack to obtain FTP credentials. In this lab, we are going to attack the FTP server of FTP Server whose IP Address is **172.19.19.9**. So, type the IP Address **172.19.19.9** and press Enter. This performs a Dictionary attack on the machine's user accounts using Hydra.



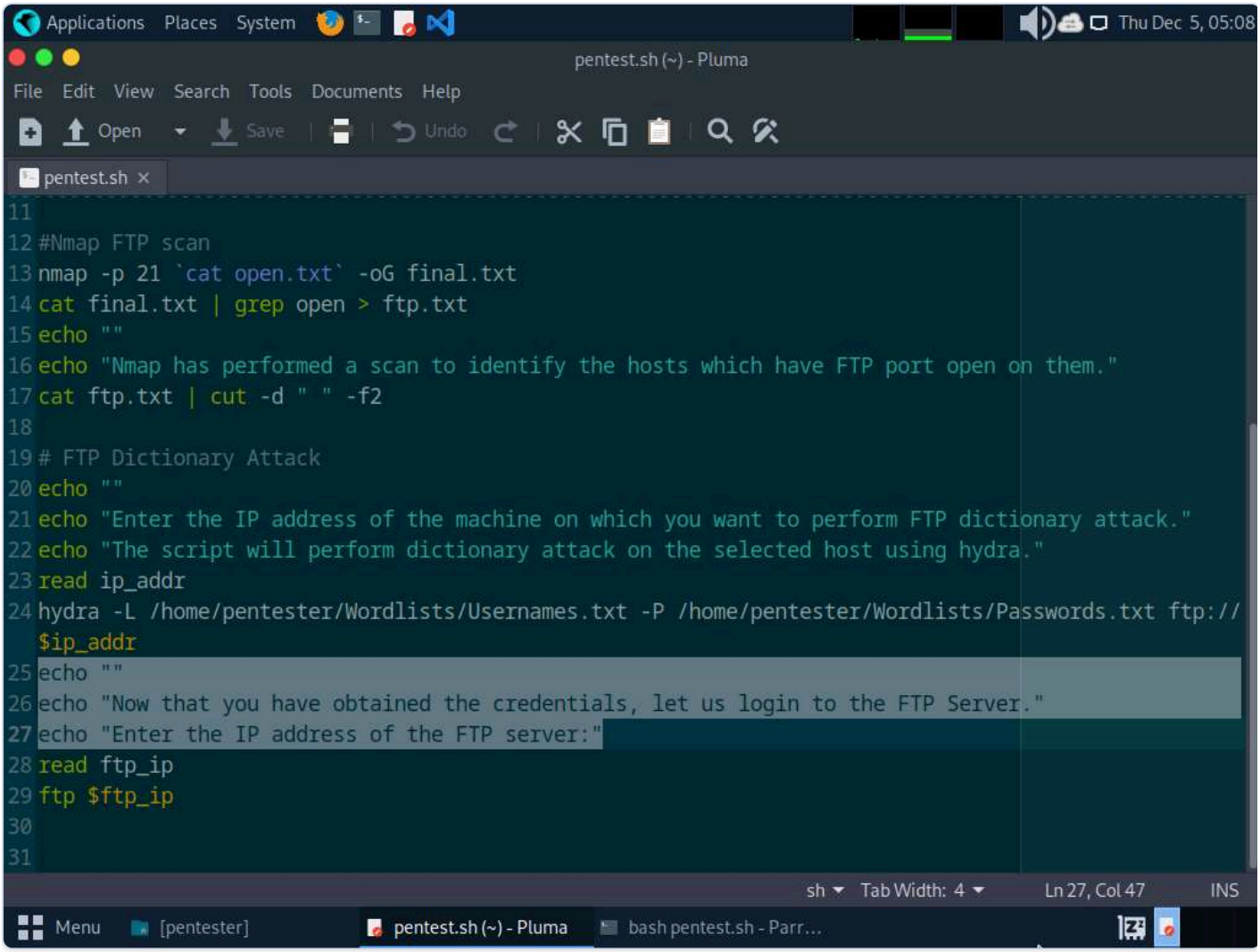

1. Minimize the command line terminal and maximize the text editor window. `hydra -L CPENTv2 Pen Testing Resources/Wordlists/Usernames.txt -P CPENTv2 Pen Testing Resources/Wordlists/Passwords.txt ftp://$ip_addr`: We are going to use hydra to perform a dictionary attack on the FTP server. `-L` switch in the script represents the username list. The list is provided in the location **CPENTv2 Pen Testing Resources/Wordlists/Usernames.txt**. `-P` switch in the script represents the password list. The list is provided in the location **CPENTv2 Pen Testing Resources/Wordlists/Passwords.txt**. `ftp://$ip_addr`: Here, `$ip_addr` grabs the value (IP Address range) you entered in read command. So, a dictionary attack will be performed on the IP address you entered in the previous step, using Hydra.



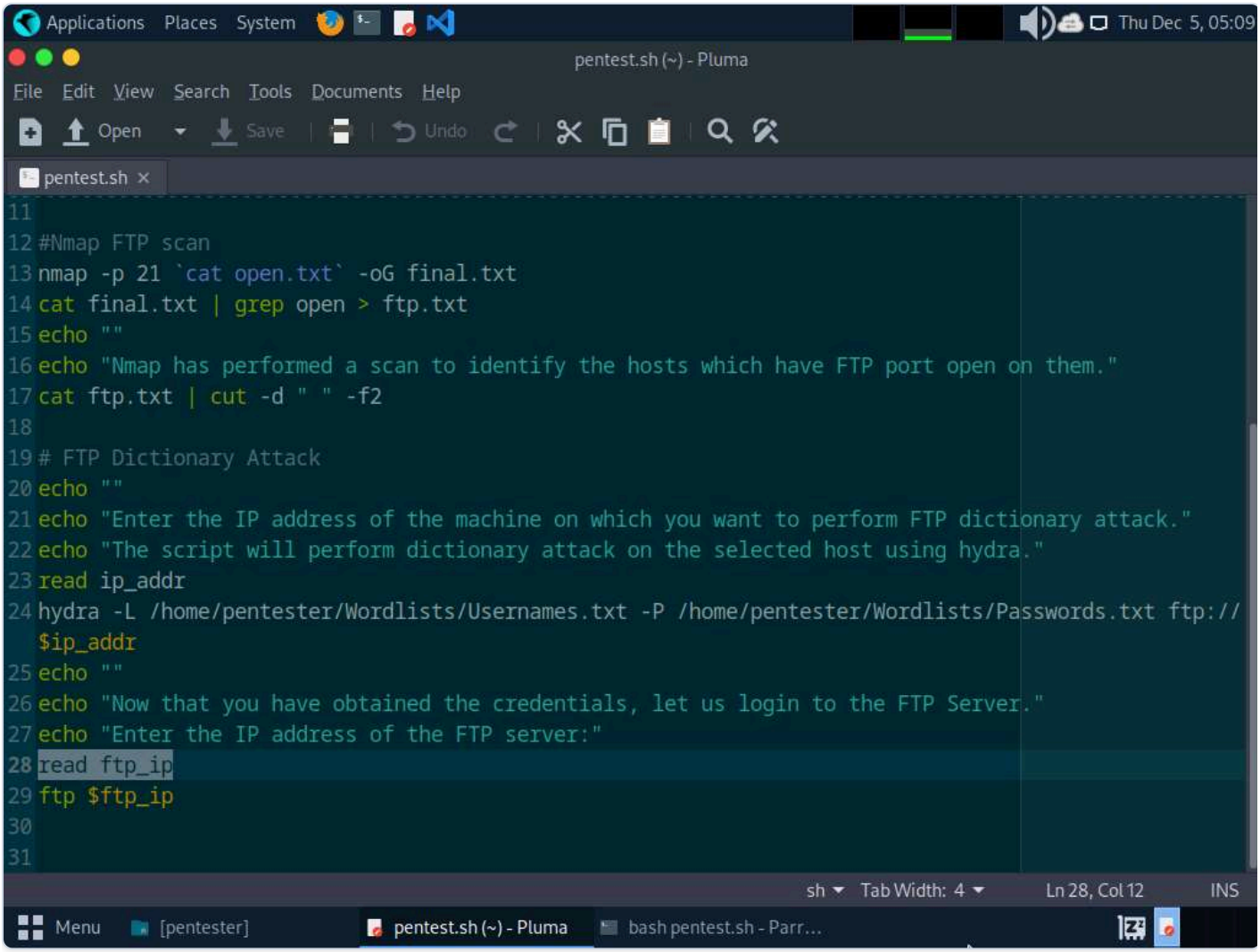

1. Minimize the text editor window and maximize the command line terminal. On issuing the IP Address, Hydra begins to perform a Dictionary attack on the machine and starts displaying the user credentials as shown in the screenshot. *(It takes around 3 minutes for Hydra to crack all the credentials.)*



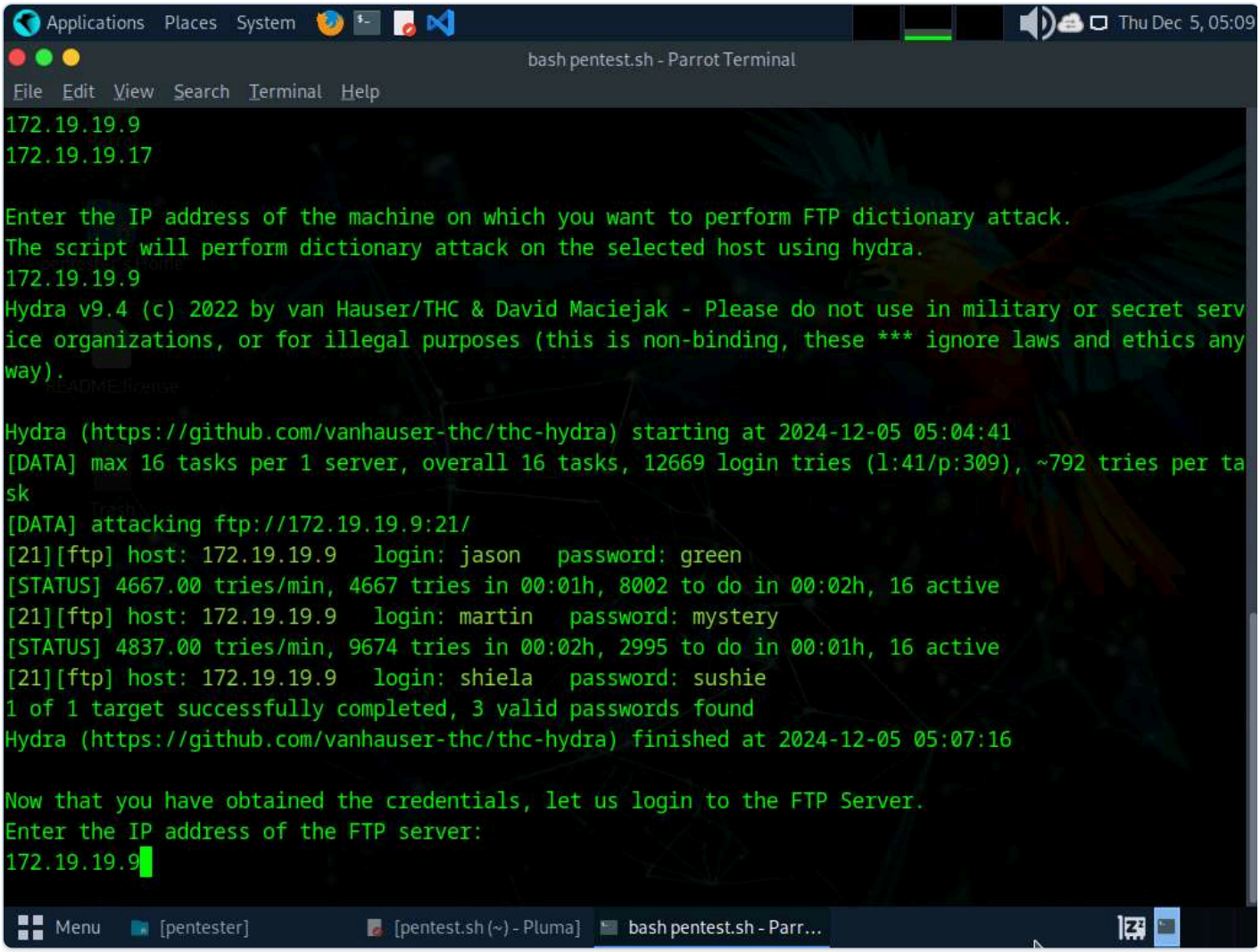

1. Minimize the command line terminal and maximize the text editor window. By now, you would have attained the user credentials to log in to the FTP server. So, your next task will be to log in to the server. Before that, we shall use the echo command to write some content related to the server to log in to the server as shown in the screenshot:



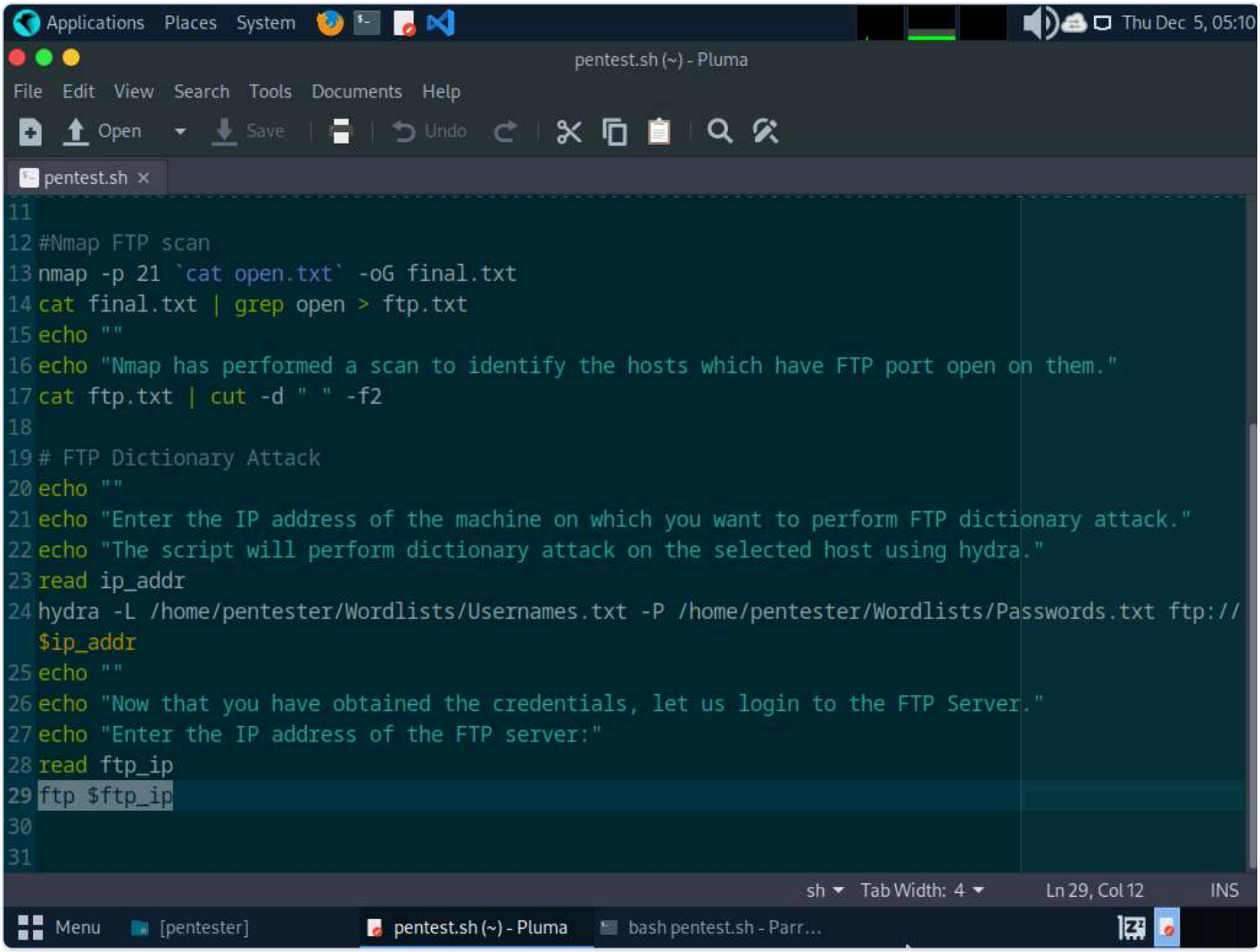

1. Now, we shall use the read command to enter the target machine's IP Address. In this lab, the variable used for addressing the IP Address range is `ftp_ip`.



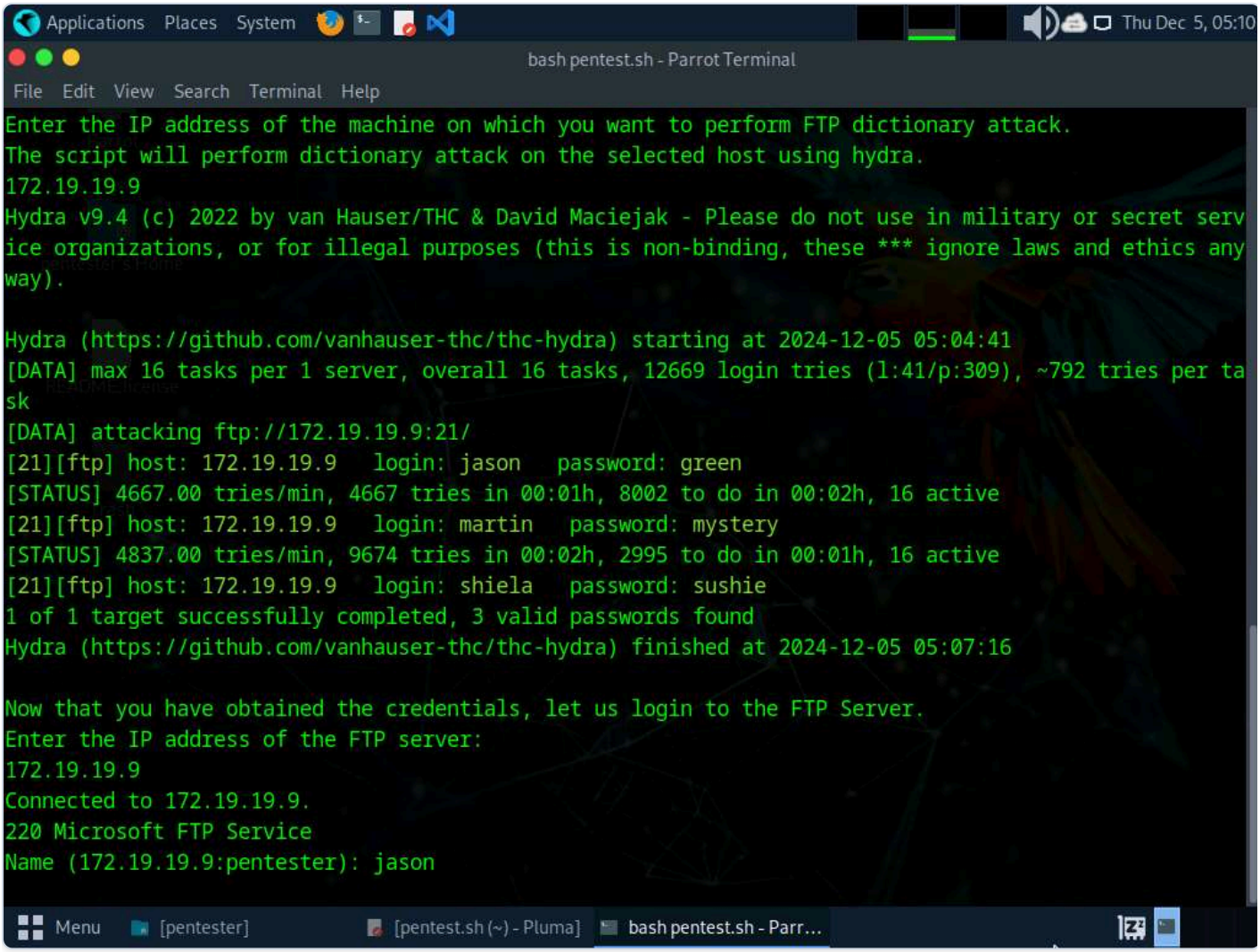

1. Minimize the text editor window and maximize the command line terminal. Once the credentials are obtained, you will be asked to enter the IP Address of the machine to log in to the FTP server. Type **172.19.19.9** and press Enter.



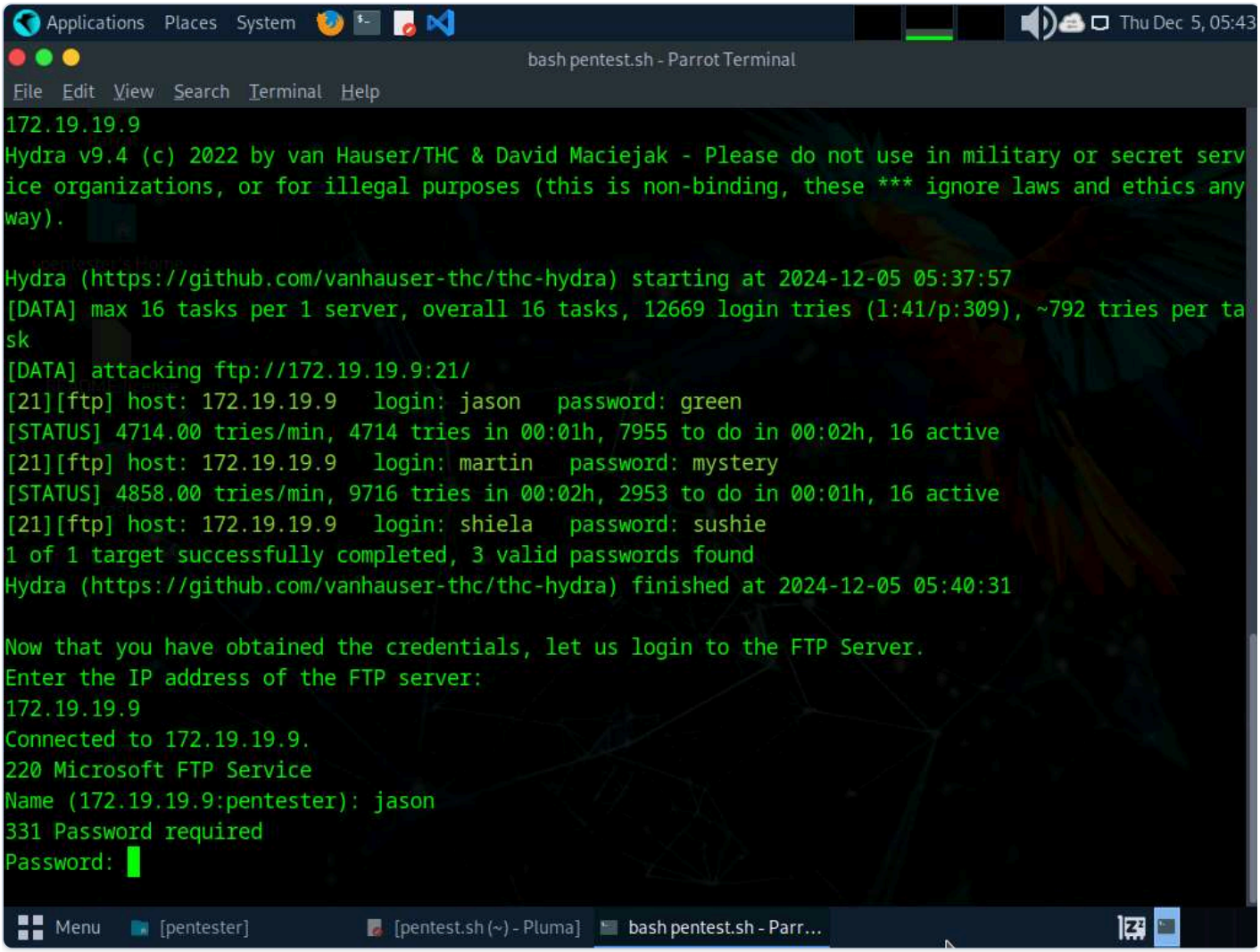

1. Minimize the command line terminal and maximize the text editor window. Upon entering the IP Address, the command `ftp $ftp_ip` is given to log in to the IP Address of the target machine.



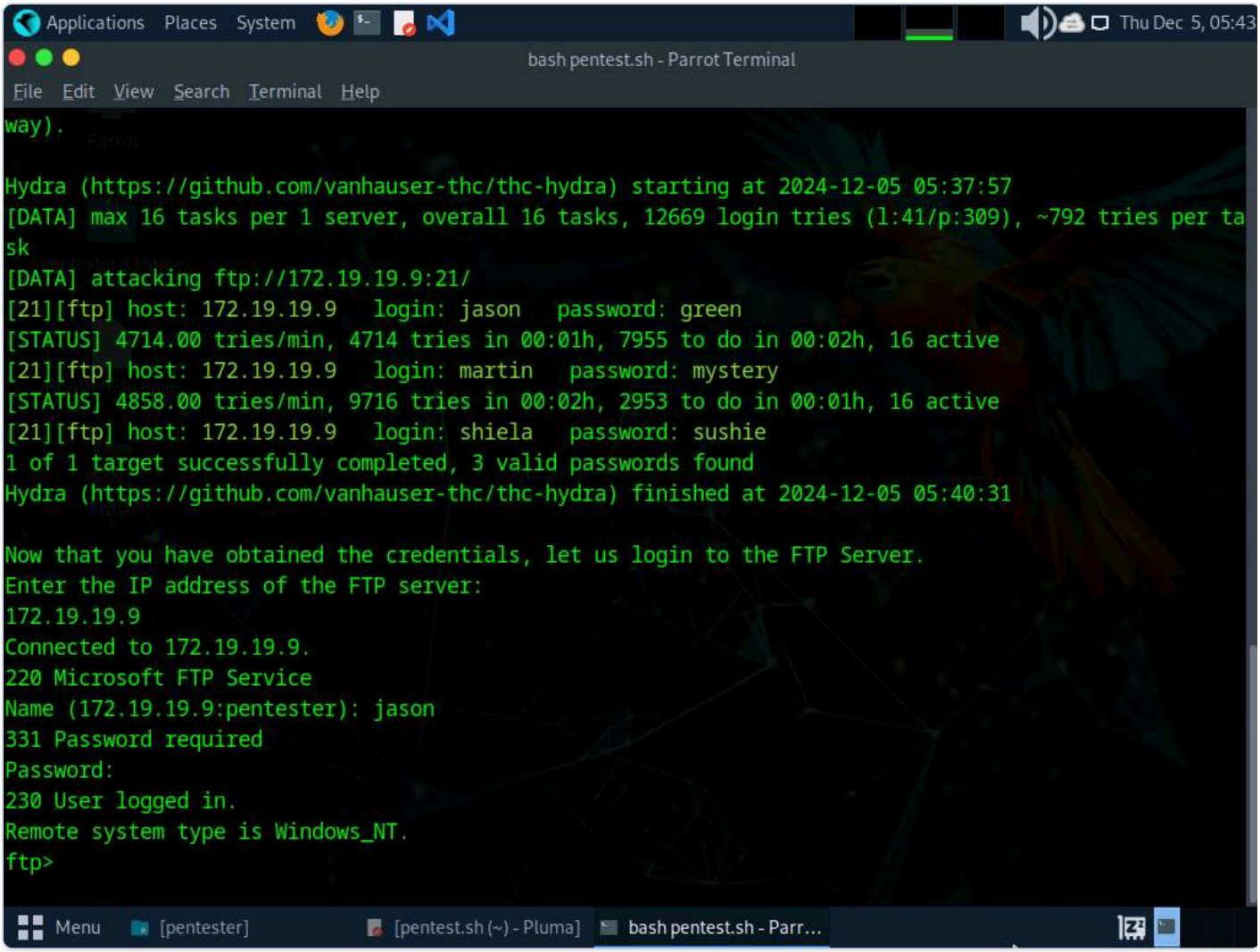

1. Minimize the Leafpad window and maximize the command line terminal. You will be asked to enter a username. In this lab, we are logging in to **jason** user's account. So type **jason** and press Enter. *(You may issue any one of the account's usernames in the Name field.)*




1. You will be asked to enter the password for the user account. Since we are going to log in to john's user account, type **green** (password for jason's user account) and press Enter. *(The Password field remains blank while you are typing the password.)*




1. On issuing the user credentials, you will be logged in to the FTP Server, as shown in the screenshot.




In the same way, you may run this script to crack the user credentials and access the FTP Server if hosted in the other networks. Close all the opened windows.

In this lab, you have successfully performed a subnet scan, found machines having FTP ports open, performed a dictionary attack to attain credentials, and successfully logged in to the server using the obtained credentials.

---

> **IMPORTANT:** ❓ **Question 3.5.4.1** On the Parrot Security machine, utilize a Bash script to conduct an Nmap scan for identifying open ports on the target IP address (**172.19.19.9**). Perform a brute-force attack to obtain credentials, then use the compromised credentials to authenticate via FTP. Enter the cracked password for the user 'shiela' to complete the process. [!SUCCESS] ✅ **Answer:** **sushie**

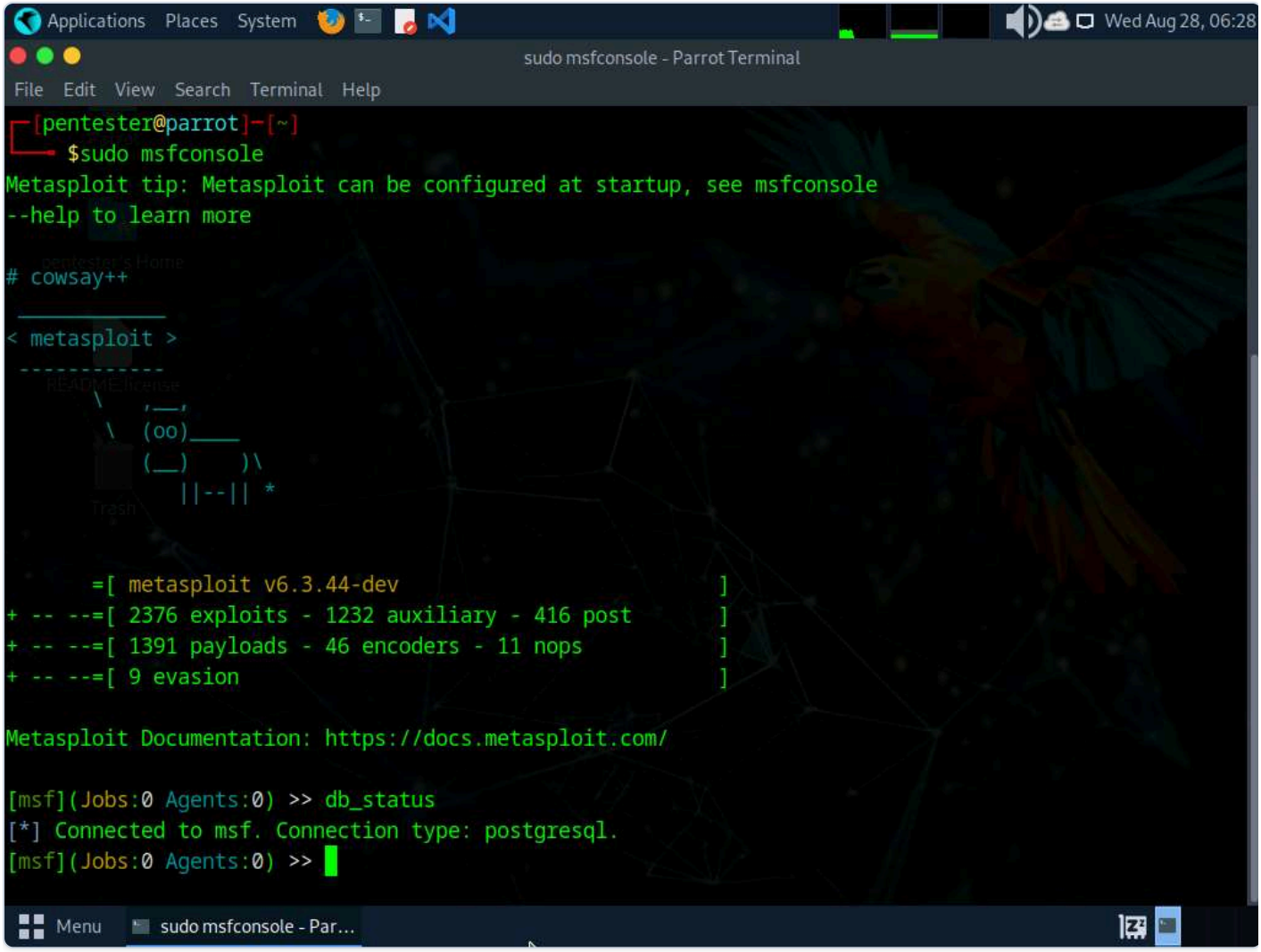
---

## Task 5: Using Workspaces and db_nmap

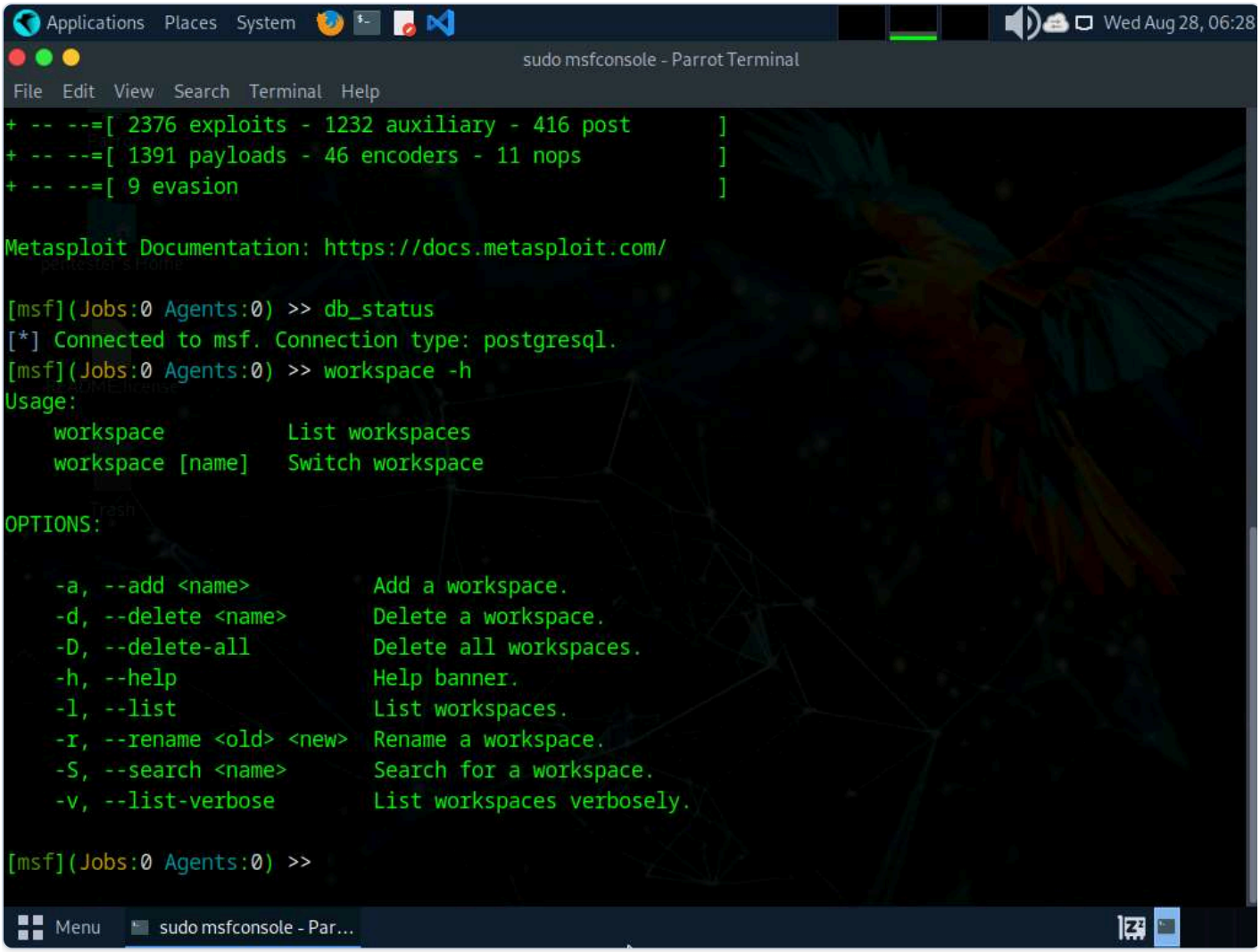
In this lab, you will:
- Conduct the task of creating workspaces
- Use db_nmap contained within the Metasploit Framework
- Store and retrieve the scan results from the tool
- Import the results into a Metasploit module

### Lab Tasks

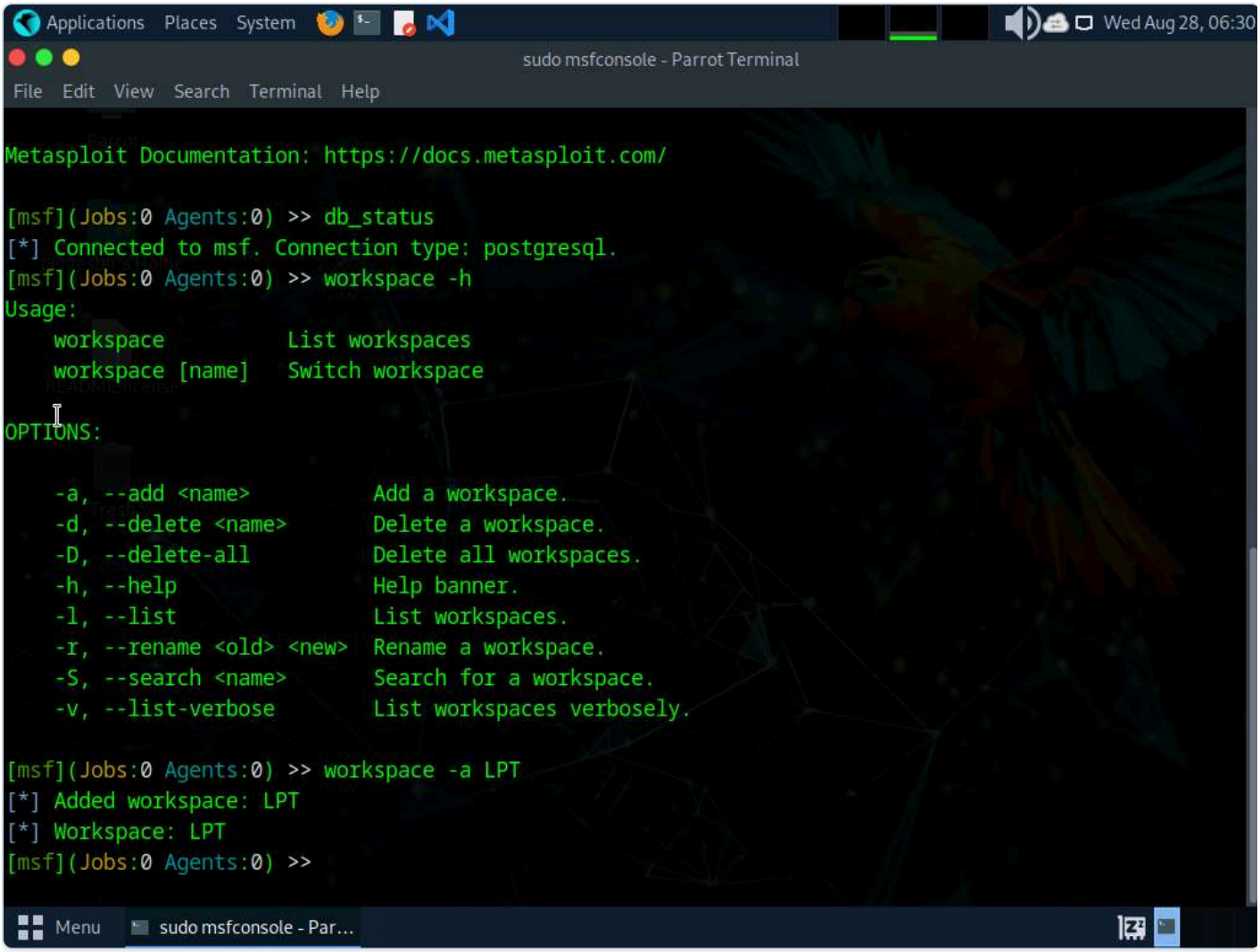
1. Open a new terminal window. Set up and initialize the sql server. In the terminal window, type **sudo service postgresql start** and press Enter. Enter the password **toor** if you are required to. The postgresql command initializes the PostgreSQL database service.
2. After the database is launched, type **sudo msfdb init**, and press Enter. Enter the password **toor** if you are required to. The msfdb init command initializes and creates the PostgreSQL database for Metasploit.
3. *(If a database appears to be already configured, a message to skip initialization appears; ignore the message.)*
4. Once the databases are created and initialized, we can quickly fire up Metasploit using the command **sudo msfconsole**. Enter the password **toor** if you are required to.
5. To find out the status of the database, type **db_status** in the terminal window, as shown in the screenshot.



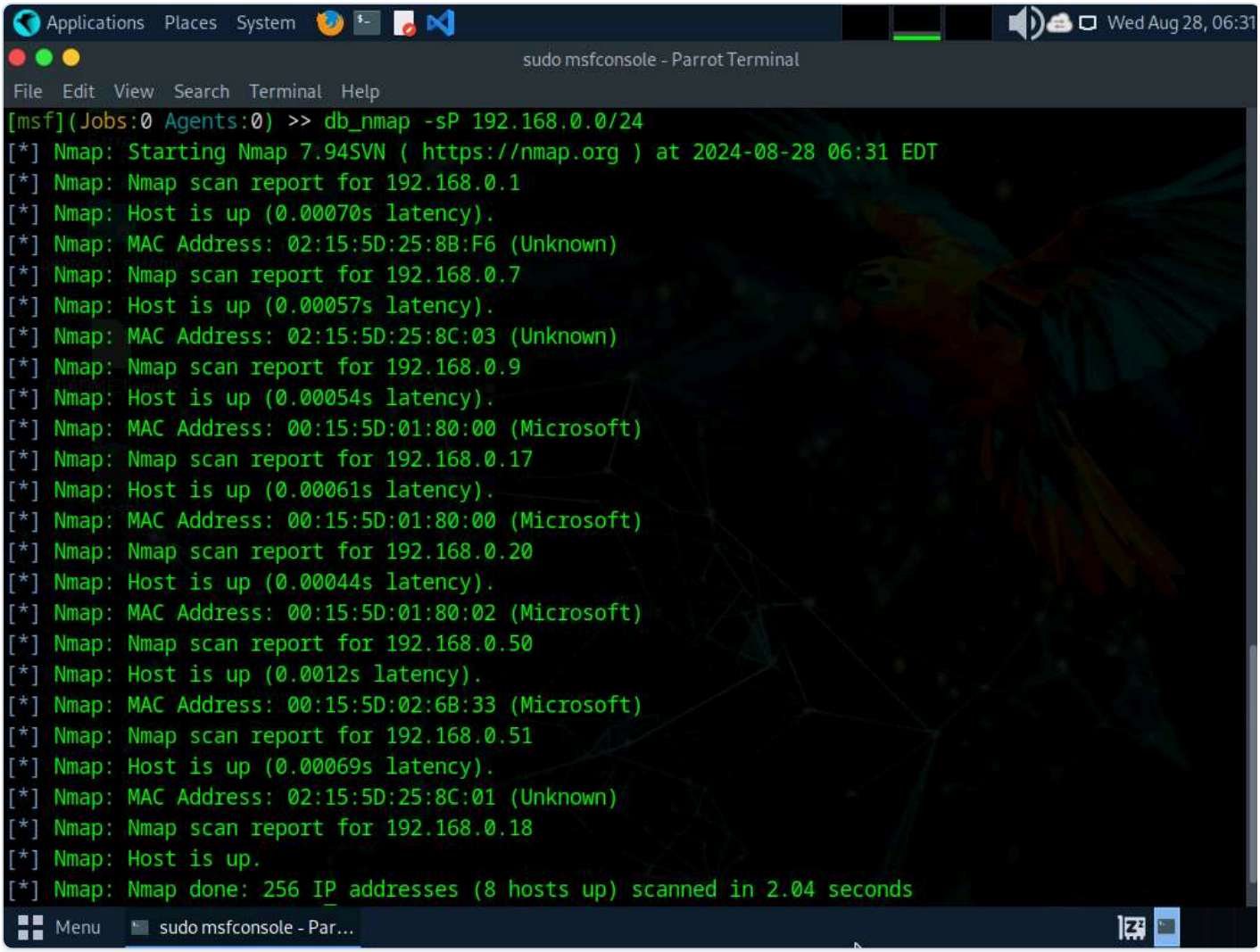

1. The Metasploit tool has different workspaces; type **workspace -h** to see the different commands available for the workspace. Once you have reviewed them, continue.



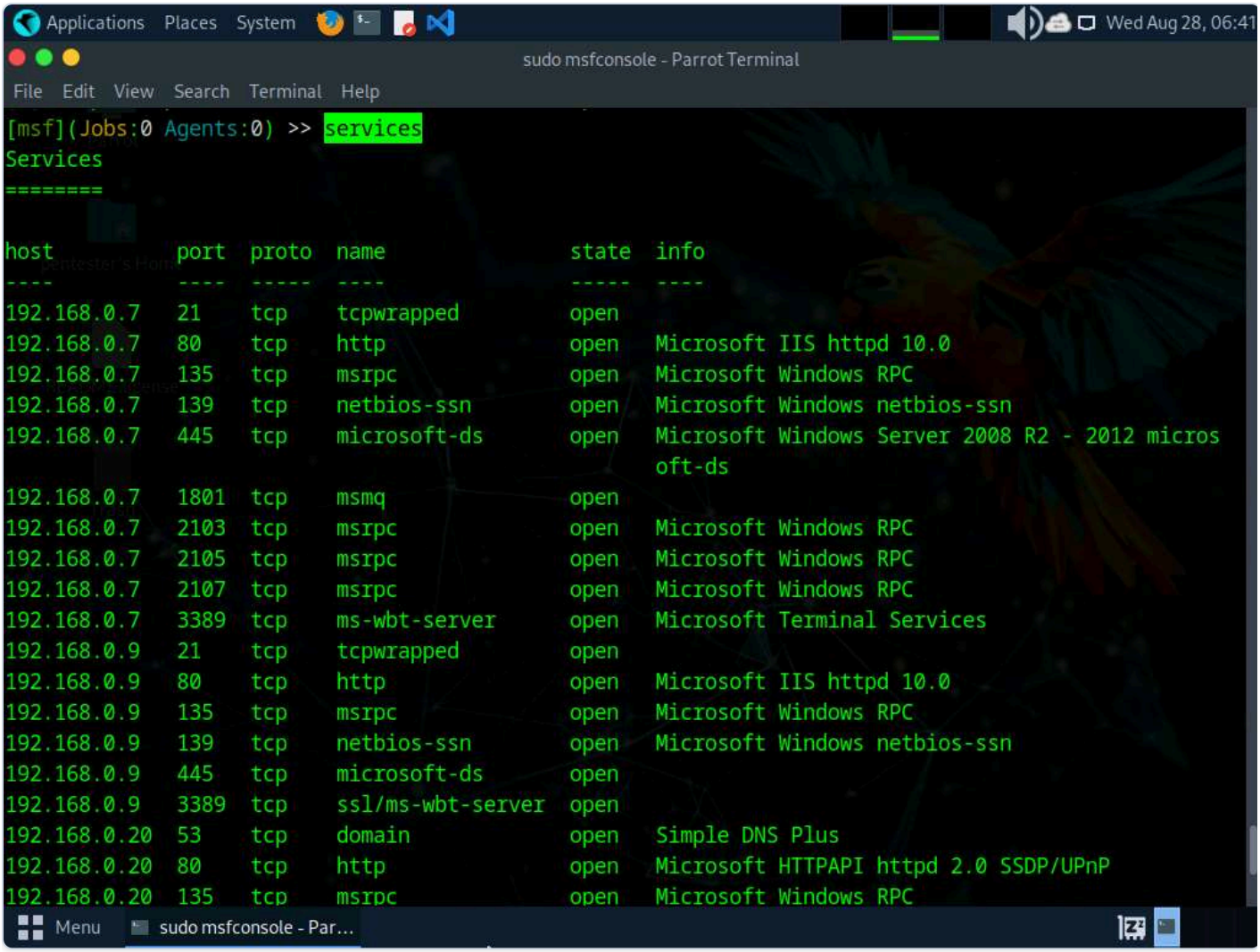

1. Create a workspace for your data by typing **workspace -a LPT**. You now have a workspace setup. You are ready to use the built-in Nmap database within Metasploit.




1. Next, use the tool to conduct the scanning methodology. Enter **db_nmap -sP 192.168.0.0/24** as shown in the screenshot.



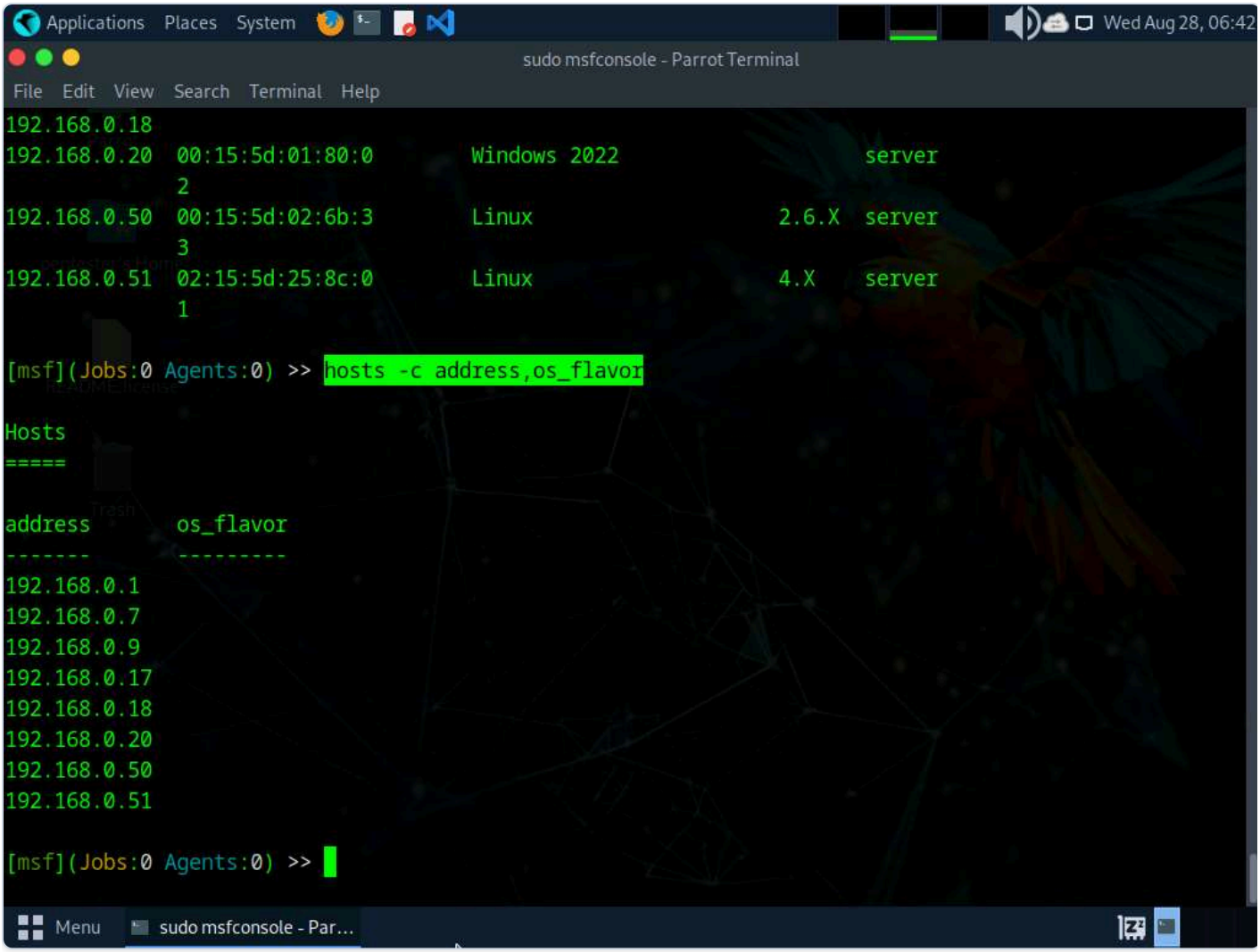

1. Once the scan is complete, move to the next step; type **db_nmap -sS 192.168.0.2-70**.
2. Once the scan is complete, move to the next step; type **db_nmap -sV 192.168.0.2-70**.
3. Once the scan is complete, move to the next step; type **db_nmap -A 192.168.0.2-70**.
4. You have now conducted the bulk of the scanning methodology. Sufficient data have been stored in the workspace. To examine the database information, type **services** and press Enter, as shown in the screenshot.



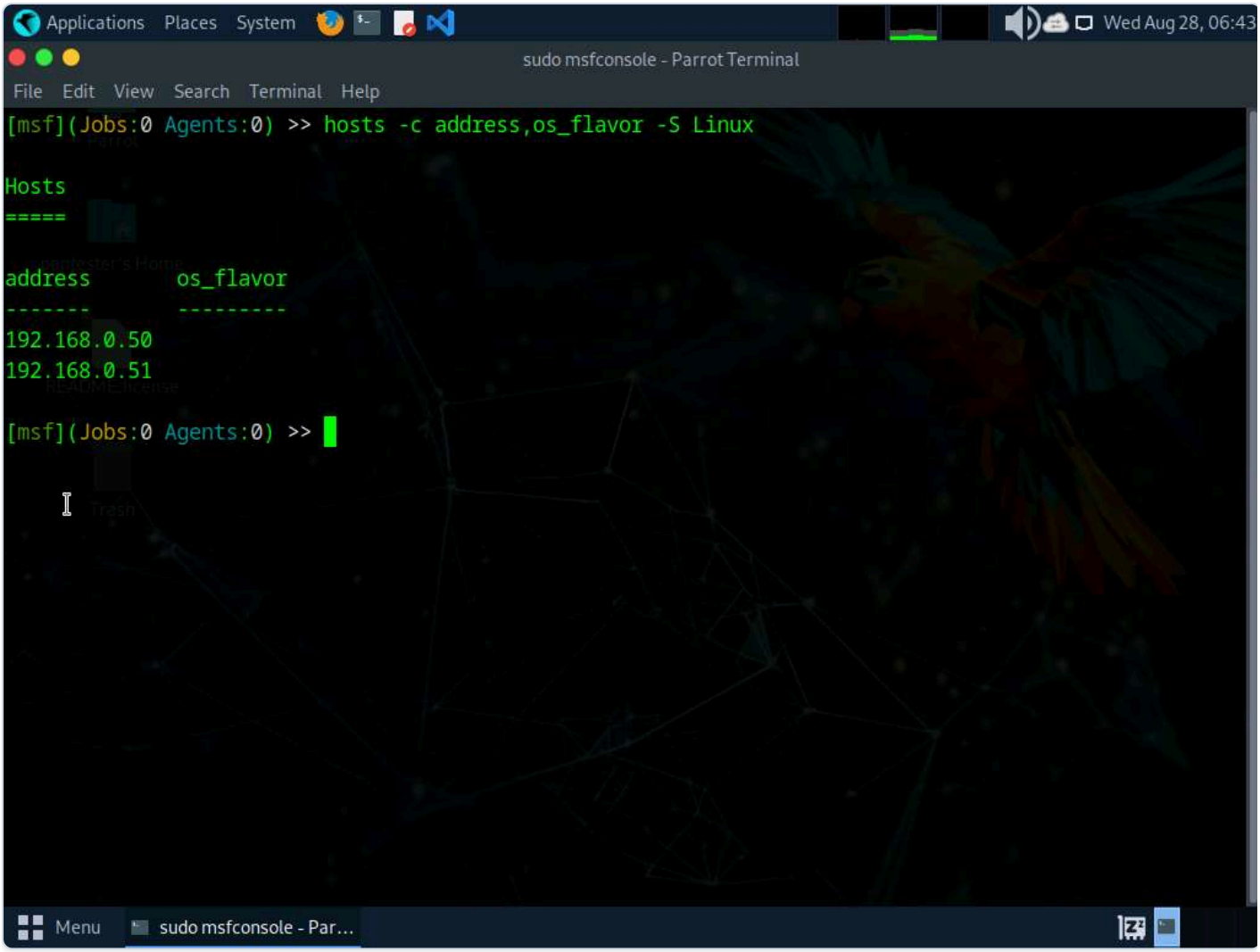

1. Next, examine the database list of hosts; type **hosts** as shown in the screenshot.



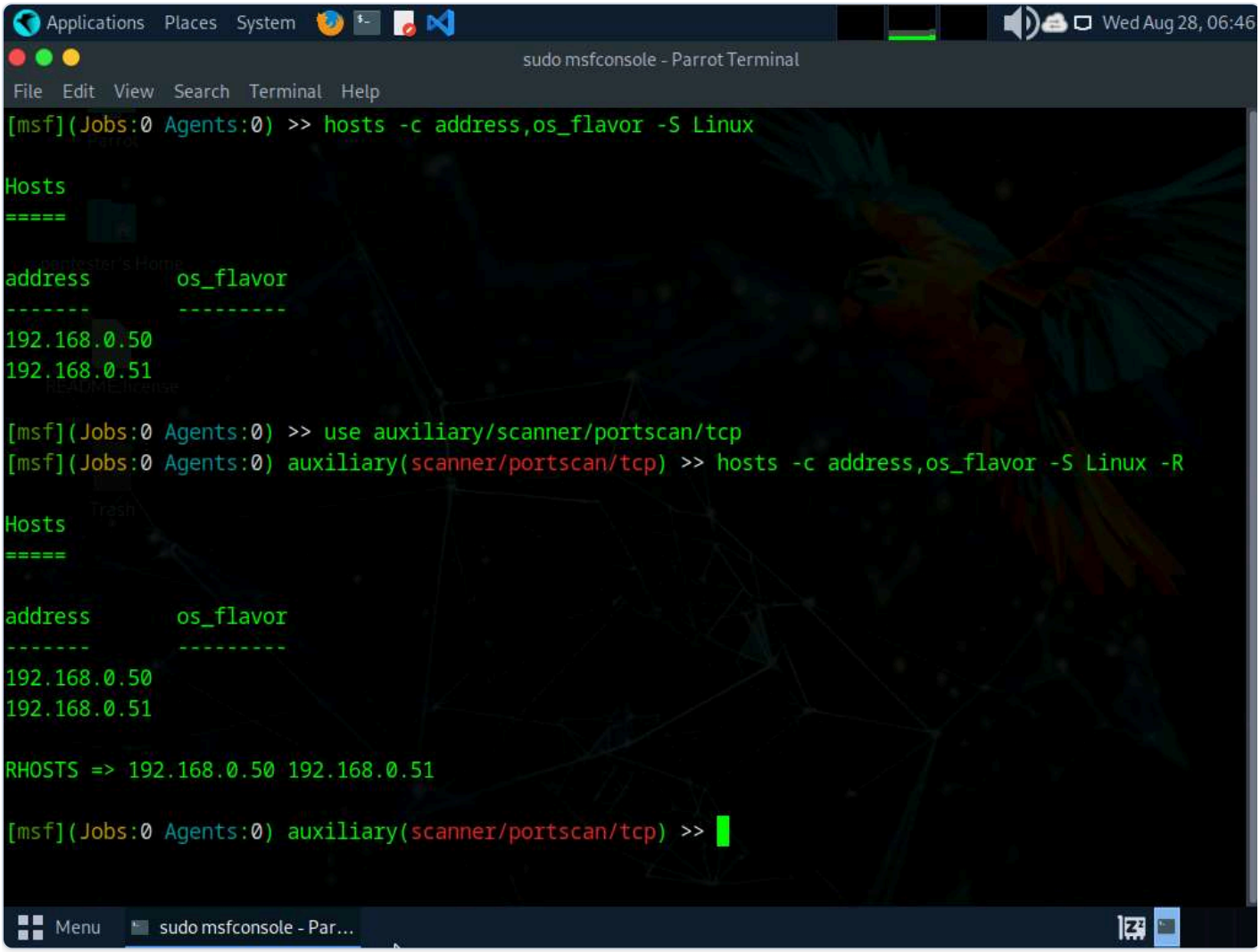

1. Enter **hosts -h** to see the different available options. Query the "hosts" command to display only the IP address and OS type using the `-c` switch. Type **hosts -c address,os_flavor** and press Enter, as shown in the screenshot.



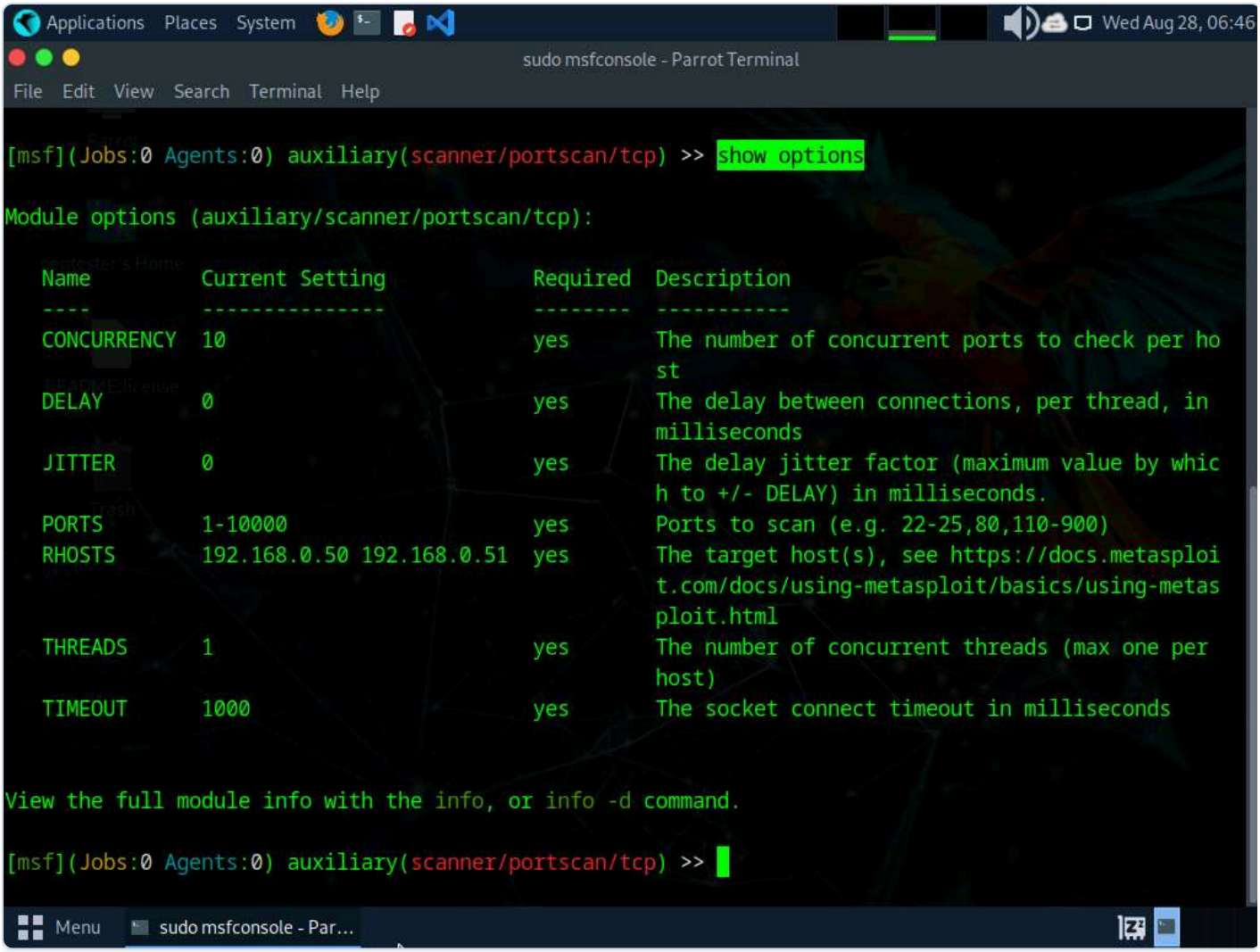

1. Note that you can also search all entries for a specific target. If you wish to find only Linux-based machines from the scan, use the `-S` option. Type **hosts -c address,os_flavor -S Linux**.



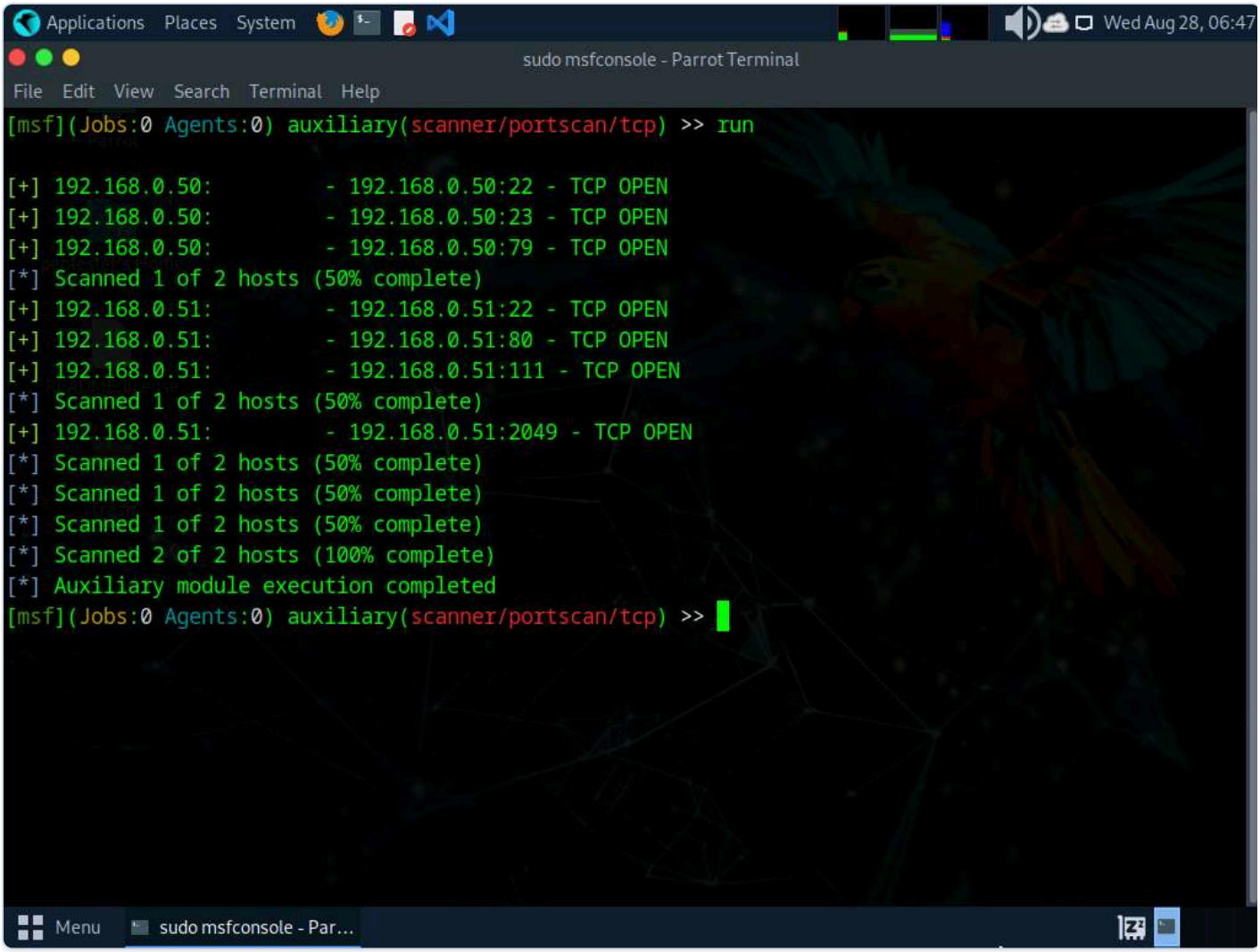

1. Next, import the results of the scans into a Metasploit module. Type **use auxiliary/scanner/portscan/tcp** and press Enter.
2. Input the data into the scanner by using the R option; type **hosts -c address,os_flavor -S Linux -R** and press Enter, as shown in the screenshot.




*(The above command will import the results in the host table into RHOSTS; you can view this by entering show options.)*




1. Once you are ready, type **run** and press Enter. The scan will be conducted against the target added to the database, as shown in the screenshot.




1. You have diverse search options; for this, type **services -c name,info -S http** and press Enter. This will search the hosts for services with HTTP in the name.

This concludes the lab.

---

> **IMPORTANT:** ❓ **Question 3.5.5.1** On the Parrot Security machine, create workspaces and utilize db_nmap within the Metasploit Framework to perform network scanning. Store and retrieve the scan results, then import them into a Metasploit module. Identify and document the version of Apache running on the target machine at **192.168.0.51**. [!SUCCESS] ✅ **Answer:** **2.4.52**

---

## Task 6: Scanning and Building a Target Database

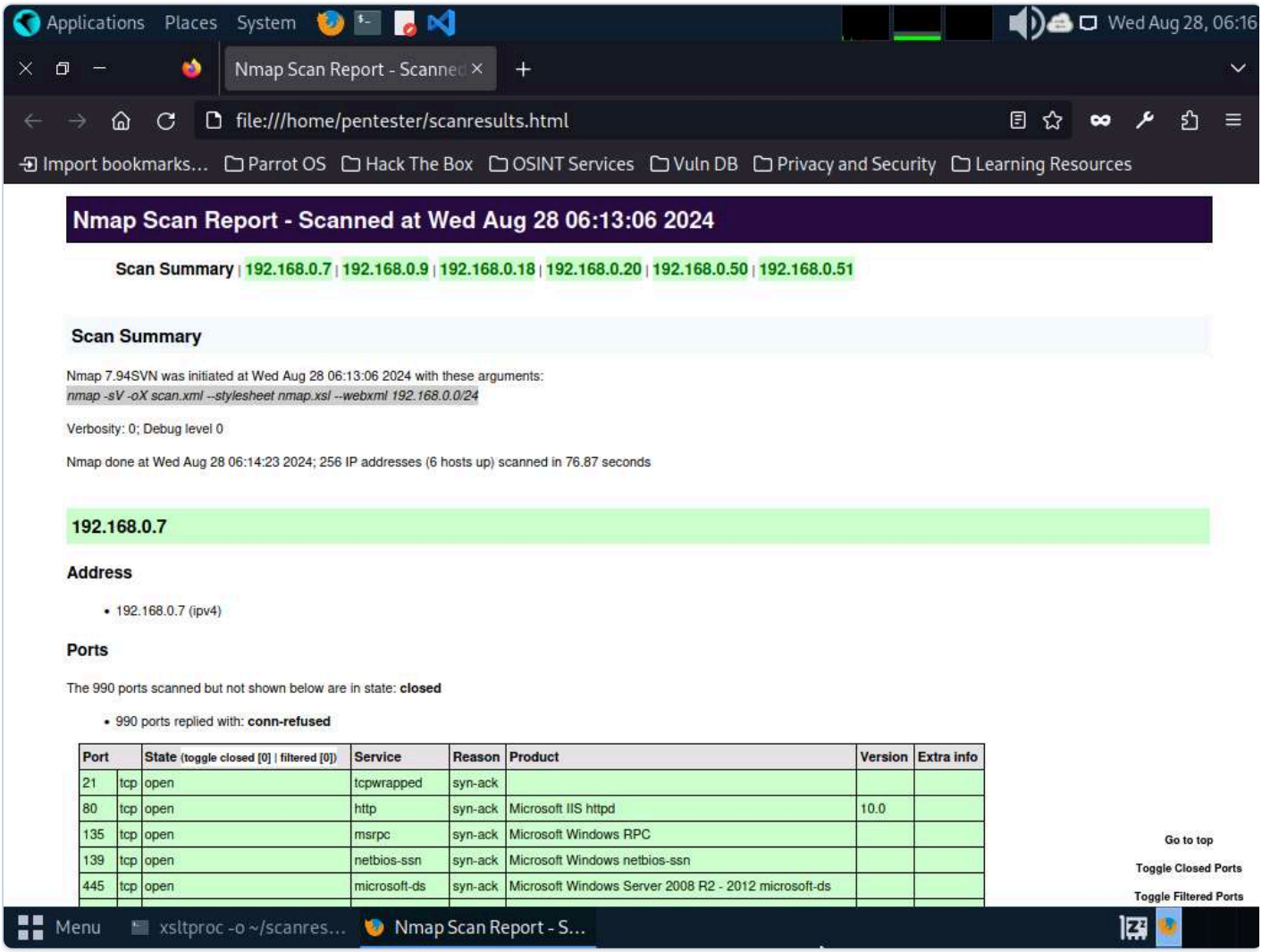
Once the tools are used, a target database must be created to prioritize targets. This is a critical step in producing the final report. The objective of this lab is to help students analyze the output of a tool and check if they can start to populate the target database used to produce the report.

In this lab, you will:
- Scan for targets
- Conduct the scanning methodology
- Review the data from the scans

- Analyze the scan output
- Build an initial target database

## Lab Tasks

1. Click **Parrot Security**. Parrot lock screen appears. By default pentester is selected as the user. Type **toor** in the Password field and press Enter.
2. Launch a command-line terminal. In a terminal window, type **nmap** and press Enter.
3. Live Systems: `-sP`
4. Ports: `-sS`
5. Services: `-sV`
6. Enumerate: `-A`
7. Convert the file to HTML using the xsltproc command. Enter **xsltproc -o ~/scanresults.html /usr/share/nmap/nmap.xsl scan.xml**. Run an nmap command to create a scan.xml file. An example of the XML-formatted output is shown in the screenshot.




1. Next, populate the target database. For this, the following database information is required: Host/IP, OS, Ports, Services, Vulnerabilities, Exploit, Notes, Priority. An example of the above is shown in the screenshot:

| | Host/IP | Host/IP | Host/IP | Host/IP | Host/IP |
|---|---|---|---|---|---|
| OS | | | | | |
| Ports | | | | | |
| Services | | | | | |
| Vulns | | | | | |
| Exploit | | | | | |
| Notes | | | | | |
| Priority | | | | | |

From this point forward, create a target database for every opportunity, range, or environment. This concludes the lab exercise.

---

> **IMPORTANT:** ❓ **Question 3.5.6.1** On Parrot Security machine, utilize Nmap to identify and scan potential targets. Conduct a thorough scan, review the collected data, analyze the output, and compile an initial target database. Perform a port scan on the target subnet **192.168.0.0/24**, then determine and document the number of open ports on the host **192.168.0.20**. [!SUCCESS] ✅ **Answer:** **10**

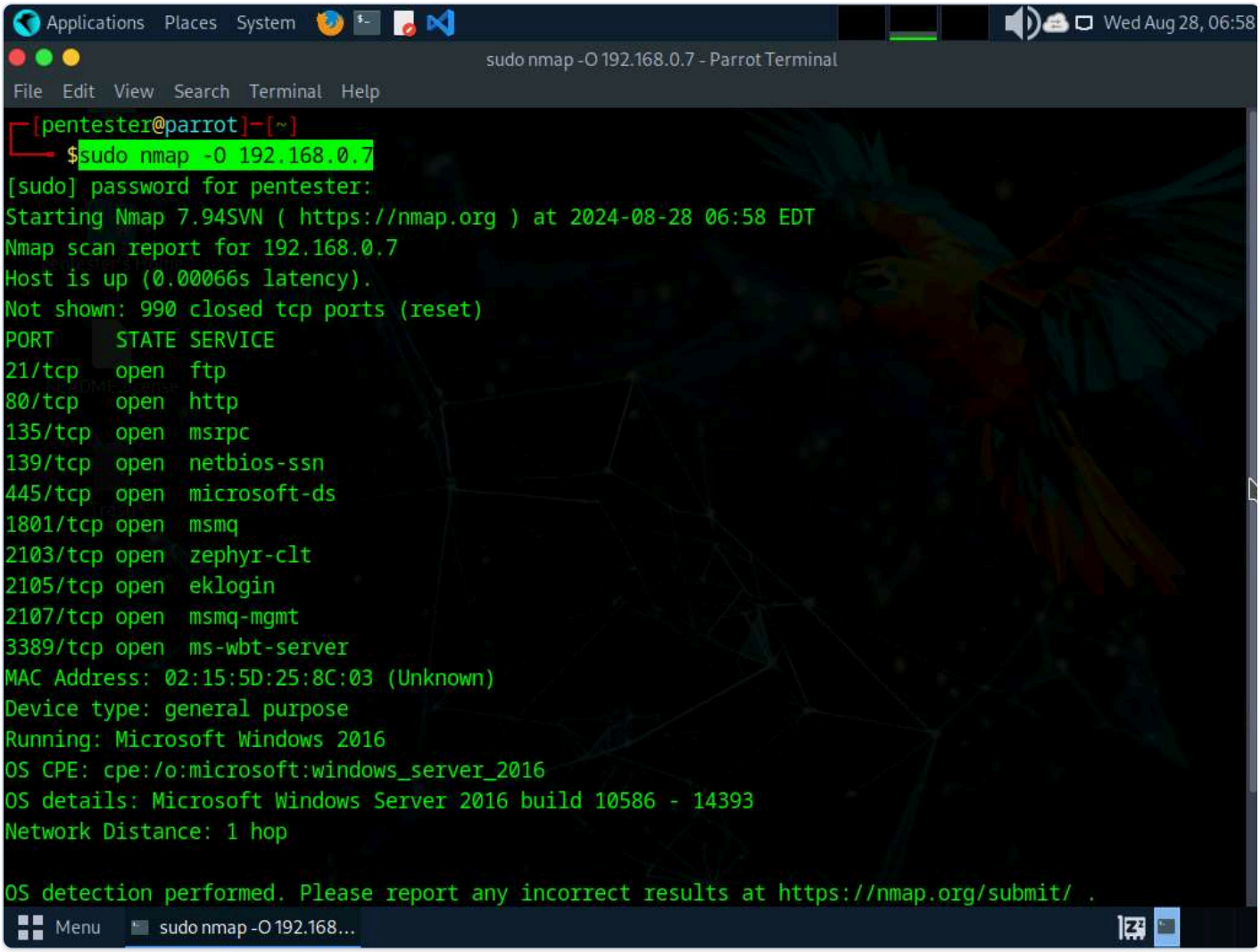
---

## Task 7: OS Fingerprinting with Nmap

A penetration tester must use a tool to fingerprint the OS. The choice of tool here is the most popular tool on the market that is free and open source: Nmap. The objective of this lab is to help students use the Nmap tool and focus on the tool's OS capability.

### Lab Tasks

1. There is a specific option for attempting to enumerate the OS with Nmap: `-O` option (the "O" does not stand for zero).
2. Start capturing on Wireshark.
3. In a terminal window, type **sudo nmap -O 192.168.0.X**, replacing the "X" with the required IP address number from your target database, as shown in the screenshot. If you are asked to enter the password, type **toor** and press Enter.




1. Carefully review the results and transfer the required data to the target database.

This concludes the lab exercise.

---

> **IMPORTANT:** ❓ **Question 3.5.7.1** Conduct OS fingerprinting on the target machine at IP address **192.168.0.51** using Parrot Security, and determine the operating system name of the target. [!SUCCESS] ✅
> **Answer:** **Linux 4.15**

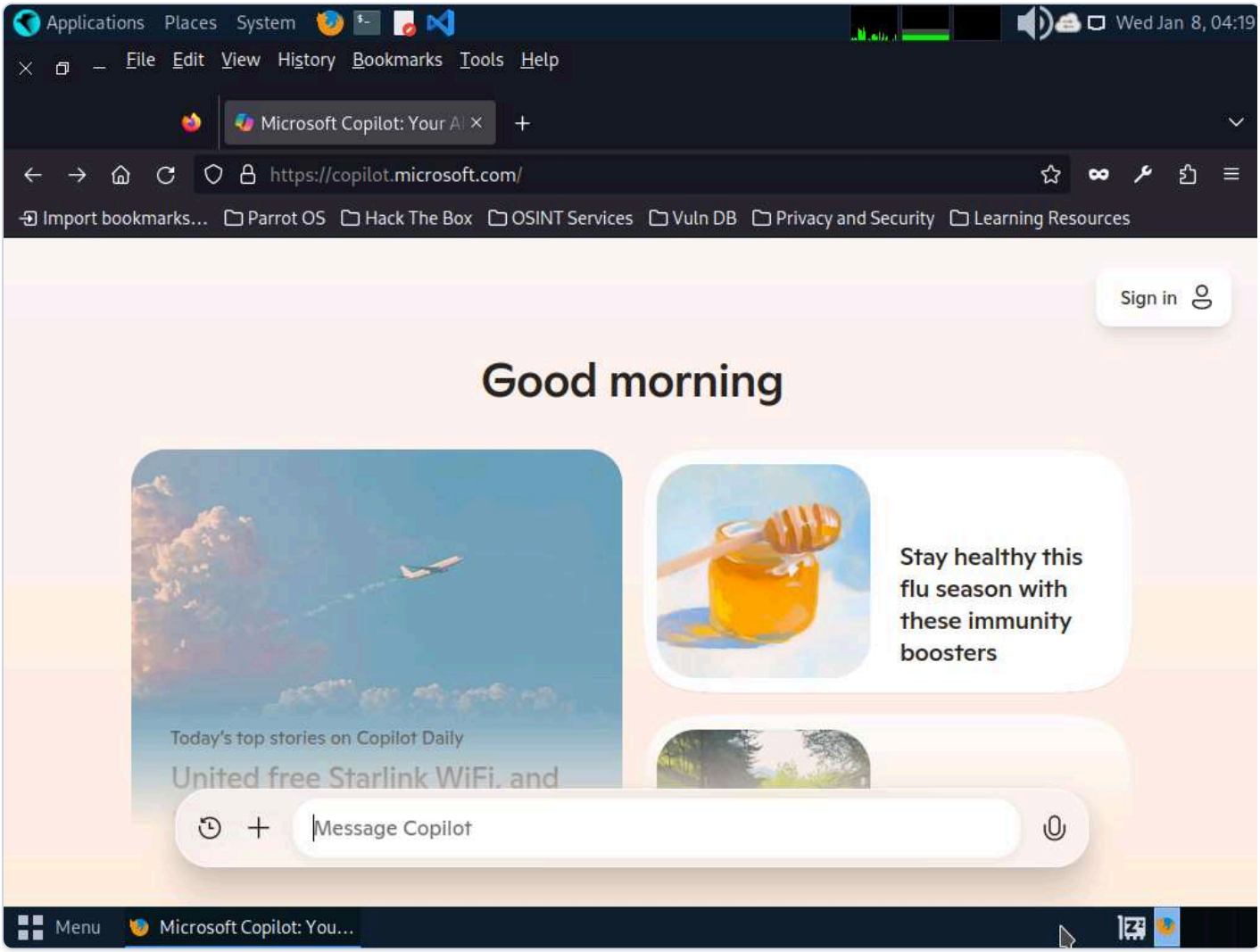
---

## Task 8: Automating Network Scanning using AI-Powered Tools

A penetration tester can use AI tools such as Microsoft Copilot to perform attack surface mapping. The objective of this lab is to allow students to use the AI tool and discover Live Hosts, scan different ports, and perform OS Banner Grabbing and Service Version Discovery.

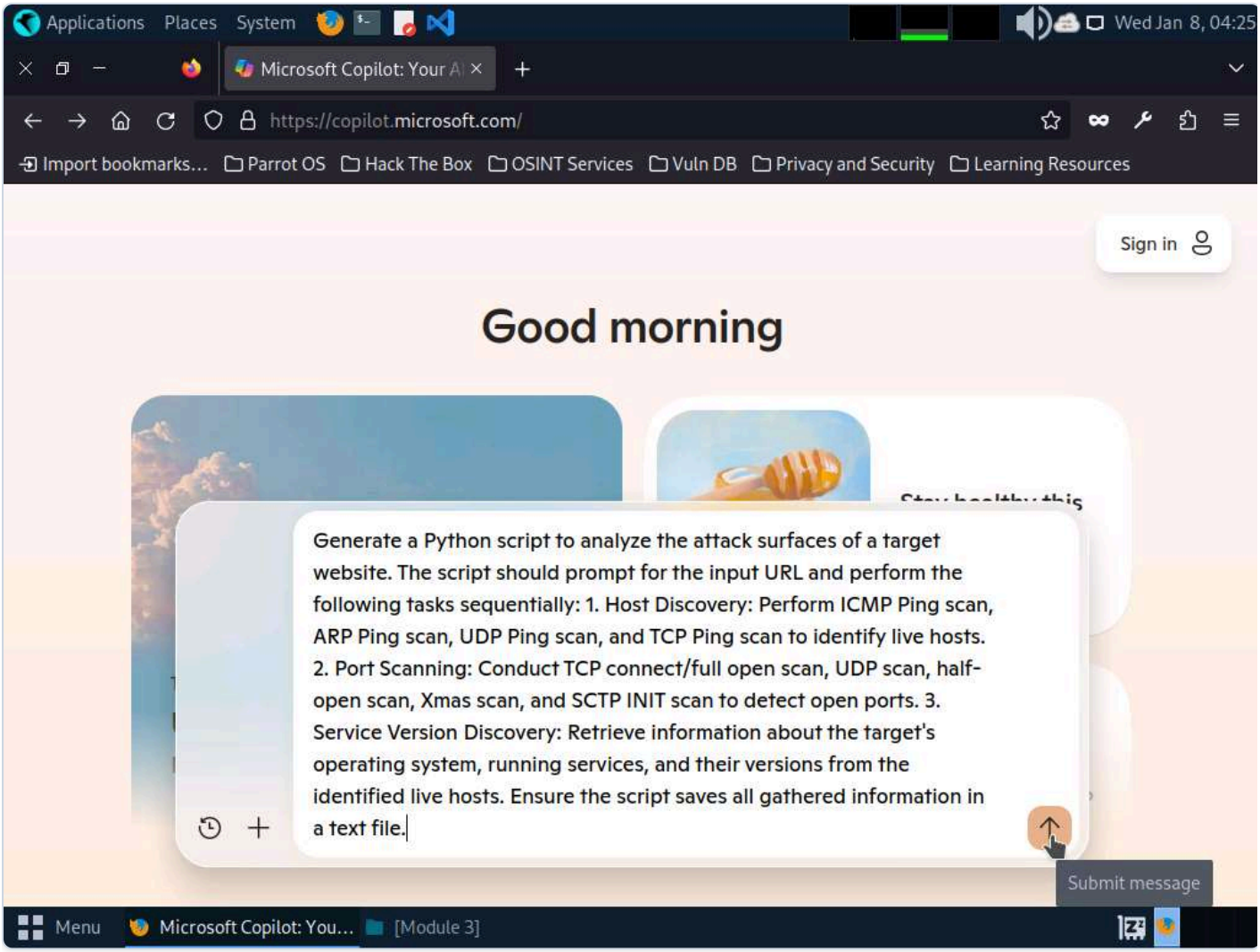
### Lab Tasks

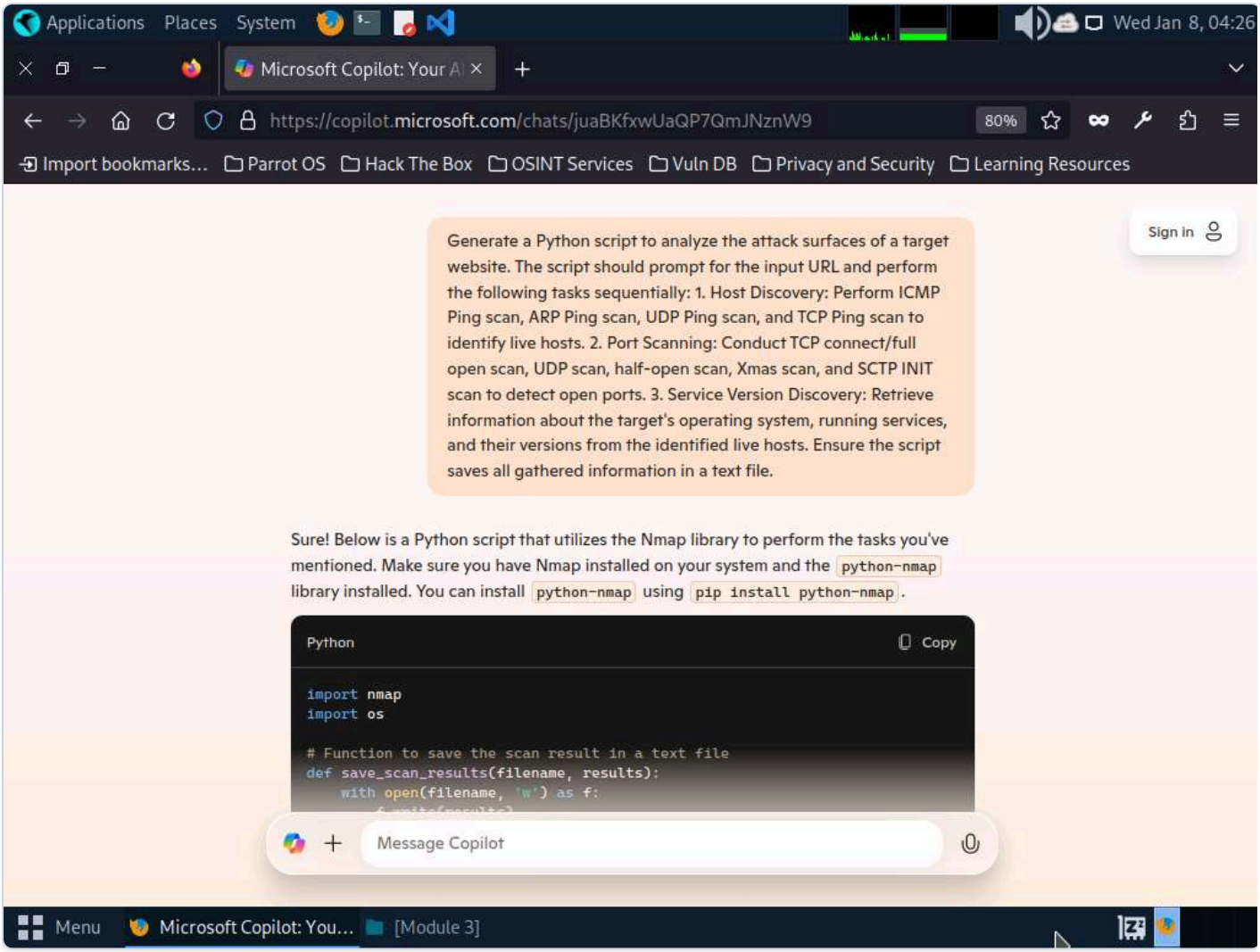
1. Click **Parrot Security** to switch to Parrot Security machine, open Mozilla Firefox, and go to any AI tool. (here, we are using Copilot: **https://copilot.microsoft.com**).



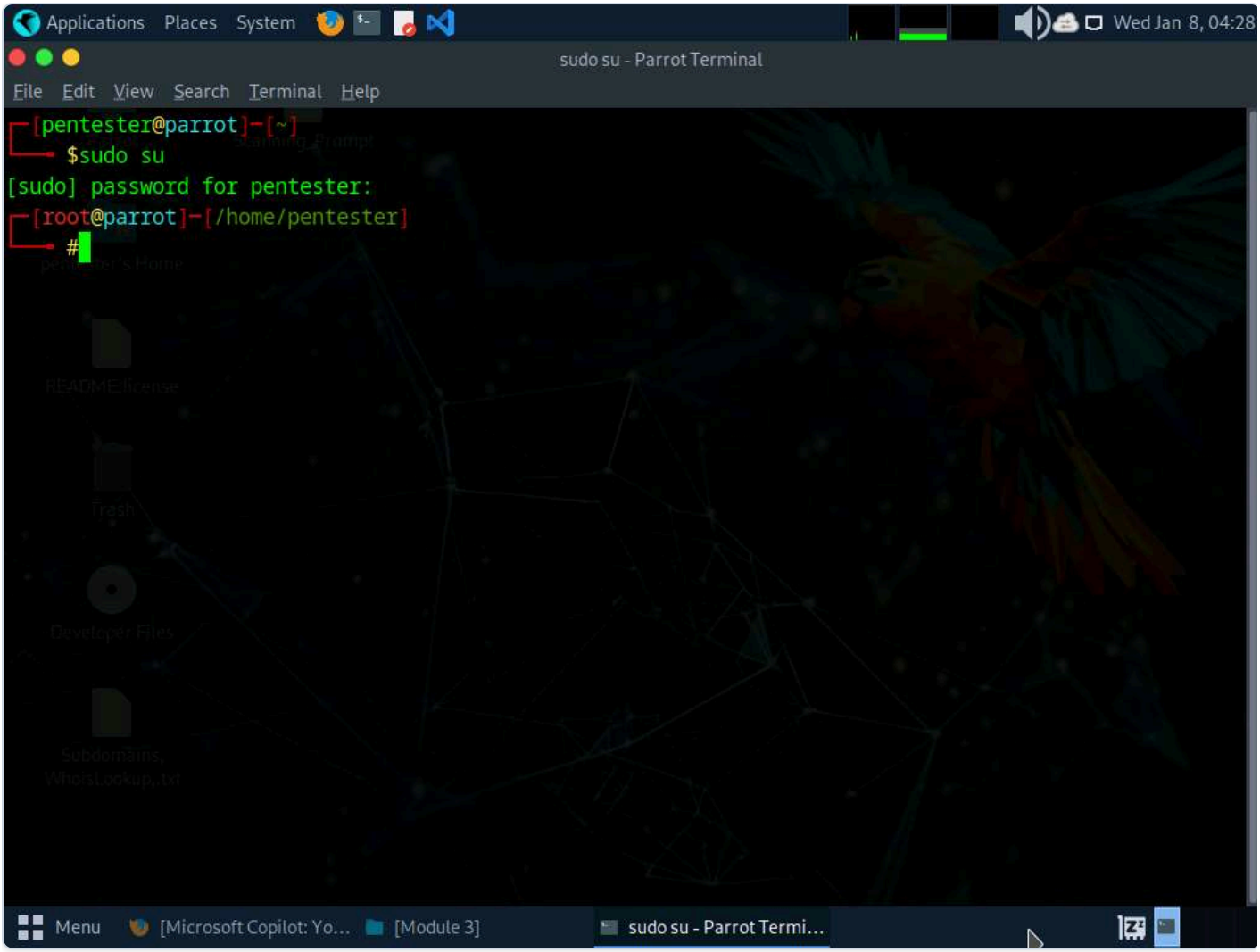

1. On the Message Copilot text box enter the below sample prompt for generating a Python Script for performing the attack surface mapping of the target IP or Network:

> *"Generate a Python script to analyze the attack surfaces of a target website. The script should prompt for the input URL and perform the following tasks sequentially: 1. Host Discovery: Perform ICMP Ping scan, ARP Ping scan, UDP Ping scan, and TCP Ping scan to identify live hosts. 2. Port Scanning: Conduct TCP connect/full open scan, UDP scan, half-open scan, Xmas scan, and SCTP INIT scan to detect open ports. 3. Service Version Discovery: Retrieve information about the target's operating system, running services, and their versions from the identified live hosts. Ensure the script saves all gathered information in a text file."*


Applications Places System
Wed Jan 8, 04:25
Microsoft Copilot: Your AI
https://copilot.microsoft.com/
Import bookmarks...
Parrot OS
Hack The Box
OSINT Services
Vuln DB
Privacy and Security
Learning Resources
Sign in
Good morning
Generate a Python script to analyze the attack surfaces of a target website. The script should prompt for the input URL and perform the following tasks sequentially: 1. Host Discovery: Perform ICMP Ping scan, ARP Ping scan, UDP Ping scan, and TCP Ping scan to identify live hosts. 2. Port Scanning: Conduct TCP connect/full open scan, UDP scan, half-open scan, Xmas scan, and SCTP INIT scan to detect open ports. 3. Service Version Discovery: Retrieve information about the target's operating system, running services, and their versions from the identified live hosts. Ensure the script saves all gathered information in a text file.
Submit message
Menu
Microsoft Copilot: You...
[Module 3]



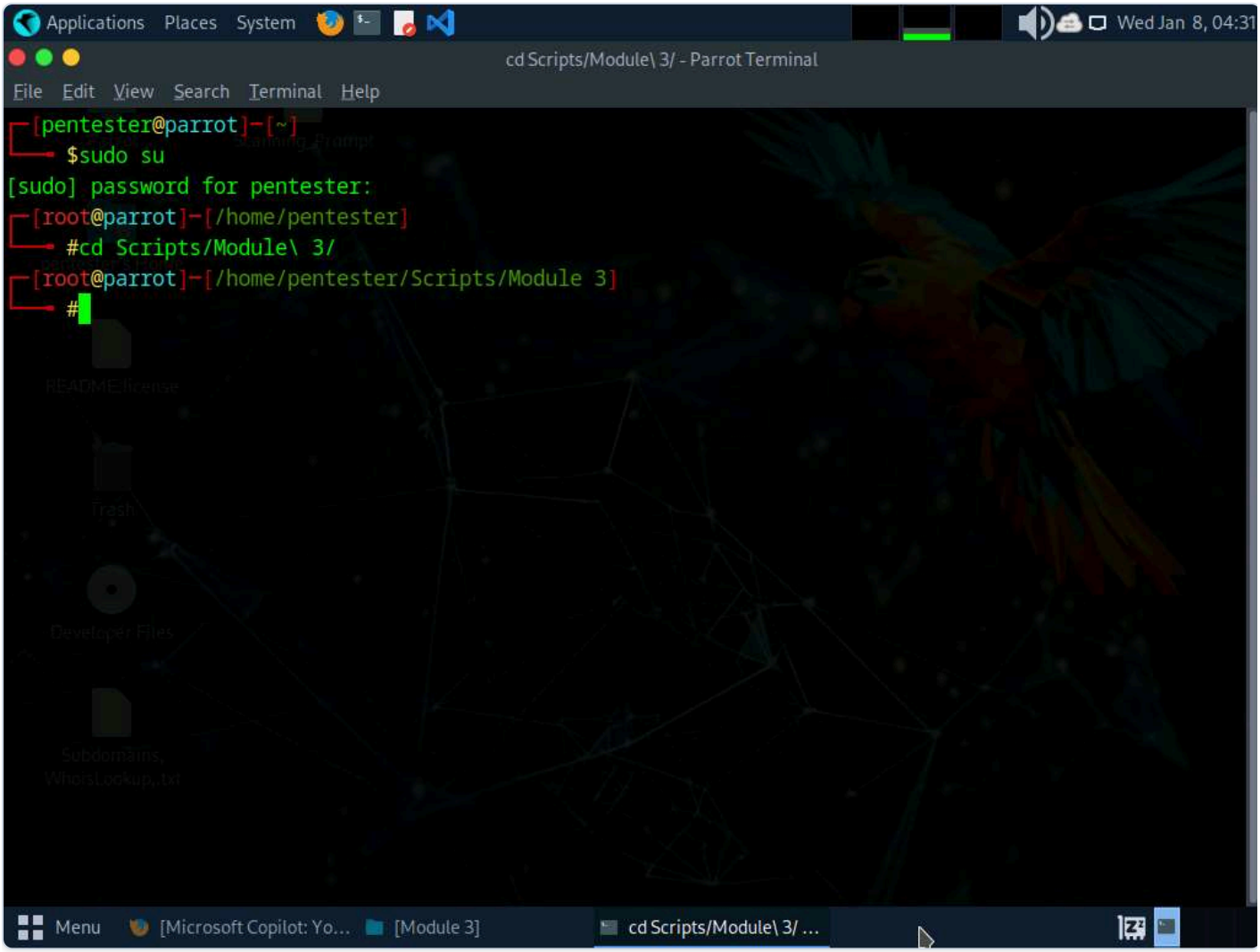

1. Save the obtained Script in a text file named **Attack_Surface_Mapping.py**.
2. Launch a command-line terminal. In the terminal window, type **sudo su** and press Enter. Type **toor** as the password.

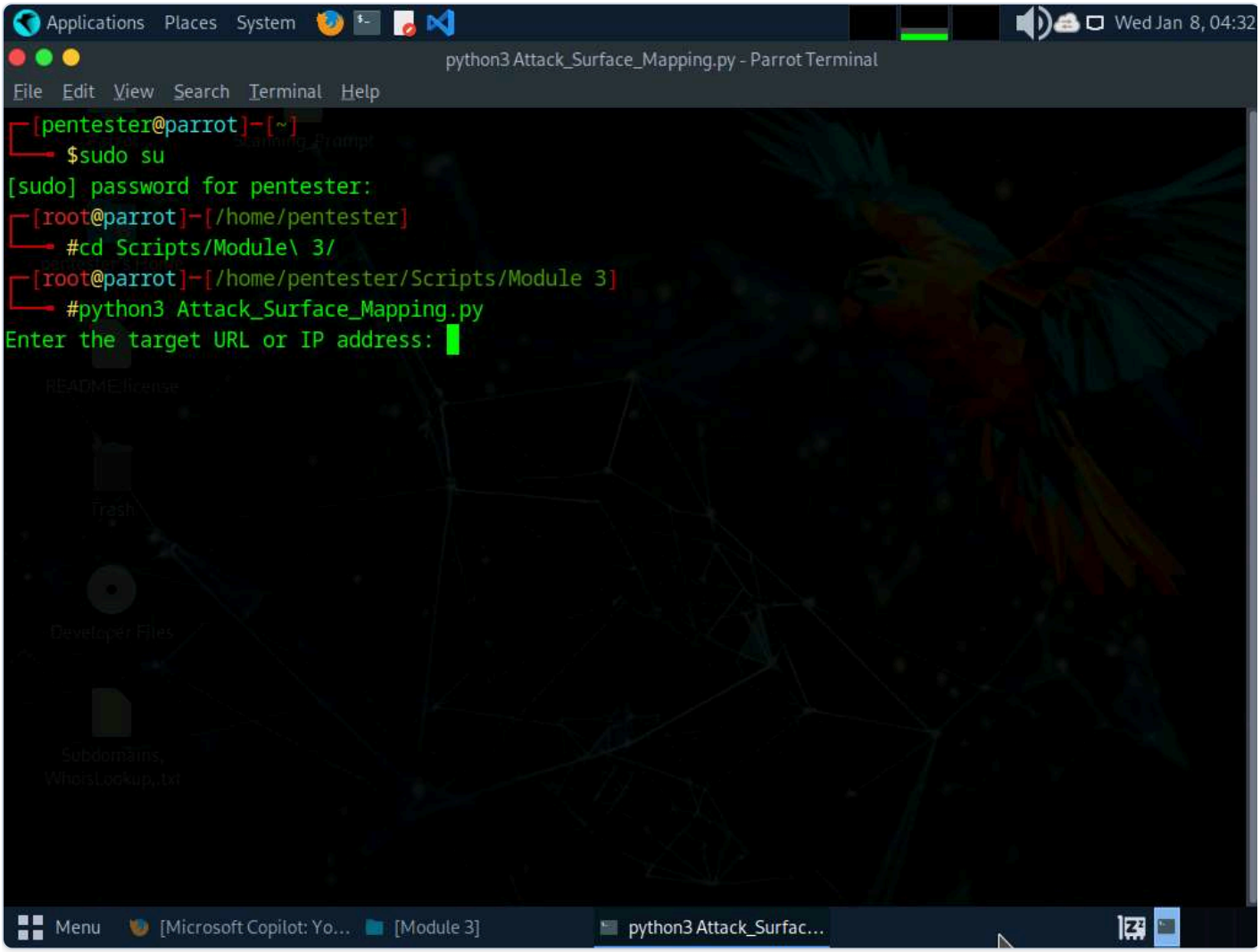



1. You can run the sample Python script that is already saved and available in the **CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 03 Open Source Intelligence (OSINT) and Attack Surface Mapping** location.

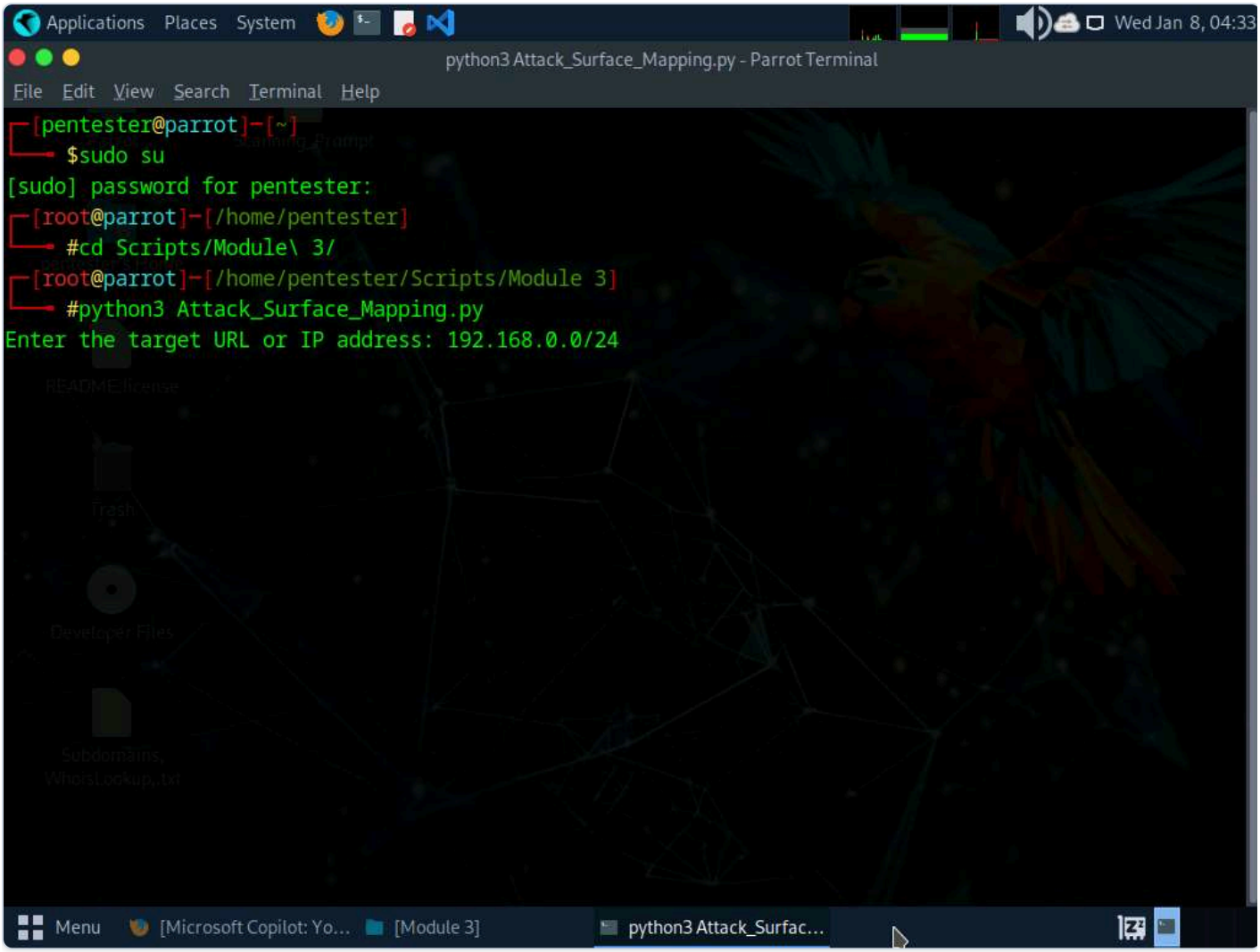
> **TIP:** 📁 **Local Repository Asset**: Inside your local vault, this script is saved at: `CPENTv2 Pen Testing Resources/CPENTv2 Scripts/Module 03 Open Source Intelligence (OSINT) and Attack Surface Mapping/Attack_Surface_Mapping.py`

1. Go to the location in the terminal, type **python3 Attack_Surface_Mapping.py** and press Enter. Once executed, it will ask you to enter the target URL or IP address that needs to be scanned.

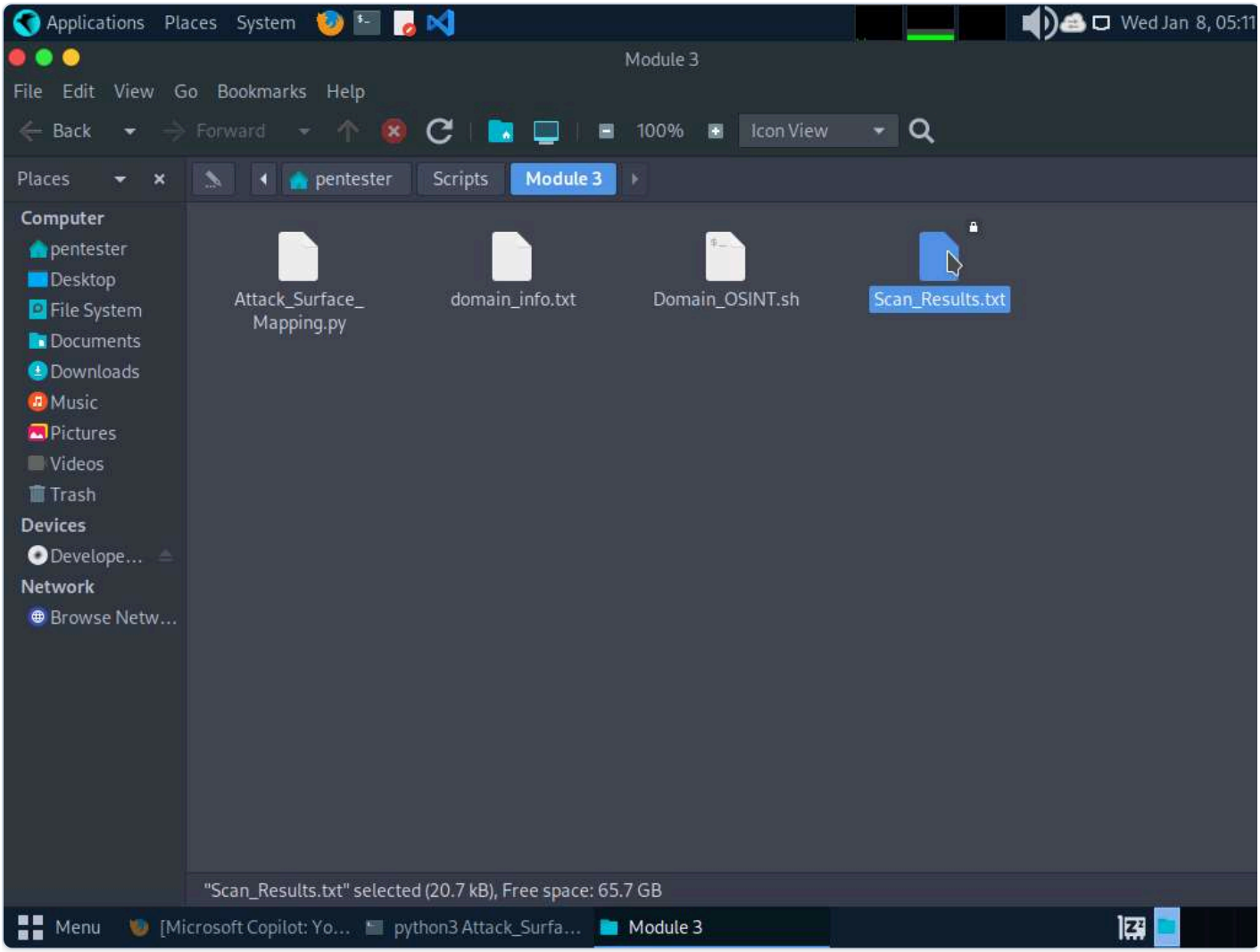

Applications Places System
Wed Jan 8, 04:31
cd Scripts/Module\ 3/ - Parrot Terminal
File Edit View Search Terminal Help
[pentester@parrot]-[~]
$sudo su
[sudo] password for pentester:
[root@parrot]-[/home/pentester]
#cd Scripts/Module\ 3/
[root@parrot]-[/home/pentester/Scripts/Module 3]
#
Menu
[Microsoft Copilot: Yo...
[Module 3]
cd Scripts/Module\ 3/ ...

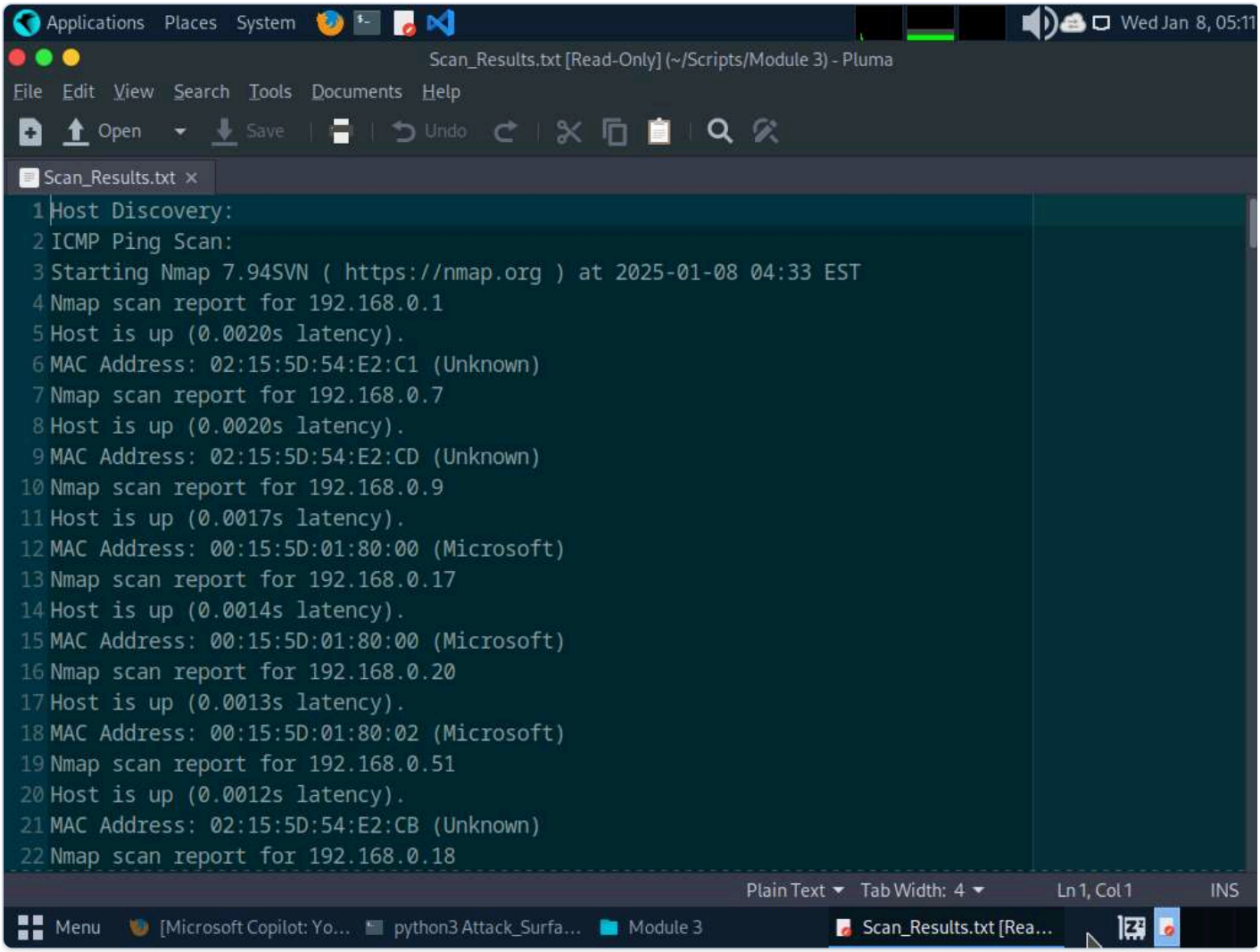


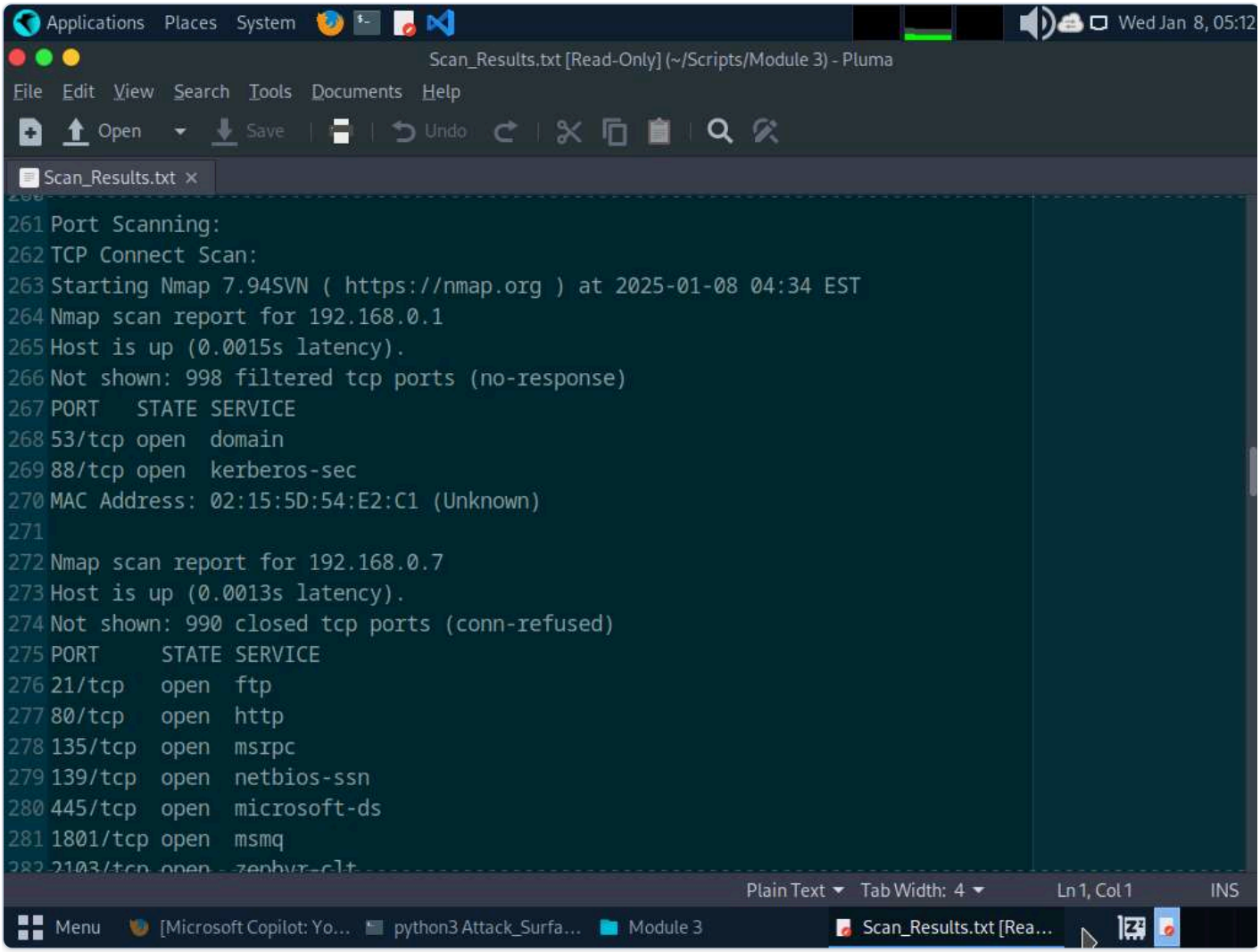

1. Type **192.168.0.0/24** and press Enter.

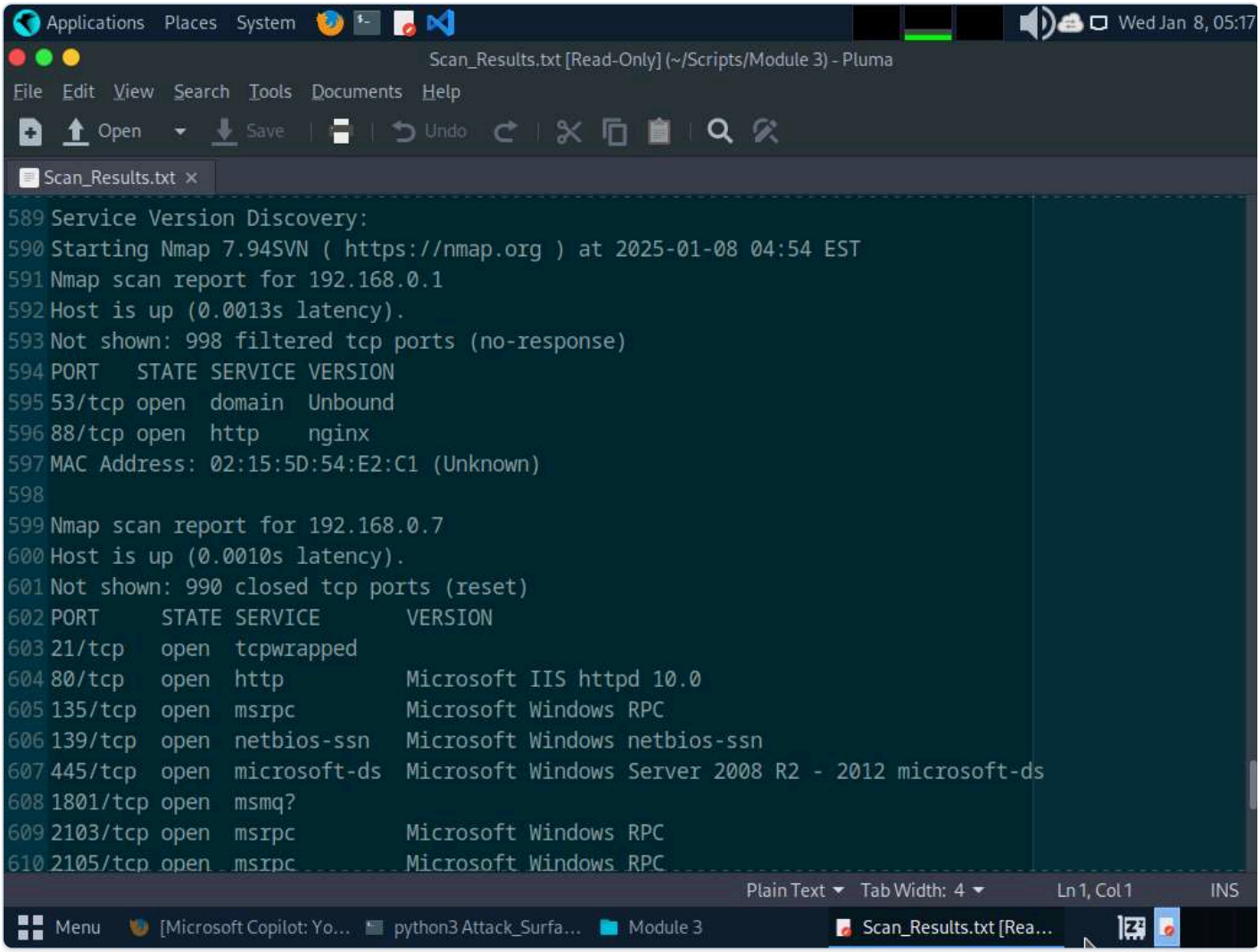



1. After the execution is completed, open the scan results file to analyze the output obtained as shown in the given screenshots:


Applications
Places
System
Wed Jan 8, 05:11
Module 3
File Edit View Go Bookmarks Help
Back
Forward
100%
Icon View
Places
pentester
Scripts
Module 3
Computer
pentester
Desktop
File System
Documents
Downloads
Music
Pictures
Videos
Trash
Devices
Develope...
Network
Browse Netw...
Attack_Surface_Mapping.py
domain_info.txt
Domain_OSINT.sh
Scan_Results.txt
"Scan_Results.txt" selected (20.7 kB), Free space: 65.7 GB
Menu
[Microsoft Copilot: Yo...
python3 Attack_Surfa...
Module 3


Applications Places System
Wed Jan 8, 05:11
Scan_Results.txt [Read-Only] (~/Scripts/Module 3) - Pluma
File Edit View Search Tools Documents Help
Open Save Undo
Scan_Results.txt
1 Host Discovery:
2 ICMP Ping Scan:
3 Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-01-08 04:33 EST
4 Nmap scan report for 192.168.0.1
5 Host is up (0.0020s latency).
6 MAC Address: 02:15:5D:54:E2:C1 (Unknown)
7 Nmap scan report for 192.168.0.7
8 Host is up (0.0020s latency).
9 MAC Address: 02:15:5D:54:E2:CD (Unknown)
10 Nmap scan report for 192.168.0.9
11 Host is up (0.0017s latency).
12 MAC Address: 00:15:5D:01:80:00 (Microsoft)
13 Nmap scan report for 192.168.0.17
14 Host is up (0.0014s latency).
15 MAC Address: 00:15:5D:01:80:00 (Microsoft)
16 Nmap scan report for 192.168.0.20
17 Host is up (0.0013s latency).
18 MAC Address: 00:15:5D:01:80:02 (Microsoft)
19 Nmap scan report for 192.168.0.51
20 Host is up (0.0012s latency).
21 MAC Address: 02:15:5D:54:E2:CB (Unknown)
22 Nmap scan report for 192.168.0.18
Plain Text Tab Width: 4 Ln 1, Col 1 INS
Menu [Microsoft Copilot: Yo... python3 Attack_Surfa... Module 3 Scan_Results.txt [Rea...


Applications Places System
Wed Jan 8, 05:12
Scan_Results.txt [Read-Only] (~/Scripts/Module 3) - Pluma
File Edit View Search Tools Documents Help
Open Save Undo
Scan_Results.txt
261 Port Scanning:
262 TCP Connect Scan:
263 Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-01-08 04:34 EST
264 Nmap scan report for 192.168.0.1
265 Host is up (0.0015s latency).
266 Not shown: 998 filtered tcp ports (no-response)
267 PORT STATE SERVICE
268 53/tcp open domain
269 88/tcp open kerberos-sec
270 MAC Address: 02:15:5D:54:E2:C1 (Unknown)
271
272 Nmap scan report for 192.168.0.7
273 Host is up (0.0013s latency).
274 Not shown: 990 closed tcp ports (conn-refused)
275 PORT STATE SERVICE
276 21/tcp open ftp
277 80/tcp open http
278 135/tcp open msrpc
279 139/tcp open netbios-ssn
280 445/tcp open microsoft-ds
281 1801/tcp open msmq
Plain Text Tab Width: 4 Ln 1, Col 1 INS
Menu [Microsoft Copilot: Yo... python3 Attack_Surfa... Module 3 Scan_Results.txt [Rea...




This concludes the lab task.

---

> **IMPORTANT:** ❓ **Question 3.5.8.1** On Parrot Security machine, utilize AI-powered tools to conduct a comprehensive scan of the target subnet (**192.168.0.0/24**) to identify active hosts, analyze open ports, perform OS banner grabbing, and determine service versions. Additionally, ascertain the operating system of the target machine (**192.168.0.20**). [!SUCCESS] ✅ **Answer:** **Windows**